

Evidence pack

Every answer in this round, with the passages it is drawn from.

Customer	Northwind Traders (journey)
Review	rev-551facf0dc99
Round	1 (rev-551facf0dc99-r1)
Framework	caiq
Data residency	us
Review state	drafting
Questions	312
Answered	309
Answers with citations	115 of 309
Sendable	62
Approved by a human	0
Generated	2026-08-17T17:45:56+00:00
Produced by	attestor-control-plane attestor-control-plane-00008-9m2 · attestor-505506 · us-central1

Release rule

Every question is listed and nothing is omitted. An answer marked approved was signed off by a named human. An answer marked drafted with citations is grounded in retrieved evidence and was not individually reviewed — the passages it relies on are listed beside it, with the document, section and relevance score, so the claim can be checked rather than trusted. An answer marked held, no evidence, quarantined or rejected must not be sent to a customer as an answer.

No — no supporting evidence found	189
Yes — drafted with citations, not individually reviewed	62
No — held for a human	53
No — quarantined by the guardrail	5
No — not answered in this round	3

Answers and evidence

1. Are passwords subject to a forced rotation schedule?

security · Q1 · Vendor Security Review row 2

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] access-control-standard — 9. Password requirements — relevance 0.67

9. Password requirements

Where a password is used, minimum length is 14 characters, checked against the Have I Been Pwned breached-password corpus at set time. Rotation is not forced on a schedule, in line with NIST SP 800-63B guidance; rotation is forced on evidence of compromise.

gs://attestor-505506-corporus/security/access-control-standard.txt

[2] access-control-standard — 1. Identity provider — relevance 0.60

1. Identity provider

All Kestrel Data systems authenticate through Okta (tenant `kestreldata.okta.com`). Local accounts on production systems are prohibited except for two documented break-glass accounts held in a sealed 1Password vault, whose use triggers a PagerDuty alert to the CISO. Both break-glass credentials were last rotated on 3 January 2026 and last used on 14 August 2025 during the

gs://attestor-505506-corporus/security/access-control-standard.txt

[3] access-control-standard — 7. Access reviews — relevance 0.58

7. Access reviews

Quarterly user access reviews cover all production systems, the AWS Organization, Snowflake, GitHub, and Okta itself. Reviews are performed by the system owner and attested in Vanta. The Q4 2025 review completed on 12 January 2026 and removed 23 entitlements, of which 9 were stale contractor accesses.

gs://attestor-505506-corporus/security/access-control-standard.txt

[4] access-control-standard — 2. Multi-factor authentication — relevance 0.58

2. Multi-factor authentication

Hardware-backed MFA (WebAuthn / FIDO2, YubiKey 5 series) is mandatory for every human account. SMS and TOTP were removed as acceptable factors on 30 June 2025 following the RISK-2025-0031 treatment plan. Coverage is 100% of the 187 active employee accounts and 100% of the 24 active contractor accounts, verified continuously by Vanta control AC-07.

gs://attestor-505506-corporus/security/access-control-standard.txt

[5] access-control-standard — 6. Joiners, movers, leavers — relevance 0.57

6. Joiners, movers, leavers

Joiners are provisioned via Okta Lifecycle Management from Rippling (HRIS); no access is granted before the background check clears. Movers have entitlements recalculated on role change, with the previous role revoked within 1 business day. Leavers have all access revoked automatically on the HRIS termination event: the target is 1 hour, and the measured median for

gs://attestor-505506-corporus/security/access-control-standard.txt

2. Are confidentiality obligations imposed on personnel, and do they survive termination?

legal · Q2 · Vendor Security Review row 3

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

3. Do you offer a single-tenant or dedicated instance deployment?

engineering · Q3 · Vendor Security Review row 4

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

4. Do you scan source code for committed secrets?

security · Q4 · Vendor Security Review row 5

Yes, Kestrel scans source code for committed secrets on every commit. This scanning is performed using Gitleaks at the pre-commit stage in combination with GitHub secret scanning with push protection (`vulnerability-management-policy`, Section 2: "Scanning coverage").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by SecurityAgent

Evidence (5)

[1] vulnerability-management-policy — 2. Scanning coverage — relevance 0.62

2. Scanning coverage

| Layer | Tool | Cadence |

|---|---|---|

| Dependencies (SCA) | Snyk Open Source | Every pull request, plus daily on `main` |

| Static analysis (SAST) | Semgrep + GitHub CodeQL | Every pull request |

| Container images | Amazon ECR enhanced scanning (Inspector) | On push, plus continuous rescan |

| Infrastructure | AWS Inspector, AWS Security Hub | Continuous |

| IaC | C

gs://attestor-505506-corpus/security/vulnerability-management-policy.txt

[2] vulnerability-management-policy — 5. Responsible disclosure — relevance 0.53

5. Responsible disclosure

Kestrel publishes a security contact at `kestreldata.com/.well-known/security.txt` and commits to acknowledging reports within 2 business days. Researchers acting in good faith under the published policy will not be pursued legally.

****Kestrel does not currently operate a paid bug bounty programme.**** Reports are handled through the responsible disclosure process above

gs://attestor-505506-corpus/security/vulnerability-management-policy.txt

[3] cloud-security-posture-standard — 8. Logging and evidence — relevance 0.52

8. Logging and evidence

CloudTrail (all regions, all accounts), VPC flow logs, GuardDuty findings, and Config history are delivered to a dedicated `kd-security` account that no engineering role can write to, with object lock set to 400 days. This is the arrangement that makes the audit trail defensible: the accounts that generate the evidence cannot alter it.

gs://attestor-505506-corpus/security/cloud-security-posture-standard.txt

[4] cloud-security-posture-standard — 4. Drift detection — relevance 0.52

4. Drift detection

Configuration drift is detected three ways:

1. ****Terraform Cloud drift detection**** runs every 24 hours against all 19 production workspaces and opens a PagerDuty ticket on any difference. Mean drift events per month in 2025: 1.4, nearly all from AWS-side attribute defaults changing.
2. ****AWS Config**** evaluates 147 rules continuously across every account, with the confo

gs://attestor-505506-corpus/security/cloud-security-posture-standard.txt

[5] vulnerability-management-policy — 4. Penetration testing — relevance 0.52

4. Penetration testing

An independent penetration test is commissioned ****annually**** at minimum, and additionally

before any significant architectural change. The most recent was performed by Include Security from 3 to 14 February 2026 (engagement INSEC-2026-0219). See the Penetration Test Executive Summary (KD-SEC-007).

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

5. Has your organisation been subject to a regulatory enforcement action?

legal · Q5 · Vendor Security Review row 6

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

6. Were any exceptions noted in your most recent SOC 2 report?

security · Q6 · Vendor Security Review row 7

No exceptions were noted in Kestrel Data's most recent SOC 2 report. For the audit period covering 1 January through 31 December 2025 (issued on 14 March 2026), the independent auditor, Prescient Assurance LLP, issued an unqualified opinion with no exceptions noted across the in-scope Trust Services Criteria of Security, Availability, and Confidentiality (`soc2-control-matrix`, Section "SOC 2 Control Matrix").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] risk-management-and-governance — 9. Exceptions — relevance 0.69

9. Exceptions

Exceptions to policy require: a written business justification, a compensating control, CISO approval, and an expiry date no later than 90 days out. Exceptions above residual score 12 additionally require Security Steering Group approval. Two exceptions were open as of 1 February 2026.

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[2] soc2-control-matrix — SOC 2 Control Matrix — relevance 0.67

SOC 2 Control Matrix

Document ID: KD-SEC-012 · **Version:** 2.1
Report period: 1 January - 31 December 2025 · **Report issued:** 14 March 2026
Auditor: Prescient Assurance LLP · **Opinion:** Unqualified, no exceptions noted
Trust Services Criteria in scope: Security, Availability, Confidentiality

Privacy and Processing Integrity are **not** in scope for the current report. Ke

gs://attestor-505506-corporus/security/soc2-control-matrix.txt

[3] risk-management-and-governance — Risk Management and Security Governance — relevance 0.65

Risk Management and Security Governance

Document ID: KD-SEC-018 · **Version:** 3.0 · **Owner:** Marcus Oyelaran, CISO
Approved: 26 January 2026 · **Next review:** 26 January 2027
Maps to: SOC 2 CC1.1, CC1.2, CC1.3, CC3.1, CC3.2, CC3.4 · ISO 27001:2022 A.5.1–A.5.4, Clauses 5–6, 9

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[4] data-handling-standard — 8. Exceptions — relevance 0.65

8. Exceptions

Exceptions require written CISO approval, a compensating control, and an expiry date not exceeding 90 days. Two exceptions were open as of 1 February 2026, both relating to the legacy TLS 1.2 SFTP integration scheduled for decommission on 30 June 2026.

gs://attestor-505506-corporus/security/data-handling-standard.txt

[5] soc2-control-matrix — Complementary user entity controls — relevance 0.64

Complementary user entity controls

The report identifies 6 controls that remain the customer responsibility, including

managing their own user accounts and entitlements within the Kestrel tenant, configuring SSO correctly, protecting API credentials issued to them, and reviewing their own audit logs. These are reproduced in full in Section 4 of the SOC 2 report.

gs://attestor-505506-corporate/security/soc2-control-matrix.txt

7. Do you operate a bug bounty programme?

security · Q7 · Vendor Security Review row 8

Kestrel does not currently operate a paid bug bounty programme. Instead, vulnerability reports are handled through a responsible disclosure process. Kestrel publishes a security contact at `kestreldata.com/.well-known/security.txt`, commits to acknowledging submissions within two business days, and provides safe harbour ensuring researchers acting in good faith under the published policy will not be pursued legally (Vulnerability Management Policy, Section 5, "Responsible disclosure").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by SecurityAgent

Evidence (5)

[1] vulnerability-management-policy — 5. Responsible disclosure — relevance 0.67

5. Responsible disclosure

Kestrel publishes a security contact at `kestreldata.com/.well-known/security.txt` and commits to acknowledging reports within 2 business days. Researchers acting in good faith under the published policy will not be pursued legally.

****Kestrel does not currently operate a paid bug bounty programme.**** Reports are handled through the responsible disclosure process above

gs://attestor-505506-corporate/security/vulnerability-management-policy.txt

[2] vulnerability-management-policy — 4. Penetration testing — relevance 0.57

4. Penetration testing

An independent penetration test is commissioned ****annually**** at minimum, and additionally before any significant architectural change. The most recent was performed by Include Security from 3 to 14 February 2026 (engagement INSEC-2026-0219). See the Penetration Test Executive Summary (KD-SEC-007).

gs://attestor-505506-corporate/security/vulnerability-management-policy.txt

[3] company-and-security-programme-overview — 3. Security programme in summary — relevance 0.57

3. Security programme in summary

The programme is built on four commitments, each evidenced elsewhere in this corpus rather than asserted here:

1. ****Independent verification.**** SOC 2 Type II (Prescient Assurance LLP, report issued 14 March 2026 covering 1 January – 31 December 2025, ****no exceptions****) and ISO 27001:2022 (BSI certificate `IS-2025-44817`, issued 22 September 2025, valid to 21

gs://attestor-505506-corporate/security/company-and-security-programme-overview.txt

[4] vulnerability-management-policy — 2. Scanning coverage — relevance 0.57

2. Scanning coverage

| Layer | Tool | Cadence |

|---|---|---|

| Dependencies (SCA) | Snyk Open Source | Every pull request, plus daily on `main` |

| Static analysis (SAST) | Semgrep + GitHub CodeQL | Every pull request |

| Container images | Amazon ECR enhanced scanning (Inspector) | On push, plus continuous rescan |

| Infrastructure | AWS Inspector, AWS Security Hub | Continuous |

| IaC | C

gs://attestor-505506-corporate/security/vulnerability-management-policy.txt

[5] company-and-security-programme-overview — Company and Security Programme Overview — relevance 0.56

Company and Security Programme Overview

****Document ID:**** KD-SEC-021 · ****Version:**** 4.2 · ****Owner:**** Marcus Oyelaran, CISO

****Approved:**** 6 February 2026 · ****Next review:**** 6 February 2027

****Maps to:**** SOC 2 CC1.1, CC1.2, CC2.1, CC2.3 · ISO 27001:2022 Clauses 4–5

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

8. Provide your data retention schedule.

legal · Q8 · Vendor Security Review row 9

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

9. Have you experienced a customer data breach in the last 3 years?

security · Q9 · Vendor Security Review row 10

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

10. Please confirm: Were any exceptions noted in your most recent SOC 2 report?

security · Q10 · Vendor Security Review row 11

No exceptions were noted in Kestrel Data's most recent SOC 2 Type II report. For the reporting period covering 1 January through 31 December 2025 (issued 14 March 2026), our independent auditor, Prescient Assurance LLP, issued an unqualified opinion with no exceptions noted across the in-scope Trust Services Criteria of Security, Availability, and Confidentiality (`soc2-control-matrix`, section "SOC 2 Control Matrix").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] soc2-control-matrix — SOC 2 Control Matrix — relevance 0.70

SOC 2 Control Matrix

****Document ID:**** KD-SEC-012 · ****Version:**** 2.1

****Report period:**** 1 January - 31 December 2025 · ****Report issued:**** 14 March 2026

****Auditor:**** Prescient Assurance LLP · ****Opinion:**** Unqualified, no exceptions noted

****Trust Services Criteria in scope:**** Security, Availability, Confidentiality

Privacy and Processing Integrity are ****not**** in scope for the current report. Ke

gs://attestor-505506-corporus/security/soc2-control-matrix.txt

[2] risk-management-and-governance — 9. Exceptions — relevance 0.68

9. Exceptions

Exceptions to policy require: a written business justification, a compensating control, CISO approval, and an expiry date no later than 90 days out. Exceptions above residual score 12 additionally require Security Steering Group approval. Two exceptions were open as of 1 February 2026.

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[3] access-control-standard — 5. Customer data access — relevance 0.66

5. Customer data access

Kestrel personnel do not access customer production data as a matter of routine. Access for support purposes requires explicit per-incident customer authorisation recorded in Zendesk, is limited to the specific tenant, and expires after 24 hours.

Between 1 January and 31 December 2025 there were 19 such authorised accesses across 7 customers, each evidenced in the SOC

gs://attestor-505506-corporus/security/access-control-standard.txt

[4] risk-management-and-governance — Risk Management and Security Governance — relevance 0.66

gs://attestor-505506-corporate/security/risk-management-and-governance.txt

[5] soc2-control-matrix — Complementary user entity controls — relevance 0.66

Complementary user entity controls

The report identifies 6 controls that remain the customer responsibility, including managing their own user accounts and entitlements within the Kestrel tenant, configuring SSO correctly, protecting API credentials issued to them, and reviewing their own audit logs. These are reproduced in full in Section 4 of the SOC 2 report.

gs://attestor-505506-corporate/security/soc2-control-matrix.txt

11. For each applicable system: Describe the data flow for customer data through your platform.

engineering · Q11 · Vendor Security Review row 12

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

12. Describe the security controls applied to your cloud service provider accounts.

security · Q12 · Vendor Security Review row 13

Kestrel Data secures its cloud service provider environment using a multi-account AWS Organization architecture governed by central guardrails, federated access, and isolated security logging: ****Account Structure and Central Guardrails:**** As outlined in the ***Cloud Security Posture and Configuration Standard (Section 1. Account structure and guardrails)***, Kestrel operates an AWS Organization comprising six member accounts and a dedicated management account that hosts no workloads. Organization-level Service Control Policies (SCPs) enforce baseline security controls centrally, preventing non-compliant configurations at the platform level: ***`deny-root-user`**: Prohibits root credentials from performing actions outside break-glass scenarios. ***`deny-region-except-approved`**: Restricts usage exclusively to **`us-east-1`**, **`eu-west-1`**, and **`us-east-2`** (backup). ***`deny-cloudtrail-disable`**: Prevents disabling or deleting CloudTrail across all accounts. ***`deny-guardduty-disable`**: Prevents GuardDuty suspension. ***`deny-public-s3`**: Enforces and prevents removal of the account-level S3 Public Access Block. ***`deny-kms-key-delete`**: Prevents scheduling customer master keys (KMS) for deletion. ***`deny-imdsv1`**: Disallows launching EC2 instances requiring IMDSv1. ****Cloud Identity and Access Management:**** Per the ***Cloud Security Posture and Configuration Standard (Section 7. Cloud identity)***, human access to AWS accounts is federated from Okta through IAM Identity Center. There are zero IAM users with long-lived access keys in the estate, an enforcement maintained by SCPs, while workloads authenticate using IAM Roles for Service Accounts (IRSA). ****Isolated Evidence and Tamper-Resistant Logging:**** Under the ***Cloud Security Posture and Configuration Standard (Section 8. Logging and evidence)*** and the ***Logging and Monitoring Standard (Section 3. Tamper resistance)***, all CloudTrail records, VPC flow logs, GuardDuty findings, and Config history across all accounts and regions are delivered directly to a dedicated **`kd-security`** account. Engineering roles have no write access to this destination, and the audit logs are protected by S3 Object Lock in compliance mode set to 400 days, ensuring the audit trail cannot be modified or deleted.

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (8)

[1] cloud-security-posture-standard — 8. Logging and evidence — relevance 0.69

8. Logging and evidence

CloudTrail (all regions, all accounts), VPC flow logs, GuardDuty findings, and Config history are delivered to a dedicated **`kd-security`** account that no engineering role can write to, with object lock set to 400 days. This is the arrangement that makes the audit trail defensible: the accounts that generate the evidence cannot alter it.

gs://attestor-505506-corporate/security/cloud-security-posture-standard.txt

[2] cloud-security-posture-standard — 1. Account structure and guardrails — relevance 0.68

1. Account structure and guardrails

Kestrel runs an AWS Organization with six accounts and a dedicated management account that holds no workloads. **Organisation-level Service Control Policies enforce security configuration centrally**, so a misconfiguration in a member account is refused by the platform rather than caught later by a report. The enforced SCPs are:

```
| SCP | Effect |  
|---|---|  
| de
```

gs://attestor-505506-corpus/security/cloud-security-posture-standard.txt

[3] soc2-control-matrix — Complementary user entity controls — relevance 0.67

Complementary user entity controls

The report identifies 6 controls that remain the customer responsibility, including managing their own user accounts and entitlements within the Kestrel tenant, configuring SSO correctly, protecting API credentials issued to them, and reviewing their own audit logs. These are reproduced in full in Section 4 of the SOC 2 report.

gs://attestor-505506-corpus/security/soc2-control-matrix.txt

[4] logging-monitoring-standard — 3. Tamper resistance — relevance 0.65

3. Tamper resistance

The security archive bucket uses S3 Object Lock in **compliance mode**, which cannot be disabled or shortened by any principal including the AWS account root. CloudTrail log file integrity validation is enabled. The archive account is a separate AWS account with no human standing access; writes arrive only through the organisation trail.

gs://attestor-505506-corpus/security/logging-monitoring-standard.txt

[5] cloud-security-posture-standard — Cloud Security Posture and Configuration Standard — relevance 0.64

Cloud Security Posture and Configuration Standard

Document ID: KD-SEC-017 · **Version:** 1.8 · **Owner:** Dana Whitfield, VP Engineering

Approved: 29 January 2026 · **Next review:** 29 January 2027

Maps to: SOC 2 CC6.1, CC7.1, CC8.1 · ISO 27001:2022 A.8.9, A.8.19, A.8.32

gs://attestor-505506-corpus/security/cloud-security-posture-standard.txt

[6] access-control-standard — 3. Role-based access — relevance 0.64

3. Role-based access

Access is granted to Okta groups, never to individuals. There are 41 defined roles, each mapping to a documented entitlement set in the Access Matrix (`SEC-GOV/access-matrix`), which is the authoritative record reviewed during audit. Standing production access is limited to 11 named Site Reliability Engineers. All other production access is just-in-time.

gs://attestor-505506-corpus/security/access-control-standard.txt

[7] soc2-control-matrix — Common Criteria — relevance 0.63

Common Criteria

```
| Control | Description | Evidence | Test result |
```

```
|---|---|---|---|
```

```
| CC1.1 | Board oversight of security; Audit and Risk Committee meets quarterly | Committee minutes, 4 meetings in 2025 | No exceptions
```

```
|
```

```
| CC1.4 | Security awareness training at hire and annually | Curricula completion records, 100% of active staff | No exceptions |
```

```
| CC2.1 | Internal communication of security
```

gs://attestor-505506-corpus/security/soc2-control-matrix.txt

[8] cloud-security-posture-standard — 7. Cloud identity — relevance 0.63

7. Cloud identity

Human access to AWS is federated from Okta through IAM Identity Center; there are **no IAM users with long-lived access keys in any account**, and the SCP set prevents their creation. Workloads use IAM Roles for Service Accounts. The last static access key in the estate was decommissioned on 17 November 2024.

gs://attestor-505506-corpus/security/cloud-security-posture-standard.txt

13. How is uptime measured, and by whom?

engineering · Q13 · Vendor Security Review row 14

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

14. Will you provide an SBOM on request?

engineering · Q14 · Vendor Security Review row 15

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

15. Where is your service status published?

engineering · Q15 · Vendor Security Review row 16

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

16. Do you run simulated phishing exercises? Provide the most recent click rate.

security · Q16 · Vendor Security Review row 17

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] personnel-security-and-training — 5. Simulated phishing — relevance 0.68

5. Simulated phishing

Kestrel runs simulated phishing exercises **quarterly** through Curricula, targeting all personnel with a Kestrel mailbox. Results for 2025:

Quarter	Sent	Click rate	Credential submission	Reported to security
Q1 2025	198	6.1%	1.0%	41%
Q2 2025	203	4.4%	0.5%	52%
Q3 2025	208	3.4%	0.0%	58%
Q4 2025	211	**2		

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

[2] personnel-security-and-training — 4. Security awareness training — relevance 0.55

4. Security awareness training

Security awareness training is **mandatory** for all personnel, annually, plus at onboarding within the first 14 days. Training is delivered through Curricula and runs approximately 45 minutes, covering phishing, credential handling, data classification, secure remote working, and incident reporting.

Measured completion for the 2025 cycle was **99.5%** (210 of 211 i

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

[3] information-security-policy — 6. Personnel security — relevance 0.53

6. Personnel security

All employees and contractors undergo background screening appropriate to jurisdiction before their start date, conducted by Checkr. Screening covers identity verification, right to work, criminal records where lawful, and employment history for the preceding

seven years.

Security awareness training is delivered through Curricula at onboarding and annually thereafter. Comple

gs://attestor-505506-corporus/security/information-security-policy.txt

[4] personnel-security-and-training — 6. Secure development training — relevance 0.51

6. Secure development training

Engineers complete role-specific secure development training annually, in addition to the general awareness training. The 2025 curriculum was Secure Code Warrior's OWASP Top 10 path plus an internal module on tenant isolation written by the platform team after the INSEC-2026-0219 penetration test. Completion for the 63 engineers in scope was 100% as of 19 December 20

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

[5] personnel-security-and-training — 3. Acceptable use and policy acknowledgement — relevance 0.48

3. Acceptable use and policy acknowledgement

Personnel acknowledge the Acceptable Use Policy (KD-SEC-005) and this standard at onboarding and annually thereafter. Acknowledgement is tracked in Vanta; the 2025 annual cycle closed on 30 November 2025 at **100%** completion across 187 employees and 24 contractors.

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

17. How long do backups containing deleted customer data persist?

engineering · Q17 · Vendor Security Review row 18

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

18. What security events are logged and for how long are they retained?

security · Q18 · Vendor Security Review row 19

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

19. Are key administrators and key users separated?

security · Q19 · Vendor Security Review row 20

Yes, key administrators and key users are strictly separated as disjoint sets. No individual holds both roles, a separation enforced at the AWS Organization level via a Service Control Policy (SCP). Furthermore, key policies restrict the use of customer-facing AWS KMS Customer Managed Keys (CMKs) to named service roles ('encryption-standard', Section 3. Key management).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] encryption-standard — 3. Key management — relevance 0.69

3. Key management

Customer-facing encryption keys are AWS KMS Customer Managed Keys. Key policies restrict use to named service roles. Key administrators and key users are disjoint sets: no individual holds both roles, enforced by a Service Control Policy at the AWS Organization level.

Automatic annual rotation is enabled on all CMKs. Manual rotation is triggered on suspected compromise. Ke

gs://attestor-505506-corporus/security/encryption-standard.txt

[2] encryption-standard — 4. Customer-managed encryption keys — relevance 0.63

4. Customer-managed encryption keys

Enterprise-tier customers may supply their own key material for the Snowflake data layer through Tri-Secret Secure. As of 1 February 2026, 3 customers use this option. CMEK is **not** currently offered for the RDS or S3 tiers. That limitation is stated explicitly in the Security Addendum (KD-LEG-008) rather than glossed over.

gs://attestor-505506-corporus/security/encryption-standard.txt

[3] access-control-standard — 3. Role-based access — relevance 0.59

3. Role-based access

Access is granted to Okta groups, never to individuals. There are 41 defined roles, each mapping to a documented entitlement set in the Access Matrix (`SEC-GOV/access-matrix`), which is the authoritative record reviewed during audit. Standing production access is limited to 11 named Site Reliability Engineers. All other production access is just-in-time.

gs://attestor-505506-corporus/security/access-control-standard.txt

[4] encryption-standard — Encryption Standard — relevance 0.59

Encryption Standard

Document ID: KD-SEC-003 · **Version:** 2.4 · **Owner:** Marcus Oyelaran, CISO
Approved: 8 January 2026 · **Next review:** 8 January 2027
Maps to: SOC 2 CC6.7 · ISO 27001:2022 A.8.24 · GDPR Art. 32(1)(a)

gs://attestor-505506-corporus/security/encryption-standard.txt

[5] encryption-standard — 1. Data at rest — relevance 0.58

1. Data at rest

All customer data at rest is encrypted using **AES-256-GCM**. No customer data is stored unencrypted at any tier.

| Store | Mechanism | Key custody |

|---|---|---|

| Amazon RDS (PostgreSQL 16) | Storage-level encryption | AWS KMS CMK, per-environment |

| Amazon S3 | SSE-KMS | AWS KMS CMK, per-bucket |

| Snowflake | Native encryption, Tri-Secret Secure | Customer-managed key

gs://attestor-505506-corporus/security/encryption-standard.txt

20. Is the service directed at children under 16?

legal · Q20 · Vendor Security Review row 21

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

21. Please confirm: Do you publish a modern slavery or supply chain labour statement?

legal · Q21 · Vendor Security Review row 22

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] security-addendum — 4. Incident notification — relevance 0.53

4. Incident notification

- Personal data breach: notification within **72 hours** of confirmation.
- Confirmed unauthorised access to customer production data: **24 hours**.
- Notification content as set out in the DPA Section 7.

gs://attestor-505506-corporus/legal/security-addendum.txt

[2] security-addendum — 3. Access commitments — relevance 0.50

3. Access commitments

- Multi-factor authentication mandatory for all Kestrel personnel with production access.
- Production access on a least-privilege, just-in-time basis, expiring within 8 hours.
- No routine Kestrel access to customer production data; support access requires per-incident customer authorisation.
- Access revoked within 24 hours of personnel departure. Measured median in 2

gs://attestor-505506-corporus/legal/security-addendum.txt

[3] security-addendum — 1. Certifications maintained — relevance 0.49

1. Certifications maintained

Kestrel will maintain, for the term of the Agreement, a SOC 2 Type II report covering Security, Availability, and Confidentiality, and ISO/IEC 27001:2022 certification. Current reports are made available annually within 30 days of issuance.

If a certification lapses or an audit opinion is qualified, Kestrel will notify affected customers within **10 business days

gs://attestor-505506-corporus/legal/security-addendum.txt

[4] security-addendum — Security Addendum — relevance 0.49

Security Addendum

****Document ID:**** KD-LEG-008 · ****Version:**** 3.1 · ****Owner:**** Marcus Oyelaran, CISO
****Effective:**** 1 February 2026 · Forms part of the Master Subscription Agreement

This addendum states the security commitments Kestrel makes contractually. It is deliberately narrower than the Information Security Policy: everything here is an obligation, not an aspiration.

gs://attestor-505506-corporus/legal/security-addendum.txt

[5] security-addendum — 8. Changes — relevance 0.48

8. Changes

Kestrel may update this addendum, provided that no update materially reduces the commitments during a paid term. Material changes are notified 30 days in advance.

gs://attestor-505506-corporus/legal/security-addendum.txt

22. What is your API deprecation policy?

engineering · Q22 · Vendor Security Review row 23

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

23. Describe your security incident classification scheme. Provide supporting evidence.

security · Q23 · Vendor Security Review row 24

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

24. What is your post-quantum cryptography readiness posture?

security · Q24 · Vendor Security Review row 25

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

25. For which data are you the controller?

legal · Q25 · Vendor Security Review row 26

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] data-processing-agreement — 1. Roles — relevance 0.69

1. Roles

Customer is **Controller**. Kestrel Data, Inc. is **Processor**. Where Customer is itself a processor for its own customers, Kestrel is sub-processor and the same obligations apply down the chain.

Kestrel is **Controller** for a limited set of data it determines the purposes of: account administrator contact details, billing records, and product telemetry described in Annex 3.

gs://attestor-505506-corpus/legal/data-processing-agreement.txt

[2] data-subject-rights-procedure — 1. Which rights, and against whom — relevance 0.68

1. Which rights, and against whom

For customer content, Kestrel is the **processor** and the customer is the controller. A data subject who approaches Kestrel directly about customer content is redirected to the relevant customer without undue delay and, where Kestrel can identify the customer, within **3 business days**. Kestrel does not respond substantively on the controller's behalf.

For data

gs://attestor-505506-corpus/legal/data-subject-rights-procedure.txt

[3] privacy-policy — 2. What we collect as controller — relevance 0.67

2. What we collect as controller

| Category | Examples | Lawful basis | Retention |

| ---|---|---|---|

| Account data | Name, work email, job title, company | Contract (Art. 6(1)(b)) | Term + 3 years |

| Billing data | Billing contact, VAT number, payment method token | Contract; legal obligation | 7 years (tax) |

| Product telemetry | Feature usage, page views, error events | Legitimate interest

gs://attestor-505506-corpus/legal/privacy-policy.txt

[4] gdpr-records-of-processing — Part A - Kestrel as Processor (Art. 30(2)) — relevance 0.66

Part A - Kestrel as Processor (Art. 30(2))

Controller: each Kestrel customer, as identified in the applicable Order Form.

Processor: Kestrel Data, Inc.

DPO: Priya Raghunathan, `dpo@kestreldata.com`

| # | Processing activity | Categories of data subject | Categories of personal data | Transfers | Retention |

| ---|---|---|---|---|

| P1 | Hosting and operating the Kestrel Insig

gs://attestor-505506-corpus/legal/gdpr-records-of-processing.txt

[5] gdpr-records-of-processing — Part B - Kestrel as Controller (Art. 30(1)) — relevance 0.65

Part B - Kestrel as Controller (Art. 30(1))

| # | Purpose | Lawful basis | Data subjects | Personal data | Retention |

| ---|---|---|---|---|

| C1 | Account administration | Art. 6(1)(b) contract | Customer administrators | Name, work email, job title | Term + 3 years |

| C2 | Billing and tax | Art. 6(1)(b), 6(1)(c) | Billing contacts | Name, email, VAT, payment token | 7 years |

| C3 | Pro

gs://attestor-505506-corpus/legal/gdpr-records-of-processing.txt

26. Please confirm: What service credits apply if the availability commitment is missed?

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

27. Do you use organisation-level guardrails to enforce security configuration?

security · Q27 · Vendor Security Review row 28

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] cloud-security-posture-standard — 1. Account structure and guardrails — relevance 0.70

1. Account structure and guardrails

Kestrel runs an AWS Organization with six accounts and a dedicated management account that holds no workloads. **Organisation-level Service Control Policies enforce security configuration centrally**, so a misconfiguration in a member account is refused by the platform rather than caught later by a report. The enforced SCPs are:

```
| SCP | Effect |  
|---|---|  
| de
```

gs://attestor-505506-corpus/security/cloud-security-posture-standard.txt

[2] cloud-security-posture-standard — 8. Logging and evidence — relevance 0.62

8. Logging and evidence

CloudTrail (all regions, all accounts), VPC flow logs, GuardDuty findings, and Config history are delivered to a dedicated `kd-security` account that no engineering role can write to, with object lock set to 400 days. This is the arrangement that makes the audit trail defensible: the accounts that generate the evidence cannot alter it.

gs://attestor-505506-corpus/security/cloud-security-posture-standard.txt

[3] access-control-standard — 3. Role-based access — relevance 0.61

3. Role-based access

Access is granted to Okta groups, never to individuals. There are 41 defined roles, each mapping to a documented entitlement set in the Access Matrix (`SEC-GOV/access-matrix`), which is the authoritative record reviewed during audit. Standing production access is limited to 11 named Site Reliability Engineers. All other production access is just-in-time.

gs://attestor-505506-corpus/security/access-control-standard.txt

[4] network-security-standard — 6. Internal application access — relevance 0.60

6. Internal application access

There is no traditional VPN. Internal applications are published through Cloudflare Access with device posture and Okta identity required on every request. This is a zero-trust model in the practical sense: there is no network position that grants access, and being "inside" confers nothing.

gs://attestor-505506-corpus/security/network-security-standard.txt

[5] information-security-policy — 7. Access control — relevance 0.60

7. Access control

Access follows least privilege and is governed by the Access Control Standard (KD-SEC-002). Identity is federated through Okta with SAML 2.0. Hardware-backed multi-factor authentication (WebAuthn / FIDO2 security keys) is mandatory for all staff; SMS and TOTP were retired as authentication factors on 30 June 2025.

Production access requires a documented business justification, e

gs://attestor-505506-corpus/security/information-security-policy.txt

28. Do engineers receive secure development training?

engineering · Q28 · Vendor Security Review row 29

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (8)

[1] sdlc-policy — Secure Software Development Lifecycle Policy — relevance 0.61

Secure Software Development Lifecycle Policy

Document ID: KD-ENG-001 · **Version:** 4.1 · **Owner:** Dana Whitfield, VP Engineering

Approved: 20 January 2026 · **Next review:** 20 January 2027

Maps to: SOC 2 CC8.1 · ISO 27001:2022 A.8.25-A.8.31

gs://attestor-505506-corpus/engineering/sdlc-policy.txt

[2] sdlc-policy — 4. Security in the pipeline — relevance 0.58

4. Security in the pipeline

Static analysis (Semgrep, CodeQL), dependency scanning (Snyk), IaC scanning (Checkov), and secret scanning (Gitleaks pre-commit plus GitHub push protection) all run on every pull request. A Critical or High dependency finding blocks the merge.

gs://attestor-505506-corpus/engineering/sdlc-policy.txt

[3] change-management-procedure — 6. Customer notification — relevance 0.58

6. Customer notification

Customers are notified at least **7 days** in advance of any change expected to cause degraded service or to require action on their part. Breaking API changes follow the deprecation policy: minimum **12 months** notice, with the deprecated version remaining available throughout.

gs://attestor-505506-corpus/engineering/change-management-procedure.txt

[4] third-party-library-policy — Third-Party Library Policy — relevance 0.54

Third-Party Library Policy

Document ID: KD-ENG-008 · **Version:** 1.4 · **Owner:** Dana Whitfield, VP Engineering

Approved: 22 January 2026 · **Maps to:** SOC 2 CC7.1 · ISO 27001:2022 A.8.28

gs://attestor-505506-corpus/engineering/third-party-library-policy.txt

[5] sdlc-policy — 1. Branching and review — relevance 0.54

1. Branching and review

``main`` is protected and always releasable. All work happens on short-lived branches merged by pull request. ``main`` requires:

- At least **one approving review** from an engineer other than the author. Self-approval is blocked at the platform level.

- Two approvals for changes touching authentication, authorisation, tenant isolation, or cryptography. These paths are

gs://attestor-505506-corpus/engineering/sdlc-policy.txt

[6] sdlc-policy — 2. Environments — relevance 0.54

2. Environments

| Environment | Purpose | Data |

|---|---|---|

| ``local`` | Developer machines | Synthetic fixtures only |

| ``ci`` | Automated testing | Synthetic fixtures only |

| ``staging`` | Pre-production verification | Synthetic and anonymised data |

| ``production`` | Live service | Customer data |

Production data is never copied to a lower environment. Staging fixtures are generated

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[7] sdlc-policy — 5. Dependency policy — relevance 0.53

5. Dependency policy

New third-party dependencies require review against the Third-Party Library Policy (KD-ENG-008). Lockfiles are committed. Renovate opens automated upgrade pull requests weekly; security patches are auto-merged when CI is green and the change is a patch-level bump.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[8] third-party-library-policy — 2. Licence policy — relevance 0.53

2. Licence policy

****Allowed:**** MIT, BSD-2-Clause, BSD-3-Clause, Apache-2.0, ISC, Python Software Foundation, Unlicense, CC0.

****Requires legal review:**** MPL-2.0, LGPL-2.1, LGPL-3.0, EPL-2.0.

****Prohibited:**** GPL-2.0, GPL-3.0, AGPL-1.0, AGPL-3.0, SSPL, BUSL, Commons Clause, and any licence without a clear grant. AGPL and SSPL are prohibited because Kestrel distributes a network service.

L

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

29. Describe your API authentication mechanism.

engineering · Q29 · Vendor Security Review row 30

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

30. Is your organisation subject to any pending litigation relating to data protection?

legal · Q30 · Vendor Security Review row 31

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

31. Provide evidence that your security controls are independently verified.

security · Q31 · Vendor Security Review row 32

Kestrel Data's security controls are independently verified through the following third-party assessments and certifications: 1. ****SOC 2 Type II Examination:**** Kestrel undergoes an annual SOC 2 Type II examination conducted by Prescient Assurance LLP. For the period covering 1 January through 31 December 2025 (report issued 14 March 2026), the auditor issued an unqualified opinion with no exceptions noted across the Security, Availability, and Confidentiality Trust Services Criteria (*soc2-control-matrix*, "SOC 2 Control Matrix"; *risk-management-and-governance*, "7. Internal audit"). 2. ****ISO/IEC 27001 Certification:**** Kestrel maintains ISO 27001 certification with regular surveillance audits conducted by BSI. The scope covers the information security management system supporting the development, operation, and support of the Kestrel Insight analytics platform (*risk-management-and-governance*, "7. Internal audit"; *company-and-security-programme-overview*, "6. Scope of certification"). 3. ****Independent Penetration Testing:**** An annual third-party penetration test is performed by Include Security (*risk-management-and-governance*, "7. Internal audit"). 4. ****Continuous Control Monitoring:**** Control operation is continuously tracked by Vanta across 187 automated checks, with any detected failures routed directly to the control owner (*risk-management-and-governance*, "7. Internal audit"). The SOC 2 Type II report, ISO 27001 certificate, and penetration testing executive summary are available to customers and prospects under NDA through the account team (*company-and-security-programme-overview*, "8. How to obtain evidence").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] soc2-control-matrix — SOC 2 Control Matrix — relevance 0.63

SOC 2 Control Matrix

Document ID: KD-SEC-012 · **Version:** 2.1

Report period: 1 January - 31 December 2025 · **Report issued:** 14 March 2026

Auditor: Prescient Assurance LLP · **Opinion:** Unqualified, no exceptions noted

Trust Services Criteria in scope: Security, Availability, Confidentiality

Privacy and Processing Integrity are **not** in scope for the current report. Ke

gs://attestor-505506-corporus/security/soc2-control-matrix.txt

[2] risk-management-and-governance — 7. Internal audit — relevance 0.63

7. Internal audit

Kestrel is too small to maintain a separate internal audit function, and says so rather than claiming one. Independent assurance comes from the annual SOC 2 Type II examination (Prescient Assurance LLP), the ISO 27001 surveillance audits (BSI), and the annual penetration test (Include Security). Control operation is monitored continuously by Vanta across 187 automated checks, wit

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[3] company-and-security-programme-overview — 8. How to obtain evidence — relevance 0.62

8. How to obtain evidence

The SOC 2 Type II report, the ISO 27001 certificate, the penetration test executive summary, and the standard DPA are available to customers and prospects under NDA through the account team, usually within two business days. The certificate and the trust page are available without an NDA.

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[4] risk-management-and-governance — Risk Management and Security Governance — relevance 0.62

Risk Management and Security Governance

Document ID: KD-SEC-018 · **Version:** 3.0 · **Owner:** Marcus Oyelaran, CISO

Approved: 26 January 2026 · **Next review:** 26 January 2027

Maps to: SOC 2 CC1.1, CC1.2, CC1.3, CC3.1, CC3.2, CC3.4 · ISO 27001:2022 A.5.1–A.5.4, Clauses 5–6, 9

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[5] company-and-security-programme-overview — 6. Scope of certification — relevance 0.61

6. Scope of certification

The ISO 27001 certificate scope statement reads: "The information security management system supporting the development, operation, and support of the Kestrel Insight analytics platform, including supporting corporate functions, at Austin, Texas and for remote personnel." The SOC 2 report covers the Security, Availability, and Confidentiality Trust Services Criteria. Pr

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

32. Is your platform multi-tenant or single-tenant?

engineering · Q32 · Vendor Security Review row 33

Kestrel Insight is a multi-tenant platform with logical isolation. Kestrel Data does not offer per-customer infrastructure, single-tenant deployment options, or customer-VPC deployments (`infrastructure-architecture-overview`, Section 5. "Tenant isolation"). Logical tenant isolation is enforced at three distinct layers: 1. **Database:** PostgreSQL row-level security policies keyed on `tenant_id` are applied at the connection level via authenticated session variables, preventing application queries from opting out (`infrastructure-architecture-overview`, Section 5. "Tenant isolation"). 2. **Application:** Every incoming request carries a validated tenant claim, and the repository base class in the data access layer refuses any query lacking a tenant predicate (`infrastructure-architecture-overview`, Section 5. "Tenant isolation"). 3. **Storage:** S3 object keys are prefixed by tenant, and AWS IAM policies restrict access by prefix (`infrastructure-architecture-overview`, Section 5. "Tenant isolation"). This isolation model is verified continuously by an 84-assertion test suite on every build and was validated during the February 2026 independent penetration test, where no cross-tenant access was achieved (`infrastructure-architecture-overview`, Section 5. "Tenant isolation").

Evidence (5)

[1] infrastructure-architecture-overview — 5. Tenant isolation — relevance 0.71

5. Tenant isolation

Kestrel Insight is **multi-tenant** with logical isolation. There is no per-customer infrastructure, no single-tenant deployment option, and no customer-VPC option.

Isolation is enforced at three layers:

1. **Database** - PostgreSQL row-level security policies keyed on `tenant_id`, applied at the connection level from an authenticated session variable. No application

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[2] data-flow-and-shared-responsibility — 3. The shared responsibility model — relevance 0.63

3. The shared responsibility model

Security of the platform is Kestrel's. Security of what the customer does with it is the customer's. The line is drawn here rather than left implicit, because an unstated boundary is where a breach lands on whoever is less able to argue.

Kestrel is responsible for:

* physical and environmental security of the infrastructure (through AWS), and the cloud co

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[3] cloud-exit-and-portability-plan — 3. Portability by design — relevance 0.62

3. Portability by design

The architecture is deliberately biased toward portable components, and the exceptions are listed rather than glossed over:

| Layer | Technology | Portability |

|---|---|---|

| Compute | Kubernetes (EKS) | High — standard manifests, no EKS-specific APIs in workloads |

| Container images | OCI in ECR | High — registry is a copy operation |

| Data warehouse | Snowflake | Hi

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[4] data-flow-and-shared-responsibility — 1. Data flow, end to end — relevance 0.61

1. Data flow, end to end

1. **Ingress** A customer's browser or API client resolves `app.kestreldata.com` or `api.kestreldata.com` to Cloudflare, which terminates TLS 1.3 (1.2 minimum) and applies WAF and rate limiting.

2. **Instance selection** DNS and tenant routing send the request to the instance chosen at contract signature: `us-east-1` or `eu-west-1`. A tenant's requests never c

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[5] infrastructure-architecture-overview — 6. Network — relevance 0.60

6. Network

Private subnets for all compute and data. No public IP addresses on workload instances. Ingress is exclusively through Cloudflare, then an AWS Application Load Balancer, then the Istio ingress gateway. Egress is through NAT gateways with an allowlist for known destinations.

Security groups are managed in Terraform and default-deny. There are no `0.0.0.0/0` ingress rules in produc

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

33. What open source licences are prohibited in your codebase? Provide supporting evidence.

engineering · Q33 · Vendor Security Review row 34

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

34. Were any Critical or High findings identified in the most recent test?

security · Q34 · Vendor Security Review row 35

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

35. Have TLS 1.0 and TLS 1.1 been disabled across all endpoints? If not, describe compensating controls.

security · Q35 · Vendor Security Review row 36

Yes, TLS 1.0 and TLS 1.1 were disabled across all endpoints on April 12, 2024. TLS 1.3 is the default protocol for all external connections, while TLS 1.2 remains enabled solely for one legacy customer SFTP integration (INT-LEGACY-0004) scheduled for decommissioning in Q3 2026 (Encryption Standard, Section 2: Data in transit).

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by SecurityAgent

Evidence (5)

[1] encryption-standard — 2. Data in transit — relevance 0.68

2. Data in transit

****TLS 1.3**** is the default for all external connections. TLS 1.2 remains enabled solely for one legacy customer SFTP integration (INT-LEGACY-0004), scheduled for decommission in Q3 2026 and tracked as RISK-2025-0088. TLS 1.0 and 1.1 were disabled across all endpoints on 12 April 2024.

Cipher suites are restricted to the Mozilla Intermediate profile. HSTS is enabled with

`gs://attestor-505506-corporus/security/encryption-standard.txt`

[2] encryption-standard — 6. Post-quantum posture — relevance 0.59

6. Post-quantum posture

Kestrel completed a cryptographic inventory (`SEC-GOV/crypto-inventory`, 19 January 2026) as the first step toward post-quantum readiness. TLS connections terminated at Cloudflare already negotiate the hybrid X25519MLKEM768 key agreement where the client supports it. No migration commitment date has been set for internal services.

`gs://attestor-505506-corporus/security/encryption-standard.txt`

[3] encryption-standard — 5. Algorithm policy — relevance 0.57

5. Algorithm policy

Approved: AES-256-GCM, AES-256-CBC (legacy read paths only), RSA-2048 and above, ECDSA P-256 and P-384, SHA-256 and above, Argon2id and bcrypt (cost factor 12 or higher) for password hashing.

Prohibited: DES, 3DES, RC4, MD5 and SHA-1 for any security purpose, RSA below 2048 bits, and any custom cryptographic construction. Kestrel does not implement its own cryptographic

`gs://attestor-505506-corporus/security/encryption-standard.txt`

[4] encryption-standard — Encryption Standard — relevance 0.55

Encryption Standard

****Document ID:**** KD-SEC-003 · ****Version:**** 2.4 · ****Owner:**** Marcus Oyelaran, CISO
****Approved:**** 8 January 2026 · ****Next review:**** 8 January 2027
****Maps to:**** SOC 2 CC6.7 · ISO 27001:2022 A.8.24 · GDPR Art. 32(1)(a)

`gs://attestor-505506-corporus/security/encryption-standard.txt`

[5] encryption-standard — 1. Data at rest — relevance 0.54

1. Data at rest

All customer data at rest is encrypted using **AES-256-GCM**. No customer data is stored unencrypted at any tier.

| Store | Mechanism | Key custody |

|---|---|---|

| Amazon RDS (PostgreSQL 16) | Storage-level encryption | AWS KMS CMK, per-environment |

| Amazon S3 | SSE-KMS | AWS KMS CMK, per-bucket |

| Snowflake | Native encryption, Tri-Secret Secure | Customer-managed key

gs://attestor-505506-corporus/security/encryption-standard.txt

36. Does the CISO have a reporting line independent of executive management?

security · Q36 · Vendor Security Review row 37

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

37. Was cross-tenant data access achieved during penetration testing?

security · Q37 · Vendor Security Review row 38

No cross-tenant data access was achieved during penetration testing. Tenant isolation held under every tested condition, including attempts involving direct object reference manipulation, JWT tenant-claim tampering, and GraphQL alias-based enumeration (`pen-test-executive-summary`, Section 3. Findings summary).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] pen-test-executive-summary — 3. Findings summary — relevance 0.70

3. Findings summary

| Severity | Found | Remediated | Retest verified |

|---|---|---|---|

| Critical | 0 | - | - |

| High | 1 | 1 | 18 March 2026 |

| Medium | 4 | 4 | 18 March 2026 |

| Low | 7 | 5 | 18 March 2026 |

| Informational | 9 | Accepted / tracked | - |

****No cross-tenant data access was achieved.**** Tenant isolation held under every tested condition, including direct object refere

gs://attestor-505506-corporus/security/pen-test-executive-summary.txt

[2] pen-test-executive-summary — 1. Scope — relevance 0.67

1. Scope

- Kestrel Insight web application (`app.kestreldata.com`), authenticated and unauthenticated surfaces
- Public REST API v2 (`api.kestreldata.com`), 89 endpoints
- Multi-tenant isolation testing across 3 seeded tenant accounts
- AWS cloud configuration review (IAM, S3, VPC, EKS)
- Authentication and session management, including the Okta SAML integration

Out of scope: physical se

gs://attestor-505506-corporus/security/pen-test-executive-summary.txt

[3] pen-test-executive-summary — 2. Methodology — relevance 0.66

2. Methodology

Grey-box testing against OWASP ASVS 4.0 Level 2 and the OWASP API Security Top 10. Testers were given standard-tier and admin-tier credentials for each seeded tenant plus API documentation. 74 person-hours across two testers.

gs://attestor-505506-corporate/security/pen-test-executive-summary.txt

[4] pen-test-executive-summary — 7. Tester statement — relevance 0.63

7. Tester statement

Kestrel Data demonstrates a mature security posture for an organisation of its size. Tenant isolation is well implemented and defence in depth is evident throughout the platform. The single High finding was an availability and privacy concern rather than a confidentiality one. - Include Security, 24 February 2026

gs://attestor-505506-corporate/security/pen-test-executive-summary.txt

[5] pen-test-executive-summary — Penetration Test Executive Summary — relevance 0.62

Penetration Test Executive Summary

Document ID: KD-SEC-007 . **Engagement:** INSEC-2026-0219

Tester: Include Security, Inc. . **Dates:** 3-14 February 2026

Report issued: 24 February 2026 . **Retest completed:** 18 March 2026

Classification: Confidential - shareable with customers under NDA

gs://attestor-505506-corporate/security/pen-test-executive-summary.txt

38. What encryption algorithm and key length is used for data at rest?

security · Q38 · Vendor Security Review row 39

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] encryption-standard — 1. Data at rest — relevance 0.71

1. Data at rest

All customer data at rest is encrypted using **AES-256-GCM**. No customer data is stored unencrypted at any tier.

| Store | Mechanism | Key custody |

|---|---|---|

| Amazon RDS (PostgreSQL 16) | Storage-level encryption | AWS KMS CMK, per-environment |

| Amazon S3 | SSE-KMS | AWS KMS CMK, per-bucket |

| Snowflake | Native encryption, Tri-Secret Secure | Customer-managed key

gs://attestor-505506-corporate/security/encryption-standard.txt

[2] information-security-policy — 8. Cryptography — relevance 0.70

8. Cryptography

Data at rest is encrypted with AES-256-GCM. Data in transit is protected with TLS 1.3; TLS 1.0 and 1.1 were disabled on 12 April 2024 and TLS 1.2 remains enabled only for a single legacy integration scheduled for removal in Q3 2026. Key management is described in the Encryption Standard (KD-SEC-003) and the Secrets Management Standard (KD-ENG-006).

gs://attestor-505506-corporate/security/information-security-policy.txt

[3] encryption-standard — 3. Key management — relevance 0.66

3. Key management

Customer-facing encryption keys are AWS KMS Customer Managed Keys. Key policies restrict use to named service roles. Key administrators and key users are disjoint sets: no individual holds both roles, enforced by a Service Control Policy at the AWS Organization level.

Automatic annual rotation is enabled on all CMKs. Manual rotation is triggered on suspected compromise. Ke

gs://attestor-505506-corporate/security/encryption-standard.txt

[4] encryption-standard — Encryption Standard — relevance 0.66

Encryption Standard

Document ID: KD-SEC-003 . **Version:** 2.4 . **Owner:** Marcus Oyelaran, CISO

gs://attestor-505506-corpus/security/encryption-standard.txt

[5] encryption-standard — 5. Algorithm policy — relevance 0.65

5. Algorithm policy

Approved: AES-256-GCM, AES-256-CBC (legacy read paths only), RSA-2048 and above, ECDSA P-256 and P-384, SHA-256 and above, Argon2id and bcrypt (cost factor 12 or higher) for password hashing.

Prohibited: DES, 3DES, RC4, MD5 and SHA-1 for any security purpose, RSA below 2048 bits, and any custom cryptographic construction. Kestrel does not implement its own cryptographic

gs://attestor-505506-corpus/security/encryption-standard.txt

39. Provide your current list of subprocessors. Provide supporting evidence.

legal · Q39 · Vendor Security Review row 40

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

40. Confirm whether any customer data is processed outside the stated regions.

legal · Q40 · Vendor Security Review row 41

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] transfer-impact-assessment — 5. Supplementary measures relied on — relevance 0.72

5. Supplementary measures relied on
Technical:

1. ****Data residency by default**** — EU customer content, including backups and the replicated log ship, never leaves `eu-west-1`.
2. ****Encryption in transit**** — TLS 1.3 (1.2 minimum) on every hop, including between Kestrel and each sub-processor.
3. ****Encryption at rest**** — AES-256-GCM with keys in AWS KMS. Keys for the EU instance are held i

gs://attestor-505506-corpus/legal/transfer-impact-assessment.txt

[2] subprocessor-list — EU data residency — relevance 0.71

EU data residency

Customers on the EU instance have their data processed exclusively within the EEA for the infrastructure subprocessors above. Kestrel does ****not**** currently offer a UK-only, Swiss-only, Canadian, or Australian data residency option. Requests for those are recorded but not committed to.

gs://attestor-505506-corpus/legal/subprocessor-list.txt

[3] transfer-impact-assessment — 2. The transfers assessed — relevance 0.70

2. The transfers assessed

#	Transfer	Exporter	Importer	Country	Data
---	----------	----------	----------	---------	------

1	EU tenant support access	Kestrel EU instance	Kestrel Data, Inc.	United States	Account identity data, support correspondence
---	--------------------------	---------------------	--------------------	---------------	---

2	Product telemetry aggregation	Kestrel EU instance	Kestrel Data, Inc.	United States	Pseudonymised usage events
---	-------------------------------	---------------------	--------------------	---------------	----------------------------

3	Error monitoring				
---	------------------	--	--	--	--

gs://attestor-505506-corpus/legal/transfer-impact-assessment.txt

[4] transfer-impact-assessment — 6. Conclusion — relevance 0.70

6. Conclusion

For T1 and T2 the residual risk to data subjects is assessed as **low**: the data transferred is limited, pseudonymised where possible, encrypted with keys held outside the importer's jurisdiction, and unaccompanied by any customer content. For T3 and T4 the residual risk is **low** on the same basis, with the additional point that no customer content is transferred at all.

The asse

gs://attestor-505506-corpus/legal/transfer-impact-assessment.txt

[5] subprocessor-list — Infrastructure subprocessors — relevance 0.69

Infrastructure subprocessors

| Subprocessor | Purpose | Location of processing | Transfer mechanism | Engaged since |

|---|---|---|---|---|

| Amazon Web Services, Inc. | Cloud hosting, compute, storage, database | US (`us-east-1`, `us-west-2`); EU (`eu-west-1`, `eu-central-1`)

| SCCs + AWS DPA; EU data stays in EU | Mar 2019 |

| Snowflake Inc. | Analytics data warehouse | US (AWS `us-east-1`);

gs://attestor-505506-corpus/legal/subprocessor-list.txt

41. Can an engineer deploy directly to production, bypassing the pipeline?

engineering · Q41 · Vendor Security Review row 42

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

42. Do you address Swiss FADP requirements? If not, describe compensating controls.

security · Q42 · Vendor Security Review row 43

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

43. Who is your lead supervisory authority?

legal · Q43 · Vendor Security Review row 44

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

44. What audit rights do you grant customers? If not, describe compensating controls.

legal · Q44 · Vendor Security Review row 45

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

45. What test coverage threshold is enforced in CI?

engineering · Q45 · Vendor Security Review row 46

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

46. Provide an overview of your information security programme.

security · Q46 · Vendor Security Review row 47

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (6)

[1] company-and-security-programme-overview — Company and Security Programme Overview — relevance 0.71

Company and Security Programme Overview

Document ID: KD-SEC-021 · **Version:** 4.2 · **Owner:** Marcus Oyelaran, CISO

Approved: 6 February 2026 · **Next review:** 6 February 2027

Maps to: SOC 2 CC1.1, CC1.2, CC2.1, CC2.3 · ISO 27001:2022 Clauses 4–5

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[2] company-and-security-programme-overview — 3. Security programme in summary — relevance 0.69

3. Security programme in summary

The programme is built on four commitments, each evidenced elsewhere in this corpus rather than asserted here:

1. **Independent verification.** SOC 2 Type II (Prescient Assurance LLP, report issued 14 March 2026 covering 1 January – 31 December 2025, **no exceptions**) and ISO 27001:2022 (BSI certificate 'IS-2025-44817', issued 22 September 2025, valid to 21

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[3] personnel-security-and-training — Personnel Security and Security Training Programme — relevance 0.68

Personnel Security and Security Training Programme

Document ID: KD-SEC-013 · **Version:** 2.1 · **Owner:** Sofia Brenner, Head of IT

Approved: 22 January 2026 · **Next review:** 22 January 2027

Maps to: SOC 2 CC1.1, CC1.4, CC2.1, CC6.2 · ISO 27001:2022 A.6.1, A.6.2, A.6.3, A.6.6

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

[4] company-and-security-programme-overview — 4. Governance — relevance 0.67

4. Governance

The CISO reports to the CEO and to the board quarterly. A Security Steering Group meets monthly. The risk register holds 41 open risks and is reviewed monthly and re-scored quarterly. Full detail is in KD-SEC-018.

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[5] risk-management-and-governance — 8. Policy management — relevance 0.66

8. Policy management

All security policies carry a document ID, a version, a named owner, an approval date, and a review date. Policies are reviewed at least annually and on material change. The 2026 review cycle covered 14 policies between 8 January and 12 February 2026; three were revised, and the changes were communicated at the February all-hands and through the annual acknowledgement cycle.

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[6] information-security-policy — 6. Personnel security — relevance 0.64

6. Personnel security

All employees and contractors undergo background screening appropriate to jurisdiction before their start date, conducted by Checkr. Screening covers identity verification, right to work, criminal records where lawful, and employment history for the preceding seven years.

Security awareness training is delivered through Curricula at onboarding and annually thereafter. Complete

gs://attestor-505506-corporus/security/information-security-policy.txt

47. Have you appointed a Data Protection Officer? Provide contact details. Provide supporting evidence.

legal · Q47 · Vendor Security Review row 48

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

48. Provide your current list of subprocessors.

legal · Q48 · Vendor Security Review row 49

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

49. Do you offer on-premises or self-hosted deployment?

engineering · Q49 · Vendor Security Review row 50

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] infrastructure-architecture-overview — Infrastructure Architecture Overview — relevance 0.64

Infrastructure Architecture Overview

Document ID: KD-ENG-003 · **Version:** 3.4 · **Owner:** Dana Whitfield, VP Engineering

Last updated: 5 February 2026 · **Classification:** Confidential, NDA required

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[2] infrastructure-architecture-overview — 1. Cloud footprint — relevance 0.63

1. Cloud footprint

Kestrel runs on **Amazon Web Services**. There are two independent production instances:

Instance	Region	Serves
----------	--------	--------

---	---	---
-----	-----	-----

US	`us-east-1` (3 AZs)	North America, and customers with no residency requirement
----	---------------------	--

EU	`eu-west-1` (3 AZs)	EEA, UK, and Swiss customers electing EU residency
----	---------------------	--

Backup replication targets `us-west-2` and `eu-central-1` respectively

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[3] infrastructure-architecture-overview — 6. Network — relevance 0.61

6. Network

Private subnets for all compute and data. No public IP addresses on workload instances.

Ingress is exclusively through Cloudflare, then an AWS Application Load Balancer, then the Istio ingress gateway. Egress is through NAT gateways with an allowlist for known destinations.

Security groups are managed in Terraform and default-deny. There are no `0.0.0.0/0` ingress rules in production

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[4] infrastructure-architecture-overview — 4. Data layer — relevance 0.61

4. Data layer

Store	Technology	Purpose
-------	------------	---------

|---|---|---|
| Primary OLTP | Amazon RDS PostgreSQL 16, Multi-AZ | Application state |
| Analytics | Snowflake | Customer analytics workloads |
| Object storage | Amazon S3 | Uploads, exports, backups |
| Cache | Amazon ElastiCache (Redis 7) | Session and query cache |
| Search | OpenSearch 2.13 | In-product search |

gs://attestor-505506-corporate-engineering/infrastructure-architecture-overview.txt

[5] infrastructure-architecture-overview — 3. Compute — relevance 0.59

3. Compute

Amazon EKS (Kubernetes 1.31) with managed node groups spanning three availability zones. Workloads run as containers built from distroless base images, as non-root, with read-only root filesystems and dropped Linux capabilities. Pod Security Standards are enforced at the `restricted` level.

Node images are immutable; nodes are recycled with a maximum age of 30 days rather than pa

gs://attestor-505506-corporate-engineering/infrastructure-architecture-overview.txt

50. Please confirm: What controls remain the responsibility of the customer?

engineering · Q50 · Vendor Security Review row 51

Under Kestrel's shared responsibility model and complementary user entity controls, the customer remains responsible for: * Deciding what data is uploaded and ensuring its lawfulness, as Kestrel does not inspect customer content. * Configuring SSO and enforcing multi-factor authentication (MFA) at their own identity provider (IdP). * Managing their own users, roles, and permissions, including the timely de-provisioning and removal of leavers. * The scope, secure storage, and regular rotation of the API credentials they create. * Reviewing their own audit logs, which Kestrel retains and makes available for 13 months. * Acting as the data controller for data subject requests concerning their content. * Notifying their own data subjects and applicable regulators where they act as the controller. * Device and endpoint security for the individuals who access and use the platform. *(Source: `data-flow-and-shared-responsibility`, Section 3: "The shared responsibility model" and Section 4: "Complementary user entity controls")*

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (4)

[1] data-flow-and-shared-responsibility — 4. Complementary user entity controls — relevance 0.66

4. Complementary user entity controls

The SOC 2 report lists these as complementary user entity controls; they are restated here because a customer reading only this document should still see them. If a customer does not operate the controls in the second list, Kestrel's controls in the first do not compensate: Kestrel cannot detect that a departed employee of the customer still holds a valid sess

gs://attestor-505506-corporate-engineering/data-flow-and-shared-responsibility.txt

[2] data-flow-and-shared-responsibility — 3. The shared responsibility model — relevance 0.65

3. The shared responsibility model

Security of the platform is Kestrel's. Security of what the customer does with it is the customer's. The line is drawn here rather than left implicit, because an unstated boundary is where a breach lands on whoever is less able to argue.

Kestrel is responsible for:

* physical and environmental security of the infrastructure (through AWS), and the cloud co

gs://attestor-505506-corporate-engineering/data-flow-and-shared-responsibility.txt

[3] data-flow-and-shared-responsibility — Data Flow and Shared Responsibility Model — relevance 0.59

Data Flow and Shared Responsibility Model

Document ID: KD-ENG-011 · **Version:** 2.0 · **Owner:** Dana Whitfield, VP Engineering

Approved: 2 February 2026 · **Next review:** 2 February 2027

Maps to: SOC 2 CC2.3, CC3.2, CC6.1 · ISO 27001:2022 A.5.2, A.5.8, A.8.9 · GDPR Article 28

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[4] secrets-management-standard — 6. Customer-issued API credentials — relevance 0.57

6. Customer-issued API credentials

API keys issued to customers are stored as Argon2id hashes; Kestrel cannot recover the plaintext of a customer API key and will not do so on request. Keys are displayed once at creation. Customers can create, scope, and revoke keys through the console, and each key carries a last-used timestamp so stale keys are visible.

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

51. How are secrets stored and rotated?

security · Q51 · Vendor Security Review row 52

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

52. Are manual production console changes permitted?

engineering · Q52 · Vendor Security Review row 53

Manual changes through the AWS console are strictly prohibited in production. All infrastructure is managed exclusively through Terraform within the `kestrel-infra` repository. To enforce this, drift detection runs every 6 hours and automatically raises a SEV3 incident upon detecting any unmanaged change (`change-management-procedure`, Section 4. Infrastructure changes).

Release status: No — held for a human · confidence low · drafted by EngineeringAgent

Evidence (5)

[1] change-management-procedure — 3. Emergency changes — relevance 0.54

3. Emergency changes

An Emergency change may bypass the Change Advisory step but never bypasses code review or CI. The Incident Commander authorises it, and a retrospective record is filed within one business day covering what changed, why the normal path was bypassed, and whether the change should be reworked.

All 9 Emergency changes in 2025 have completed retrospectives on file.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[2] change-management-procedure — 1. Change classes — relevance 0.54

1. Change classes

| Class | Definition | Approval | Example |

|---|---|---|---|

| **Standard** | Pre-approved, low risk, automated | PR review + CI | Application code, config change through IaC |

| **Normal** | Material risk or customer-visible | PR review + Change Advisory sign-off | Schema migration, dependency major version |

| **Emergency** | Fixing an active SEV1/SEV2 | Retrospective with

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[3] change-management-procedure — Change Management Procedure — relevance 0.53

Change Management Procedure

Document ID: KD-ENG-002 · **Version:** 3.0 · **Owner:** Dana Whitfield, VP Engineering

Approved: 20 January 2026 · **Maps to:** SOC 2 CC8.1 · ISO 27001:2022 A.8.32

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[4] change-management-procedure — 2. Normal change requirements — relevance 0.53

2. Normal change requirements

A Normal change additionally requires a written rollback plan, a customer-impact assessment, and sign-off from the Change Advisory group (VP Engineering plus one SRE). Schema migrations must be backward compatible for at least one release, so that a rollback does not require a data migration.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[5] change-management-procedure — 4. Infrastructure changes — relevance 0.50

4. Infrastructure changes

Infrastructure is managed exclusively through Terraform in the `kestrel-infra` repository. Manual changes through the AWS console are prohibited in production; drift detection runs every 6 hours and raises a SEV3 on any unmanaged change. Drift was detected 4 times in 2025, all traced to AWS-initiated maintenance rather than human action.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

53. What is your contractual availability commitment?

engineering · Q53 · Vendor Security Review row 54

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

54. Does the availability commitment apply to all pricing tiers?

legal · Q54 · Vendor Security Review row 55

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

55. Do you impose equivalent data protection obligations on subprocessors?

legal · Q55 · Vendor Security Review row 56

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

56. Do you act as a service provider under the CCPA?

legal · Q56 · Vendor Security Review row 57

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

57. Will you sign a Business Associate Agreement under HIPAA?

legal · Q57 · Vendor Security Review row 58

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

58. Provide your public privacy policy.

legal · Q58 · Vendor Security Review row 59

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

59. How many government data requests did you receive last year?

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

60. Was cross-tenant data access achieved during penetration testing? If not, describe compensating controls.

security · Q60 · Vendor Security Review row 61

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

61. What is your notification window for confirmed unauthorised access to production data?

legal · Q61 · Vendor Security Review row 62

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

62. For each applicable system: Who holds the encryption keys for customer data?

engineering · Q62 · Vendor Security Review row 63

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (7)

[1] data-flow-and-shared-responsibility — 1. Data flow, end to end — relevance 0.68

1. Data flow, end to end

1. **Ingress.** A customer's browser or API client resolves `app.kestreldata.com` or `api.kestreldata.com` to Cloudflare, which terminates TLS 1.3 (1.2 minimum) and applies WAF and rate limiting.

2. **Instance selection.** DNS and tenant routing send the request to the instance chosen at contract signature: `us-east-1` or `eu-west-1`. A tenant's requests never c

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[2] secrets-management-standard — 6. Customer-issued API credentials — relevance 0.67

6. Customer-issued API credentials

API keys issued to customers are stored as Argon2id hashes; Kestrel cannot recover the plaintext of a customer API key and will not do so on request. Keys are displayed once at creation. Customers can create, scope, and revoke keys through the console, and each key carries a last-used timestamp so stale keys are visible.

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

[3] backup-restore-procedure — 2. Encryption and location — relevance 0.67

2. Encryption and location

All backups are encrypted with AES-256 using AWS KMS. The daily logical dump uses a **separate CMK** from the primary database, so that compromise of the primary key does not compromise the backups.

Cross-region replication stays inside the residency boundary: `us-east-1` replicates to `us-west-2`, `eu-west-1` replicates to `eu-central-1`. EU customer data never le

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[4] data-flow-and-shared-responsibility — 3. The shared responsibility model — relevance 0.65

3. The shared responsibility model

Security of the platform is Kestrel's. Security of what the customer does with it is the customer's. The line is drawn here rather than left implicit, because an unstated boundary is where a breach lands on whoever is less able to argue.

****Kestrel is responsible for:****

* physical and environmental security of the infrastructure (through AWS), and the cloud
co

gs://attestor-505506-corpus/engineering/data-flow-and-shared-responsibility.txt

[5] data-flow-and-shared-responsibility — 6. Where processing occurs — relevance 0.64

6. Where processing occurs

Processing occurs in AWS `us-east-1` (US instance) and AWS `eu-west-1` (EU instance), by personnel located in the United States, the European Union, the United Kingdom, and Canada, under the access controls in KD-SEC-002. ****No processing occurs outside the stated regions****, and no support is subcontracted to a third-party provider in another jurisdiction.

gs://attestor-505506-corpus/engineering/data-flow-and-shared-responsibility.txt

[6] secrets-management-standard — 1. Where secrets live — relevance 0.58

1. Where secrets live

| Secret class | Store | Rotation |

|---|---|---|

| Application secrets, API keys | AWS Secrets Manager | 90 days, automated |

| Database credentials | AWS Secrets Manager with RDS-managed rotation | 30 days, automated |

| Encryption keys | AWS KMS (key material never leaves KMS) | Annual, automated |

| TLS certificates | AWS Certificate Manager | Automatic before expiry

gs://attestor-505506-corpus/engineering/secrets-management-standard.txt

[7] backup-restore-procedure — 1. What is backed up — relevance 0.58

1. What is backed up

| Asset | Method | Frequency | Retention |

|---|---|---|---|

| RDS PostgreSQL | Automated snapshots + WAL archiving (PITR) | Continuous | ****35 days**** |

| RDS logical dump | `pg\_dump` to S3, encrypted with a separate CMK | Daily 03:00 UTC | 90 days |

| S3 objects | Versioning + cross-region replication | Continuous | 90 days for non-current versions |

| Snowflake | Time Tr

gs://attestor-505506-corpus/engineering/backup-restore-procedure.txt

63. Do you deploy endpoint detection and response on all company devices?

security · Q63 · Vendor Security Review row 64

Yes. CrowdStrike Falcon is deployed on 100% of managed endpoints and all production compute nodes (*Endpoint Protection and Data Loss Prevention Standard*, Section 2, "Endpoint detection and response"). All devices with access to Kestrel systems are company-owned and centrally managed, with no bring-your-own-device (BYOD) programme for laptops (*Endpoint Protection and Data Loss Prevention Standard*, Section 1, "Managed devices"). Coverage is reconciled nightly against the Kandji and AWS inventories. If a device is present in inventory but absent from CrowdStrike Falcon, a ticket is raised to the Head of IT within one business day. Additionally, detections are routed to the `#sec-alerts` Slack channel and automatically page the on-call engineer for High and Critical severity alerts (*Endpoint Protection and Data Loss Prevention Standard*, Section 2, "Endpoint detection and response").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] endpoint-protection-standard — 2. Endpoint detection and response — relevance 0.64

2. Endpoint detection and response

****CrowdStrike Falcon is deployed on 100% of managed endpoints and on all production compute nodes.**** Coverage is reconciled nightly against the Kandji and AWS inventories, and a device present in inventory but absent from Falcon raises a ticket to the Head of IT within one business day. The reconciliation found two gaps during 2025, both new

contractor laptops, b

gs://attestor-505506-corporate/security/endpoint-protection-standard.txt

[2] endpoint-protection-standard — 8. Patching of endpoints — relevance 0.61

8. Patching of endpoints

Operating system updates are enforced within 14 days of release for standard updates and 72 hours for updates addressing a Critical vulnerability, with a Kandji deferral window that cannot be extended by the user. Measured compliance at the last audit point (1 February 2026) was 168 of 174 devices within policy, the remaining six being on extended leave with access suspend

gs://attestor-505506-corporate/security/endpoint-protection-standard.txt

[3] endpoint-protection-standard — Endpoint Protection and Data Loss Prevention Standard — relevance 0.60

Endpoint Protection and Data Loss Prevention Standard

****Document ID:**** KD-SEC-015 · ****Version:**** 2.2 · ****Owner:**** Sofia Brenner, Head of IT
****Approved:**** 19 January 2026 · ****Next review:**** 19 January 2027
****Maps to:**** SOC 2 CC6.6, CC6.8, CC7.1 · ISO 27001:2022 A.8.1, A.8.7, A.8.12, A.8.16

gs://attestor-505506-corporate/security/endpoint-protection-standard.txt

[4] endpoint-protection-standard — 4. Disk encryption — relevance 0.59

4. Disk encryption

FileVault 2 is enforced on all macOS devices, with recovery keys held in Kandji custody; LUKS is enforced on Linux workstations. Compliance is 100% of 174 devices, verified continuously by Vanta control DE-03.

gs://attestor-505506-corporate/security/endpoint-protection-standard.txt

[5] endpoint-protection-standard — 1. Managed devices — relevance 0.59

1. Managed devices

Every device with access to Kestrel systems is company-owned and centrally managed. There is no bring-your-own-device programme for laptops. As of 1 February 2026 the estate is 163 macOS laptops managed by Kandji and 11 Linux workstations managed by Fleet; there are no Windows endpoints in use.

Enrolment is a precondition of access: Cloudflare Access performs a device posture c

gs://attestor-505506-corporate/security/endpoint-protection-standard.txt

64. Can customers export their data in a machine-readable format?

engineering · Q64 · Vendor Security Review row 65

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

65. In which cloud regions is the production platform hosted?

legal · Q65 · Vendor Security Review row 66

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

66. Is there board-level oversight of information security?

security · Q66 · Vendor Security Review row 67

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

67. Do you publish a transparency report of government data requests?

legal · Q67 · Vendor Security Review row 68

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

68. Can a developer approve their own pull request?

engineering · Q68 · Vendor Security Review row 69

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

69. What is the governing law of your standard agreement?

legal · Q69 · Vendor Security Review row 70

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

70. Do you undergo independent audit of your security controls?

security · Q70 · Vendor Security Review row 71

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] risk-management-and-governance — 7. Internal audit — relevance 0.65

7. Internal audit

Kestrel is too small to maintain a separate internal audit function, and says so rather than claiming one. Independent assurance comes from the annual SOC 2 Type II examination (Prescient Assurance LLP), the ISO 27001 surveillance audits (BSI), and the annual penetration test (Include Security). Control operation is monitored continuously by Vanta across 187 automated checks, wit

gs://attestor-505506-corpus/security/risk-management-and-governance.txt

[2] soc2-control-matrix — Common Criteria — relevance 0.64

Common Criteria

Control	Description	Evidence	Test result
---------	-------------	----------	-------------

CC1.1	Board oversight of security; Audit and Risk Committee meets quarterly	Committee minutes, 4 meetings in 2025	No exceptions
-------	---	---------------------------------------	---------------

CC1.4	Security awareness training at hire and annually	Curricula completion records, 100% of active staff	No exceptions
-------	--	--	---------------

CC2.1	Internal communication of securit		
-------	-----------------------------------	--	--

gs://attestor-505506-corpus/security/soc2-control-matrix.txt

[3] risk-management-and-governance — Risk Management and Security Governance — relevance 0.61

Risk Management and Security Governance

Document ID: KD-SEC-018 · **Version:** 3.0 · **Owner:** Marcus Oyelaran, CISO

Approved: 26 January 2026 · **Next review:** 26 January 2027

Maps to: SOC 2 CC1.1, CC1.2, CC1.3, CC3.1, CC3.2, CC3.4 · ISO 27001:2022 A.5.1–A.5.4, Clauses 5–6, 9

gs://attestor-505506-corpus/security/risk-management-and-governance.txt

[4] company-and-security-programme-overview — 3. Security programme in summary — relevance 0.61

3. Security programme in summary

The programme is built on four commitments, each evidenced elsewhere in this corpus rather than asserted here:

1. ****Independent verification.**** SOC 2 Type II (Prescient Assurance LLP, report issued 14 March 2026 covering 1 January – 31 December 2025, ****no exceptions****) and ISO 27001:2022 (BSI certificate `IS-2025-44817`, issued 22 September 2025, valid to 21

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[5] company-and-security-programme-overview — 4. Governance — relevance 0.60

4. Governance

The CISO reports to the CEO and to the board quarterly. A Security Steering Group meets monthly. The risk register holds 41 open risks and is reviewed monthly and re-scored quarterly. Full detail is in KD-SEC-018.

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

71. Please confirm: Do you maintain Records of Processing Activities under Article 30?

legal · Q71 · Vendor Security Review row 72

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

72. How many changes were deployed to production in the last year?

engineering · Q72 · Vendor Security Review row 73

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

73. Describe your network segmentation approach.

security · Q73 · Vendor Security Review row 74

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

74. Will EU customer data ever be processed outside the EEA, including backups?

legal · Q74 · Vendor Security Review row 75

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

75. Please confirm: Provide the results of your most recent disaster recovery test.

engineering · Q75 · Vendor Security Review row 76

Our most recent disaster recovery and restore test was conducted on January 17, 2026 (Q1 2026). The test involved a full restore rather than a backup-listing check, taking 2 hours and 41 minutes to complete. All 1,240 integrity assertions passed, covering row counts, referential integrity, tenant isolation invariants, and known-value spot checks (backup-restore-procedure, "4. Test results").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] backup-restore-procedure — 4. Test results — relevance 0.70

4. Test results

Restore is tested ****quarterly****, and the test is a real restore, not a backup-listing check.

Quarter	Date	Duration	Assertions	Outcome
Q1 2026	17 Jan 2026	2h 41m	1,240 / 1,240	Pass
Q4 2025	11 Oct 2025	3h 02m	1,238 / 1,240	Pass, 2 known-stale fixtures corrected
Q3 2025	19 Jul 2025	3h 20m	1,240 / 1,240	Pass

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[2] backup-restore-procedure — 5. Tenant-scoped restore — relevance 0.61

5. Tenant-scoped restore

A single customer can be restored without affecting others, by restoring to an isolated account and exporting that tenant rows back. This was exercised once in production, on 22 September 2025, at a customer request following an erroneous bulk delete on their side. Time to complete was 5 hours 10 minutes.

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[3] backup-restore-procedure — 3. Restore procedure — relevance 0.58

3. Restore procedure

1. Declare the restore scope: point in time, and whether tenant-scoped or full.
2. Provision an isolated restore account from the Terraform module `restore-target`.
3. Restore the RDS snapshot or PITR target into the isolated account.
4. Run the integrity suite: 1,240 assertions covering row counts, referential integrity, tenant isolation invariants, and known-value spo

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[4] backup-restore-procedure — Backup and Restore Procedure — relevance 0.57

Backup and Restore Procedure

****Document ID:**** KD-ENG-004 · ****Version:**** 2.5 · ****Owner:**** Sofia Brenner, Head of IT
****Approved:**** 29 January 2026 · ****Maps to:**** SOC 2 A1.2 · ISO 27001:2022 A.8.13

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[5] backup-restore-procedure — 1. What is backed up — relevance 0.55

1. What is backed up

Asset	Method	Frequency	Retention
RDS PostgreSQL	Automated snapshots + WAL archiving (PITR)	Continuous	**35 days**
RDS logical dump	`pg_dump` to S3, encrypted with a separate CMK	Daily 03:00 UTC	90 days
S3 objects	Versioning + cross-region replication	Continuous	90 days for non-current versions
Snowflake	Time Tr		

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

76. Are shared or team accounts permitted?

security · Q76 · Vendor Security Review row 77

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

77. How do you detect configuration drift in production infrastructure?

engineering · Q77 · Vendor Security Review row 78

Kestrel Data manages production infrastructure exclusively through Terraform in the `kestrel-infra` repository, and manual changes via the AWS console are strictly prohibited in production. Automated drift detection runs every 6 hours and triggers a SEV3 incident upon identifying any unmanaged change (`change-management-procedure`, Section 4. Infrastructure changes).

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (5)

[1] change-management-procedure — 4. Infrastructure changes — relevance 0.66

4. Infrastructure changes

Infrastructure is managed exclusively through Terraform in the `kestrel-infra` repository. Manual changes through the AWS console are prohibited in production; drift detection runs every 6 hours and raises a SEV3 on any unmanaged change. Drift was detected 4 times in 2025, all traced to AWS-initiated maintenance rather than human action.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[2] change-management-procedure — Change Management Procedure — relevance 0.54

Change Management Procedure

Document ID: KD-ENG-002 · **Version:** 3.0 · **Owner:** Dana Whitfield, VP Engineering

Approved: 20 January 2026 · **Maps to:** SOC 2 CC8.1 · ISO 27001:2022 A.8.32

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[3] change-management-procedure — 1. Change classes — relevance 0.53

1. Change classes

| Class | Definition | Approval | Example |

|---|---|---|---|

| **Standard** | Pre-approved, low risk, automated | PR review + CI | Application code, config change through IaC |

| **Normal** | Material risk or customer-visible | PR review + Change Advisory sign-off | Schema migration, dependency major version |

| **Emergency** | Fixing an active SEV1/SEV2 | Retrospective with

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[4] change-management-procedure — 2. Normal change requirements — relevance 0.53

2. Normal change requirements

A Normal change additionally requires a written rollback plan, a customer-impact assessment, and sign-off from the Change Advisory group (VP Engineering plus one SRE). Schema migrations must be backward compatible for at least one release, so that a rollback does not require a data migration.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[5] change-management-procedure — 5. Database changes — relevance 0.53

5. Database changes

Migrations run through Atlas with a plan-and-approve step. Destructive operations (column drop, table drop) require a two-phase deployment separated by at least one release: the column is first stopped being read, then dropped in a later release.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

78. For each applicable system: Do you undergo independent audit of your security controls?

security · Q78 · Vendor Security Review row 79

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] risk-management-and-governance — 7. Internal audit — relevance 0.69

7. Internal audit

Kestrel is too small to maintain a separate internal audit function, and says so rather than claiming one. Independent assurance comes from the annual SOC 2 Type II examination (Prescient Assurance LLP), the ISO 27001 surveillance audits (BSI), and the annual penetration test (Include Security). Control operation is monitored continuously by Vanta across 187 automated checks, wit

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[2] company-and-security-programme-overview — 8. How to obtain evidence — relevance 0.68

8. How to obtain evidence

The SOC 2 Type II report, the ISO 27001 certificate, the penetration test executive summary, and the standard DPA are available to customers and prospects under NDA through the account team, usually within two business days. The certificate and the trust page are available without an NDA.

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[3] company-and-security-programme-overview — 3. Security programme in summary — relevance 0.66

3. Security programme in summary

The programme is built on four commitments, each evidenced elsewhere in this corpus rather than asserted here:

1. ****Independent verification.**** SOC 2 Type II (Prescient Assurance LLP, report issued 14 March 2026 covering 1 January – 31 December 2025, ****no exceptions****) and ISO 27001:2022 (BSI certificate `IS-2025-44817`, issued 22 September 2025, valid to 21

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[4] soc2-control-matrix — SOC 2 Control Matrix — relevance 0.66

SOC 2 Control Matrix

****Document ID:**** KD-SEC-012 · ****Version:**** 2.1

****Report period:**** 1 January - 31 December 2025 · ****Report issued:**** 14 March 2026

****Auditor:**** Prescient Assurance LLP · ****Opinion:**** Unqualified, no exceptions noted

****Trust Services Criteria in scope:**** Security, Availability, Confidentiality

Privacy and Processing Integrity are ****not**** in scope for the current report. Ke

gs://attestor-505506-corporus/security/soc2-control-matrix.txt

[5] risk-management-and-governance — Risk Management and Security Governance — relevance 0.66

Risk Management and Security Governance

****Document ID:**** KD-SEC-018 · ****Version:**** 3.0 · ****Owner:**** Marcus Oyelaran, CISO

****Approved:**** 26 January 2026 · ****Next review:**** 26 January 2027

****Maps to:**** SOC 2 CC1.1, CC1.2, CC1.3, CC3.1, CC3.2, CC3.4 · ISO 27001:2022 A.5.1–A.5.4, Clauses 5–6, 9

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

79. Have TLS 1.0 and TLS 1.1 been disabled across all endpoints?

security · Q79 · Vendor Security Review row 80

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] encryption-standard — 2. Data in transit — relevance 0.68

2. Data in transit

****TLS 1.3**** is the default for all external connections. TLS 1.2 remains enabled solely for one legacy customer SFTP integration (INT-LEGACY-0004), scheduled for decommission in Q3 2026 and tracked as RISK-2025-0088. TLS 1.0 and 1.1 were disabled across all endpoints on 12 April 2024.

Cipher suites are restricted to the Mozilla Intermediate profile. HSTS is enabled with

gs://attestor-505506-corporus/security/encryption-standard.txt

[2] encryption-standard — 6. Post-quantum posture — relevance 0.59

6. Post-quantum posture

Kestrel completed a cryptographic inventory (`SEC-GOV/crypto-inventory`, 19 January 2026) as the first step toward post-quantum readiness. TLS connections terminated at Cloudflare already negotiate the hybrid X25519MLKEM768 key agreement where the client supports it. No migration commitment date has been set for internal services.

gs://attestor-505506-corporus/security/encryption-standard.txt

[3] encryption-standard — 5. Algorithm policy — relevance 0.57

5. Algorithm policy

Approved: AES-256-GCM, AES-256-CBC (legacy read paths only), RSA-2048 and above, ECDSA P-256 and P-384, SHA-256 and above, Argon2id and bcrypt (cost factor 12 or higher) for password hashing.

Prohibited: DES, 3DES, RC4, MD5 and SHA-1 for any security purpose, RSA below 2048 bits, and any custom cryptographic construction. Kestrel does not implement its own cryptographic

gs://attestor-505506-corporus/security/encryption-standard.txt

[4] encryption-standard — Encryption Standard — relevance 0.55

Encryption Standard

Document ID: KD-SEC-003 · **Version:** 2.4 · **Owner:** Marcus Oyelaran, CISO

Approved: 8 January 2026 · **Next review:** 8 January 2027

Maps to: SOC 2 CC6.7 · ISO 27001:2022 A.8.24 · GDPR Art. 32(1)(a)

gs://attestor-505506-corporus/security/encryption-standard.txt

[5] encryption-standard — 1. Data at rest — relevance 0.54

1. Data at rest

All customer data at rest is encrypted using **AES-256-GCM**. No customer data is stored unencrypted at any tier.

| Store | Mechanism | Key custody |

|---|---|---|

| Amazon RDS (PostgreSQL 16) | Storage-level encryption | AWS KMS CMK, per-environment |

| Amazon S3 | SSE-KMS | AWS KMS CMK, per-bucket |

| Snowflake | Native encryption, Tri-Secret Secure | Customer-managed key

gs://attestor-505506-corporus/security/encryption-standard.txt

80. In which jurisdictions is customer data processed?

legal · Q80 · Vendor Security Review row 81

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

81. What is the maximum age of a production compute node?

engineering · Q81 · Vendor Security Review row 82

Production compute node images are immutable and nodes are recycled with a maximum age of 30 days rather than being patched in place (KD-ENG-003 Infrastructure Architecture Overview, Section 3. Compute).

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (5)

[1] infrastructure-architecture-overview — 3. Compute — relevance 0.62

3. Compute

Amazon EKS (Kubernetes 1.31) with managed node groups spanning three availability zones.

Workloads run as containers built from distroless base images, as non-root, with read-only root filesystems and dropped Linux capabilities. Pod Security Standards are enforced at the `restricted` level.

Node images are immutable; nodes are recycled with a maximum age of 30 days rather than pa

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[2] infrastructure-architecture-overview — 6. Network — relevance 0.56

6. Network

Private subnets for all compute and data. No public IP addresses on workload instances. Ingress is exclusively through Cloudflare, then an AWS Application Load Balancer, then the Istio ingress gateway. Egress is through NAT gateways with an allowlist for known destinations.

Security groups are managed in Terraform and default-deny. There are no `0.0.0.0/0` ingress rules in produc

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[3] infrastructure-architecture-overview — 1. Cloud footprint — relevance 0.54

1. Cloud footprint

Kestrel runs on **Amazon Web Services**. There are two independent production instances:

Instance	Region	Serves
----------	--------	--------

---	---	---
-----	-----	-----

US	us-east-1 (3 AZs)	North America, and customers with no residency requirement
----	-------------------	--

EU	eu-west-1 (3 AZs)	EEA, UK, and Swiss customers electing EU residency
----	-------------------	--

Backup replication targets us-west-2 and eu-central-1 respecti

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[4] infrastructure-architecture-overview — 2. Account structure — relevance 0.53

2. Account structure

AWS Organizations with 9 accounts: management, security-tooling, log-archive, shared-services, prod-us, prod-eu, staging, dev, sandbox. Service Control Policies enforce guardrails at the Organization level, including mandatory EBS encryption, denial of root user actions, and denial of CloudTrail or GuardDuty disablement.

The log-archive account has no

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[5] infrastructure-architecture-overview — Infrastructure Architecture Overview — relevance 0.52

Infrastructure Architecture Overview

Document ID: KD-ENG-003 · **Version:** 3.4 · **Owner:** Dana Whitfield, VP Engineering

Last updated: 5 February 2026 · **Classification:** Confidential, NDA required

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

82. Will you execute a Data Processing Agreement?

legal · Q82 · Vendor Security Review row 83

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

83. Do engineers receive secure development training? Provide supporting evidence.

engineering · Q83 · Vendor Security Review row 84

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

84. For each applicable system: Describe your process for responding to government requests for customer data.

legal · Q84 · Vendor Security Review row 85

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

85. Do you have a documented exit plan from your cloud provider?

engineering · Q85 · Vendor Security Review row 86

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

86. Have you appointed an EU representative under Article 27?

legal · Q86 · Vendor Security Review row 87

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

87. What is your Recovery Point Objective?

engineering · Q87 · Vendor Security Review row 88

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

88. What is your remediation SLA for Critical severity vulnerabilities?

security · Q88 · Vendor Security Review row 89

Our remediation SLA for Critical severity vulnerabilities (CVSS 9.0–10.0) is ****7 days****, as defined in our ***Vulnerability Management Policy*** (§1, "Remediation SLAs"). Vulnerability severity is determined using CVSS v3.1 base scores adjusted for exploitability and exposure, with internet-facing findings automatically escalated by one severity level. In 2025, our measured compliance with the Critical remediation SLA was 100% (11 of 11 findings remediated within SLA).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] vulnerability-management-policy — 1. Remediation SLAs — relevance 0.76

1. Remediation SLAs

Severity is assigned from CVSS v3.1 base score, adjusted for exploitability and exposure.

Internet-facing findings are escalated one level.

| Severity | CVSS | Remediation SLA | Measured 2025 compliance |

|---|---|---|---|

| Critical | 9.0-10.0 | ****7 days**** | 100% (11 of 11) |

| High | 7.0-8.9 | ****30 days**** | 96% (74 of 77) |

| Medium | 4.0-6.9 | ****90 days**** | 91% |

|

gs://attestor-505506-corpus/security/vulnerability-management-policy.txt

[2] vulnerability-management-policy — 6. Exceptions — relevance 0.69

6. Exceptions

A finding that cannot be remediated within SLA requires a documented exception approved by the CISO, with a compensating control and an expiry date not exceeding 180 days.

gs://attestor-505506-corpus/security/vulnerability-management-policy.txt

[3] cloud-security-posture-standard — 6. Handling a vulnerability with no upstream fix — relevance 0.64

6. Handling a vulnerability with no upstream fix

Where no upstream fix exists, the finding is recorded in the risk register with a named owner and the mitigation is chosen from: removing the affected component, blocking the

attack path at the network or WAF layer, or applying a vendored patch maintained by Kestrel (see KD-ENG-007 §7). The vulnerability is re-reviewed weekly until an upstream fix
|

gs://attestor-505506-corporus/security/cloud-security-posture-standard.txt

[4] vulnerability-management-policy — Vulnerability Management Policy — relevance 0.64

Vulnerability Management Policy

****Document ID:**** KD-SEC-006 · ****Version:**** 3.3 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 22 January 2026 · ****Next review:**** 22 January 2027

****Maps to:**** SOC 2 CC7.1, CC7.2 · ISO 27001:2022 A.8.8

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[5] vulnerability-management-policy — 3. Patch management — relevance 0.63

3. Patch management

Operating system patching is handled by rebuilding immutable AMIs; instances are replaced rather than patched in place. The base image is rebuilt weekly and on any Critical CVE affecting it. Kubernetes node groups are recycled on a rolling basis with a maximum node age of ****30 days****.

Managed services (RDS, ElastiCache, EKS control plane) follow AWS maintenance windows,

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

89. Describe your approach to environmental sustainability and carbon reporting.

unassigned · Q89 · Vendor Security Review row 90

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

90. How much notice is given before scheduled maintenance?

engineering · Q90 · Vendor Security Review row 91

Customers receive at least 7 days' advance notice for any scheduled maintenance expected to be customer-affecting or to cause degraded service (`service-operations-and-support`, "2. Scheduled maintenance"; `change-management-procedure`, "6. Customer notification"). When a scheduled change requires customer action, notice is extended to 30 days (`service-operations-and-support`, "2. Scheduled maintenance"), and breaking API changes follow a deprecation policy providing a minimum of 12 months' notice (`change-management-procedure`, "6. Customer notification"). Notifications are delivered by email directly to tenant administrators and published on the independent status page at `status.kestreldata.com` (`service-operations-and-support`, "1. Status page", "2. Scheduled maintenance"). For emergency maintenance—such as an urgent security fix—work may proceed with shorter notice under the emergency change procedure, with notifications dispatched as soon as the maintenance is scheduled (`service-operations-and-support`, "2. Scheduled maintenance").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (5)

[1] service-operations-and-support — 2. Scheduled maintenance — relevance 0.66

2. Scheduled maintenance

The standard maintenance window is ****Sundays 06:00–10:00 UTC****. Most changes do not use it: deployments are rolling and zero-downtime, and 2025 saw 1,412 production deployments with no customer-visible downtime.

****Customers receive at least 7 days' notice of scheduled maintenance expected to be customer-affecting**, and 30 days' notice where the change requires customer a**

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[2] change-management-procedure — 6. Customer notification — relevance 0.59

6. Customer notification

Customers are notified at least **7 days** in advance of any change expected to cause degraded service or to require action on their part. Breaking API changes follow the deprecation policy: minimum **12 months** notice, with the deprecated version remaining available throughout.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[3] service-operations-and-support — Service Operations, Maintenance and Support — relevance 0.58

Service Operations, Maintenance and Support

Document ID: KD-ENG-009 · **Version:** 2.2 · **Owner:** Dana Whitfield, VP Engineering

Approved: 23 January 2026 · **Next review:** 23 January 2027

Maps to: SOC 2 A1.1, A1.2, CC7.3, CC8.1 · ISO 27001:2022 A.5.29, A.8.6, A.8.32

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[4] service-operations-and-support — 1. Status page — relevance 0.57

1. Status page

Service status is published at `status.kestreldata.com`, hosted by Statuspage on infrastructure independent of Kestrel's own — a status page that shares a failure domain with the service is worthless during exactly the event it exists for. The page shows per-component status for the US and EU instances, current and historical incidents, and scheduled maintenance. Customers may s

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[5] change-management-procedure — Change Management Procedure — relevance 0.55

Change Management Procedure

Document ID: KD-ENG-002 · **Version:** 3.0 · **Owner:** Dana Whitfield, VP Engineering

Approved: 20 January 2026 · **Maps to:** SOC 2 CC8.1 · ISO 27001:2022 A.8.32

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

91. For each applicable system: How do workloads authenticate to cloud services?

engineering · Q91 · Vendor Security Review row 92

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

92. Do you support SCIM user provisioning?

security · Q92 · Vendor Security Review row 93

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

93. Please confirm: How do you detect prohibited licences?

engineering · Q93 · Vendor Security Review row 94

License compliance is checked automatically in the CI pipeline using FOSSA on every pull request (`third-party-library-policy`, section "2. Licence policy"). Any pull request introducing a prohibited license—such as GPL-2.0, GPL-3.0, AGPL-1.0, AGPL-3.0, SSPL, BUSL, Commons Clause, or any license without a clear grant—automatically fails the build (`third-party-library-policy`, section "2. Licence policy"). Additionally, adding any new direct dependency requires a pull request where the license is documented and verified against the allowlist prior to review (`third-party-library-policy`, section "1. Adding a dependency").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (5)

[1] third-party-library-policy — 2. Licence policy — relevance 0.59

2. Licence policy

****Allowed:**** MIT, BSD-2-Clause, BSD-3-Clause, Apache-2.0, ISC, Python Software Foundation, Unlicense, CC0.

****Requires legal review:**** MPL-2.0, LGPL-2.1, LGPL-3.0, EPL-2.0.

****Prohibited:**** GPL-2.0, GPL-3.0, AGPL-1.0, AGPL-3.0, SSPL, BUSL, Commons Clause, and any licence without a clear grant. AGPL and SSPL are prohibited because Kestrel distributes a network service.

L

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[2] third-party-library-policy — 1. Adding a dependency — relevance 0.52

1. Adding a dependency

A new direct dependency requires a pull request that documents:

1. Why an existing dependency or the standard library is insufficient.
2. The licence, checked against the allowlist below.
3. Maintenance signal: last release date, open critical issues, number of maintainers.
4. Transitive dependency count added.

Review is by any engineer other than the author. Depend

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[3] third-party-library-policy — 7. Internal forks — relevance 0.49

7. Internal forks

Forking a third-party library requires VP Engineering approval and creates an obligation to track upstream security advisories manually. Kestrel currently maintains ****zero**** internal forks, deliberately.

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[4] third-party-library-policy — Third-Party Library Policy — relevance 0.49

Third-Party Library Policy

****Document ID:**** KD-ENG-008 · ****Version:**** 1.4 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 22 January 2026 · ****Maps to:**** SOC 2 CC7.1 · ISO 27001:2022 A.8.28

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[5] third-party-library-policy — 6. Unmaintained dependencies — relevance 0.48

6. Unmaintained dependencies

A dependency with no release in 24 months and no active maintainer is flagged for replacement. Three such dependencies were identified in the January 2026 review, all scheduled for replacement by Q3 2026.

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

94. Do Kestrel personnel routinely access customer production data? Provide supporting evidence.

security · Q94 · Vendor Security Review row 95

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] access-control-standard — 5. Customer data access — relevance 0.81

5. Customer data access

Kestrel personnel do not access customer production data as a matter of routine. Access for support purposes requires explicit per-incident customer authorisation recorded in Zendesk, is limited to the specific tenant, and expires after 24 hours.

Between 1 January and 31 December 2025 there were 19 such authorised accesses across 7

customers, each evidenced in the SOC

gs://attestor-505506-corpus/security/access-control-standard.txt

[2] incident-response-runbook — 4. Customer notification commitments — relevance 0.76

4. Customer notification commitments

These are contractual and are reproduced in the DPA (KD-LEG-001) and the Security Addendum (KD-LEG-008):

- **Personal data breach** - affected customers notified without undue delay and in any event **within 72 hours** of Kestrel confirming the breach.
- **Confirmed unauthorised access to customer production data** - affected customers notified **with**

gs://attestor-505506-corpus/security/incident-response-runbook.txt

[3] information-security-policy — 9. Incident response — relevance 0.76

9. Incident response

Security incidents are handled under the Incident Response Runbook (KD-SEC-005). Kestrel commits contractually to notifying affected customers within 72 hours of confirming a personal data breach, and within 24 hours for incidents involving confirmed unauthorised access to customer production data.

gs://attestor-505506-corpus/security/information-security-policy.txt

[4] information-security-policy — 1. Purpose and scope — relevance 0.74

1. Purpose and scope

This policy establishes how Kestrel Data, Inc. ("Kestrel") protects the confidentiality, integrity, and availability of information belonging to Kestrel and to customers of the Kestrel Insight platform.

It applies to all 187 employees and to all 24 contractors engaged as of 1 February 2026, to every system that processes Kestrel or customer data, and to all facilities includi

gs://attestor-505506-corpus/security/information-security-policy.txt

[5] physical-and-environmental-security — 1. Production infrastructure — relevance 0.74

1. Production infrastructure

Kestrel Data operates **no owned or leased data centre**. All production infrastructure runs in AWS: `us-east-1` for the US instance and `eu-west-1` for the EU instance. Physical and environmental controls for those facilities — perimeter security, biometric access, CCTV, fire suppression, power redundancy, environmental monitoring, and media destruction — are AWS's re

gs://attestor-505506-corpus/security/physical-and-environmental-security.txt

95. Are you self-certified under the EU-US Data Privacy Framework? Provide supporting evidence.

legal · Q95 · Vendor Security Review row 96

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

96. Provide evidence of your most recent user access review. If not, describe compensating controls.

security · Q96 · Vendor Security Review row 97

Kestrel Data conducts quarterly user access reviews covering all production systems, the AWS Organization, Snowflake, GitHub, and Okta itself. These reviews are performed by the respective system owners and formally attested in Vanta. As evidence of the most recent cycle, the Q4 2025 access review was completed on 12 January 2026, resulting in the removal of 23 entitlements, including 9 stale contractor accesses (*Access Control Standard*, Section 7, "Access reviews").

Evidence (5)

[1] risk-management-and-governance — 9. Exceptions — relevance 0.64

9. Exceptions

Exceptions to policy require: a written business justification, a compensating control, CISO approval, and an expiry date no later than 90 days out. Exceptions above residual score 12 additionally require Security Steering Group approval. Two exceptions were open as of 1 February 2026.

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[2] information-security-policy — 10. Exceptions — relevance 0.61

10. Exceptions

Exceptions to this policy require written approval from the CISO, a documented compensating control, and an expiry date not exceeding 180 days. Four exceptions are open as of 11 February 2026, all tracked in Vanta and all with expiry dates before 30 September 2026.

gs://attestor-505506-corporus/security/information-security-policy.txt

[3] access-control-standard — Access Control Standard — relevance 0.60

Access Control Standard

****Document ID:**** KD-SEC-002 · ****Version:**** 3.1 · ****Owner:**** Sofia Brenner, Head of IT
****Approved:**** 8 January 2026 · ****Next review:**** 8 January 2027
****Maps to:**** SOC 2 CC6.1, CC6.2, CC6.3 · ISO 27001:2022 A.5.15, A.5.16, A.5.18, A.8.2

gs://attestor-505506-corporus/security/access-control-standard.txt

[4] access-control-standard — 3. Role-based access — relevance 0.60

3. Role-based access

Access is granted to Okta groups, never to individuals. There are 41 defined roles, each mapping to a documented entitlement set in the Access Matrix (`SEC-GOV/access-matrix`), which is the authoritative record reviewed during audit. Standing production access is limited to 11 named Site Reliability Engineers. All other production access is just-in-time.

gs://attestor-505506-corporus/security/access-control-standard.txt

[5] access-control-standard — 7. Access reviews — relevance 0.60

7. Access reviews

Quarterly user access reviews cover all production systems, the AWS Organization, Snowflake, GitHub, and Okta itself. Reviews are performed by the system owner and attested in Vanta. The Q4 2025 review completed on 12 January 2026 and removed 23 entitlements, of which 9 were stale contractor accesses.

gs://attestor-505506-corporus/security/access-control-standard.txt

97. For each applicable system: Provide an overview of your information security programme.

security · Q97 · Vendor Security Review row 98

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

98. How many employees and contractors does your organisation have?

unassigned · Q98 · Vendor Security Review row 99

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

99. Provide your Information Security Policy.

security · Q99 · Vendor Security Review row 100

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

100. Which module of the 2021 Standard Contractual Clauses do you use?

legal · Q100 · Vendor Security Review row 101

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

101. How many security incidents were recorded in the last calendar year?

security · Q101 · Vendor Security Review row 102

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

102. Do you have a documented exit plan from your cloud provider? If not, describe compensating controls.

engineering · Q102 · Vendor Security Review row 103

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (6)

[1] cloud-exit-and-portability-plan — 2. Exit triggers — relevance 0.71

2. Exit triggers

The plan would be invoked on: sustained material degradation of AWS service, a commercial breakdown or unacceptable pricing change, a regulatory instruction, or a security failure at the provider that could not be compensated for.

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[2] cloud-exit-and-portability-plan — Cloud Exit and Portability Plan — relevance 0.71

Cloud Exit and Portability Plan

****Document ID:**** KD-ENG-010 · ****Version:**** 1.7 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 30 January 2026 · ****Next review:**** 30 January 2027

****Maps to:**** SOC 2 A1.2, CC9.1 · ISO 27001:2022 A.5.19, A.5.21, A.5.30 · EBA/DORA-aligned

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[3] cloud-exit-and-portability-plan — 4. Estimated exit timeline — relevance 0.65

4. Estimated exit timeline

The tabletop exercise produced these estimates, which are planning figures rather than commitments:

| Phase | Work | Estimate |

|---|---|---|

| 1 | Target selection, landing zone, network and identity foundation | 4–6 weeks |

| 2 | Terraform provider rewrite, CI/CD retargeting | 6–8 weeks |

| 3 | Data migration — Snowflake region move, PostgreSQL logical replication, ob

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[4] cloud-exit-and-portability-plan — 5. Customer-facing continuity during an exit — relevance 0.64

5. Customer-facing continuity during an exit

An exit would be executed instance by instance, with EU and US cut over separately, and **data residency commitments would be honoured throughout**: an EU tenant would move to an EU region of the target provider, never transiting a US region. Customers would be given a minimum of 90 days' notice of a planned provider change and would retain their export

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[5] cloud-exit-and-portability-plan — 3. Portability by design — relevance 0.64

3. Portability by design

The architecture is deliberately biased toward portable components, and the exceptions are listed rather than glossed over:

Layer	Technology	Portability
Compute	Kubernetes (EKS)	High — standard manifests, no EKS-specific APIs in workloads
Container images	OCI in ECR	High — registry is a copy operation
Data warehouse	Snowflake	Hi

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[6] data-flow-and-shared-responsibility — 4. Complementary user entity controls — relevance 0.62

4. Complementary user entity controls

The SOC 2 report lists these as complementary user entity controls; they are restated here because a customer reading only this document should still see them. If a customer does not operate the controls in the second list, Kestrel's controls in the first do not compensate: Kestrel cannot detect that a departed employee of the customer still holds a valid sess

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

103. Do you operate a web application firewall?

security · Q103 · Vendor Security Review row 104

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

104. How do workloads authenticate to cloud services?

engineering · Q104 · Vendor Security Review row 105

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

105. How do you detect prohibited licences?

engineering · Q105 · Vendor Security Review row 106

Licence compliance is automatically checked in CI using FOSSA on every pull request. If a prohibited licence is detected, the build fails automatically (Third-Party Library Policy, Section 2. Licence policy). Additionally, when proposing a new direct dependency, engineers must check the licence against Kestrel's allowlist as part of the pull request documentation and review process (Third-Party Library Policy, Section 1. Adding a dependency).

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (5)

[1] third-party-library-policy — 2. Licence policy — relevance 0.60

2. Licence policy

Allowed: MIT, BSD-2-Clause, BSD-3-Clause, Apache-2.0, ISC, Python Software Foundation, Unlicense, CCO.

****Requires legal review:**** MPL-2.0, LGPL-2.1, LGPL-3.0, EPL-2.0.

****Prohibited:**** GPL-2.0, GPL-3.0, AGPL-1.0, AGPL-3.0, SSPL, BUSL, Commons Clause, and any licence without a clear grant. AGPL and SSPL are prohibited because Kestrel distributes a network service.

L

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[2] third-party-library-policy — 1. Adding a dependency — relevance 0.53

1. Adding a dependency

A new direct dependency requires a pull request that documents:

1. Why an existing dependency or the standard library is insufficient.
2. The licence, checked against the allowlist below.
3. Maintenance signal: last release date, open critical issues, number of maintainers.
4. Transitive dependency count added.

Review is by any engineer other than the author. Depend

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[3] third-party-library-policy — 7. Internal forks — relevance 0.50

7. Internal forks

Forking a third-party library requires VP Engineering approval and creates an obligation to track upstream security advisories manually. Kestrel currently maintains ****zero**** internal forks, deliberately.

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[4] third-party-library-policy — Third-Party Library Policy — relevance 0.49

Third-Party Library Policy

****Document ID:**** KD-ENG-008 · ****Version:**** 1.4 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 22 January 2026 · ****Maps to:**** SOC 2 CC7.1 · ISO 27001:2022 A.8.28

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[5] third-party-library-policy — 6. Unmaintained dependencies — relevance 0.49

6. Unmaintained dependencies

A dependency with no release in 24 months and no active maintainer is flagged for replacement. Three such dependencies were identified in the January 2026 review, all scheduled for replacement by Q3 2026.

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

106. Do you sell personal data to third parties?

legal · Q106 · Vendor Security Review row 107

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

107. Describe how tenant isolation is enforced.

engineering · Q107 · Vendor Security Review row 108

Kestrel Insight is a multi-tenant platform with logical isolation enforced across three distinct layers ('infrastructure-architecture-overview', '5. Tenant isolation'): 1. ****Database Layer:**** PostgreSQL row-level security (RLS) policies are keyed on `tenant\_id` and applied at the connection level via an authenticated session variable. No application query is permitted to opt out. 2. ****Application Layer:**** Every incoming request carries a validated tenant claim. The data access layer enforces this through a repository base class, which automatically refuses any query that lacks a tenant predicate rather than relying on developer convention. 3. ****Storage Layer:**** Amazon S3 object keys are prefixed by tenant, and AWS IAM policies restrict access strictly by prefix. Tenant isolation is continuously verified on

every build by an 84-assertion test suite that attempts cross-tenant reads across all public API surfaces ('infrastructure-architecture-overview', "5. Tenant isolation"; 'sdlc-policy', "3. Testing requirements"). Additionally, any code changes touching tenant isolation require two approving pull request reviews enforced via 'CODEOWNERS' ('sdlc-policy', "1. Branching and review"). Tenant isolation was also independently validated during the February 2026 penetration test, with zero cross-tenant access achieved ('infrastructure-architecture-overview', "5. Tenant isolation").

Release status: No — held for a human · confidence low · drafted by EngineeringAgent

Evidence (4)

[1] infrastructure-architecture-overview — 5. Tenant isolation — relevance 0.50

5. Tenant isolation

Kestrel Insight is **multi-tenant** with logical isolation. There is no per-customer infrastructure, no single-tenant deployment option, and no customer-VPC option.

Isolation is enforced at three layers:

1. **Database** - PostgreSQL row-level security policies keyed on 'tenant_id', applied at the connection level from an authenticated session variable. No application

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[2] sdlc-policy — 3. Testing requirements — relevance 0.49

3. Testing requirements

- Unit test coverage gate at **80%** on changed lines, enforced in CI.
- Integration tests run against ephemeral infrastructure provisioned per pull request.
- Tenant isolation tests run on every build: a suite of 84 assertions attempting cross-tenant reads through every public API surface.
- Load tests before any release expected to change the performance profile.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[3] sdlc-policy — 1. Branching and review — relevance 0.47

1. Branching and review

'main' is protected and always releasable. All work happens on short-lived branches merged by pull request. 'main' requires:

- At least **one approving review** from a engineer other than the author. Self-approval is blocked at the platform level.
- Two approvals for changes touching authentication, authorisation, tenant isolation, or cryptography. These paths ar

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[4] data-flow-and-shared-responsibility — 3. The shared responsibility model — relevance 0.46

- * deciding what data they upload, and its lawfulness — Kestrel does not inspect it;
- * configuring SSO, and enforcing MFA at their own identity provider;
- * managing their own users, roles, and permissions, including timely removal of leavers;
- * the scope, storage, and rotation of the API credentials they create;
- * reviewing their own audit log, which Kestrel makes available for 13 months;
- * acting

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

108. How long is product telemetry retained?

legal · Q108 · Vendor Security Review row 109

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

109. How much notice do you provide before adding a subprocessor?

legal · Q109 · Vendor Security Review row 110

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

110. Are you self-certified under the EU-US Data Privacy Framework?

legal · Q110 · Vendor Security Review row 111

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

111. Provide the technical and organisational measures annexed to your DPA. Provide supporting evidence.

legal · Q111 · Vendor Security Review row 112

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (8)

[1] dpa-annex-2-technical-measures — DPA Annex 2 - Technical and Organisational Measures — relevance 0.77

DPA Annex 2 - Technical and Organisational Measures

Document ID: KD-LEG-009 · **Version:** 4.0 · **Owner:** Marcus Oyelaran, CISO

Effective: 1 February 2026 · Annex to the DPA (KD-LEG-001)

Maps to: GDPR Art. 32

Measures are described at a level that allows a controller to assess adequacy under Art. 32 without exposing information that would itself create risk.

gs://attestor-505506-corpus/legal/dpa-annex-2-technical-measures.txt

[2] gdpr-records-of-processing — Data Protection Impact Assessments — relevance 0.66

Data Protection Impact Assessments

One DPIA is on file, covering the introduction of the anomaly detection feature

(`LEG-GOV/dpia-2025-01`, completed 8 September 2025). Conclusion: residual risk low, no prior consultation with the supervisory authority required.

gs://attestor-505506-corpus/legal/gdpr-records-of-processing.txt

[3] data-processing-agreement — 4. Security — relevance 0.65

4. Security

Kestrel implements the technical and organisational measures set out in **Annex 2**, including encryption at rest (AES-256-GCM) and in transit (TLS 1.3), least-privilege access control with mandatory hardware MFA, and continuous monitoring.

gs://attestor-505506-corpus/legal/data-processing-agreement.txt

[4] dpa-annex-2-technical-measures — 4. Regular testing and evaluation (Art. 32(1)(d)) — relevance 0.65

4. Regular testing and evaluation (Art. 32(1)(d))

| Activity | Frequency | Last performed |

|---|---|---|

| Independent penetration test | Annual minimum | 3-14 February 2026 |

| SOC 2 Type II audit | Annual | Period ended 31 December 2025 |

| ISO 27001 surveillance audit | Annual | 22 September 2025 |

| Disaster recovery restore test | Quarterly | 17 January 2026 |

| User access review | Qu

gs://attestor-505506-corpus/legal/dpa-annex-2-technical-measures.txt

[5] transfer-impact-assessment — 5. Supplementary measures relied on — relevance 0.65

5. Supplementary measures relied on
Technical:

1. **Data residency by default** — EU customer content, including backups and the replicated log ship, never leaves `eu-west-1`.
2. **Encryption in transit** — TLS 1.3 (1.2 minimum) on every hop, including between Kestrel and each sub-processor.
3. **Encryption at rest** — AES-256-GCM with keys in AWS KMS. Keys for the EU instance are held i

gs://attestor-505506-corpus/legal/transfer-impact-assessment.txt

[6] dpa-annex-2-technical-measures — 3. Restoring availability (Art. 32(1)(c)) — relevance 0.61

3. Restoring availability (Art. 32(1)(c))
RTO 4 hours, RPO 15 minutes. The 17 January 2026 full failover exercise achieved 2 hours 41 minutes and 4 minutes respectively. Results are documented in KD-SEC-010.

gs://attestor-505506-corpus/legal/dpa-annex-2-technical-measures.txt

[7] dpa-annex-2-technical-measures — 2. Confidentiality, integrity, availability, resilience (Art. 32(1)(b)) — relevance 0.59

2. Confidentiality, integrity, availability, resilience (Art. 32(1)(b))
Confidentiality. Least-privilege access via Okta with mandatory hardware MFA; just-in-time production elevation expiring in 8 hours; tenant isolation verified by independent penetration testing (no cross-tenant access achieved, February 2026).

Integrity. All changes reviewed and merged through pull request with a

gs://attestor-505506-corpus/legal/dpa-annex-2-technical-measures.txt

[8] dpa-annex-2-technical-measures — 1. Pseudonymisation and encryption (Art. 32(1)(a)) — relevance 0.58

1. Pseudonymisation and encryption (Art. 32(1)(a))
Data at rest is encrypted with AES-256-GCM across RDS, S3, EBS, and Snowflake. Data in transit uses TLS 1.3 externally and mutual TLS internally within the service mesh. Application logs are pseudonymised at emission: direct identifiers are replaced with opaque `tenant\_id` and `user\_id` values before the log leaves the process.

gs://attestor-505506-corpus/legal/dpa-annex-2-technical-measures.txt

112. Is restore tested by performing an actual restore, or by verifying backup existence?

engineering · Q112 · Vendor Security Review row 113

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

113. Please confirm: Do you use customer content to train machine learning models?

legal · Q113 · Vendor Security Review row 114

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

114. Are you FedRAMP authorised?

security · Q114 · Vendor Security Review row 115

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

115. Do you permit use of generative AI tools with customer data?

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

116. Can a privileged administrator delete or alter audit logs?

security · Q116 · Vendor Security Review row 117

No, privileged administrators cannot delete or alter audit logs. Audit logs are protected by the following controls: * **Compliance Mode Object Lock:** The security archive bucket uses Amazon S3 Object Lock in compliance mode, which cannot be disabled, altered, or shortened by any principal, including the AWS account root user ('logging-monitoring-standard', Section 3, "Tamper resistance"). * **Account Isolation:** Logs (including multi-region CloudTrail, VPC flow logs, GuardDuty findings, and AWS Config history) are delivered to a dedicated archive account ('kd-security') with no human standing access, ensuring that engineering roles and the accounts generating the evidence cannot write to or modify the audit trail ('logging-monitoring-standard', Section 3, "Tamper resistance"; 'cloud-security-posture-standard', Section 8, "Logging and evidence"). * **Log Integrity Validation:** CloudTrail log file integrity validation is enabled to detect any tampering or modification ('logging-monitoring-standard', Section 3, "Tamper resistance").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] logging-monitoring-standard — 6. Customer access to logs — relevance 0.62

6. Customer access to logs

Enterprise-tier customers can retrieve tenant-scoped audit events for their own organisation through the Audit API ('GET /v2/audit/events'), covering the previous 365 days. Kestrel does not expose its own infrastructure logs to customers; relevant extracts are provided during incident response on request.

gs://attestor-505506-corpus/security/logging-monitoring-standard.txt

[2] logging-monitoring-standard — 3. Tamper resistance — relevance 0.61

3. Tamper resistance

The security archive bucket uses S3 Object Lock in **compliance mode**, which cannot be disabled or shortened by any principal including the AWS account root. CloudTrail log file integrity validation is enabled. The archive account is a separate AWS account with no human standing access; writes arrive only through the organisation trail.

gs://attestor-505506-corpus/security/logging-monitoring-standard.txt

[3] cloud-security-posture-standard — 8. Logging and evidence — relevance 0.61

8. Logging and evidence

CloudTrail (all regions, all accounts), VPC flow logs, GuardDuty findings, and Config history are delivered to a dedicated 'kd-security' account that no engineering role can write to, with object lock set to 400 days. This is the arrangement that makes the audit trail defensible: the accounts that generate the evidence cannot alter it.

gs://attestor-505506-corpus/security/cloud-security-posture-standard.txt

[4] cloud-security-posture-standard — 3. Manual console changes — relevance 0.57

3. Manual console changes

Manual changes in the production AWS console are not permitted. Human IAM principals in production accounts hold read-only permissions by default; write access is obtained through the just-in-time process in KD-SEC-002 §4, is time-boxed to 8 hours, and is intended for incident response rather than routine change.

Any write action taken by a human principal in product

gs://attestor-505506-corpus/security/cloud-security-posture-standard.txt

[5] logging-monitoring-standard — 2. Retention — relevance 0.57

2. Retention

| Log class | Hot (searchable) | Archive | Total |

|---|---|---|---|
| Security and audit (CloudTrail, Okta) | 90 days in Datadog | 7 years in S3 Glacier | **7 years** |
| Application | 30 days in Datadog | 1 year in S3 | 1 year |
| Snowflake ACCESS_HISTORY | 365 days native | 7 years in S3 | 7 years |
| VPC Flow / WAF | 30 days | 1 year | 1 year |

gs://attestor-505506-corporus/security/logging-monitoring-standard.txt

117. Does the platform incorporate any machine learning models that process customer data?

engineering · Q117 · Vendor Security Review row 118

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

118. What categories of customer data does the platform process?

legal · Q118 · Vendor Security Review row 119

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

119. How far back are customer-accessible audit logs available?

security · Q119 · Vendor Security Review row 120

Enterprise-tier customers can access tenant-scoped audit events for their organization covering the previous 365 days via the Audit API (`GET /v2/audit/events`) (`logging-monitoring-standard`, Section 6, "Customer access to logs"). While Kestrel does not expose its underlying infrastructure logs directly to customers, relevant log extracts are provided upon request during incident response (`logging-monitoring-standard`, Section 6, "Customer access to logs").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] logging-monitoring-standard — 2. Retention — relevance 0.71

2. Retention

| Log class | Hot (searchable) | Archive | Total |

|---|---|---|---|

| Security and audit (CloudTrail, Okta) | 90 days in Datadog | 7 years in S3 Glacier | **7 years** |

| Application | 30 days in Datadog | 1 year in S3 | 1 year |

| Snowflake ACCESS_HISTORY | 365 days native | 7 years in S3 | 7 years |

| VPC Flow / WAF | 30 days | 1 year | 1 year |

gs://attestor-505506-corporus/security/logging-monitoring-standard.txt

[2] logging-monitoring-standard — 6. Customer access to logs — relevance 0.69

6. Customer access to logs

Enterprise-tier customers can retrieve tenant-scoped audit events for their own organisation through the Audit API (`GET /v2/audit/events`), covering the previous 365 days. Kestrel does not expose its own infrastructure logs to customers; relevant extracts are provided during incident response on request.

gs://attestor-505506-corporus/security/logging-monitoring-standard.txt

[3] logging-monitoring-standard — 3. Tamper resistance — relevance 0.63

3. Tamper resistance

The security archive bucket uses S3 Object Lock in **compliance mode**, which cannot be disabled or shortened by any principal including the AWS account root. CloudTrail log file integrity validation is enabled. The archive account is a separate AWS account with no human standing access; writes arrive only through the organisation trail.

gs://attestor-505506-corporus/security/logging-monitoring-standard.txt

[4] cloud-security-posture-standard — 8. Logging and evidence — relevance 0.63

8. Logging and evidence

CloudTrail (all regions, all accounts), VPC flow logs, GuardDuty findings, and Config history are delivered to a dedicated `kd-security` account that no engineering role can write to, with object lock set to 400 days. This is the arrangement that makes the audit trail defensible: the accounts that generate the evidence cannot alter it.

gs://attestor-505506-corpus/security/cloud-security-posture-standard.txt

[5] logging-monitoring-standard — 1. What is logged — relevance 0.61

1. What is logged

- **Authentication** - every Okta event: sign-in success and failure, MFA challenge, factor enrolment, admin action.
- **Authorisation** - every JIT production elevation, approval, and expiry.
- **Data access** - all queries against customer data in Snowflake, captured via `ACCESS\_HISTORY`, including the querying identity and the objects touched.
- **Infrastructure** - A

gs://attestor-505506-corpus/security/logging-monitoring-standard.txt

120. Provide your public privacy policy. Provide supporting evidence.

legal · Q120 · Vendor Security Review row 121

Quarantined: Model Armor blocked this question.

Release status: No — quarantined by the guardrail · confidence low · drafted by ArmorGuard

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

121. For which data stores are customer-managed keys available?

engineering · Q121 · Vendor Security Review row 122

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (9)

[1] data-flow-and-shared-responsibility — 6. Where processing occurs — relevance 0.64

6. Where processing occurs

Processing occurs in AWS `us-east-1` (US instance) and AWS `eu-west-1` (EU instance), by personnel located in the United States, the European Union, the United Kingdom, and Canada, under the access controls in KD-SEC-002. **No processing occurs outside the stated regions**, and no support is subcontracted to a third-party provider in another jurisdiction.

gs://attestor-505506-corpus/engineering/data-flow-and-shared-responsibility.txt

[2] data-flow-and-shared-responsibility — 1. Data flow, end to end — relevance 0.63

1. Data flow, end to end

1. **Ingress.** A customer's browser or API client resolves `app.kestreldata.com` or `api.kestreldata.com` to Cloudflare, which terminates TLS 1.3 (1.2 minimum) and applies WAF and rate limiting.
2. **Instance selection.** DNS and tenant routing send the request to the instance chosen at contract signature: `us-east-1` or `eu-west-1`. **A tenant's requests never c**

gs://attestor-505506-corpus/engineering/data-flow-and-shared-responsibility.txt

[3] secrets-management-standard — 6. Customer-issued API credentials — relevance 0.62

6. Customer-issued API credentials

API keys issued to customers are stored as Argon2id hashes; Kestrel cannot recover the plaintext of a customer API key and will not do so on request. Keys are displayed once at creation. Customers can create, scope, and revoke keys through the console, and each key carries a last-used timestamp so stale keys are visible.

gs://attestor-505506-corpus/engineering/secrets-management-standard.txt

[4] backup-restore-procedure — 2. Encryption and location — relevance 0.60

2. Encryption and location

All backups are encrypted with AES-256 using AWS KMS. The daily logical dump uses a **separate CMK** from the primary database, so that compromise of the primary key does not compromise the backups.

Cross-region replication stays inside the residency boundary: `us-east-1` replicates to `us-west-2`, `eu-west-1` replicates to `eu-central-1`. EU customer data never le

gs://attestor-505506-corpus/engineering/backup-restore-procedure.txt

[5] infrastructure-architecture-overview — 3. Compute — relevance 0.60

3. Compute

Amazon EKS (Kubernetes 1.31) with managed node groups spanning three availability zones. Workloads run as containers built from distroless base images, as non-root, with read-only root filesystems and dropped Linux capabilities. Pod Security Standards are enforced at the `restricted` level.

Node images are immutable; nodes are recycled with a maximum age of 30 days rather than pa

gs://attestor-505506-corpus/engineering/infrastructure-architecture-overview.txt

[6] cloud-exit-and-portability-plan — 3. Portability by design — relevance 0.59

3. Portability by design

The architecture is deliberately biased toward portable components, and the exceptions are listed rather than glossed over:

Layer	Technology	Portability
Compute	Kubernetes (EKS)	High — standard manifests, no EKS-specific APIs in workloads
Container images	OCI in ECR	High — registry is a copy operation
Data warehouse	Snowflake	Hi

gs://attestor-505506-corpus/engineering/cloud-exit-and-portability-plan.txt

[7] secrets-management-standard — Secrets Management Standard — relevance 0.59

Secrets Management Standard

Document ID: KD-ENG-006 · **Version:** 2.1 · **Owner:** Dana Whitfield, VP Engineering
Approved: 22 January 2026 · **Maps to:** SOC 2 CC6.1 · ISO 27001:2022 A.8.24

gs://attestor-505506-corpus/engineering/secrets-management-standard.txt

[8] infrastructure-architecture-overview — 4. Data layer — relevance 0.59

4. Data layer

Store	Technology	Purpose
Primary OLTP	Amazon RDS PostgreSQL 16, Multi-AZ	Application state
Analytics	Snowflake	Customer analytics workloads
Object storage	Amazon S3	Uploads, exports, backups
Cache	Amazon ElastiCache (Redis 7)	Session and query cache
Search	OpenSearch 2.13	In-product search

gs://attestor-505506-corpus/engineering/infrastructure-architecture-overview.txt

[9] secrets-management-standard — 4. Runtime access — relevance 0.58

4. Runtime access

Workloads obtain secrets at runtime through the AWS Secrets Manager CSI driver, mounted as in-memory `tmpfs` volumes. Secrets are never written to disk, never baked into container images, and never passed as environment variables where they could leak into a crash dump or a process listing.

gs://attestor-505506-corpus/engineering/secrets-management-standard.txt

122. Do you encrypt data in transit, and which TLS versions do you support?

security · Q122 · Vendor Security Review row 123

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

123. Which MFA factors are permitted? Are SMS or TOTP still accepted?

security · Q123 · Vendor Security Review row 124

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

124. Please confirm: In which cloud regions is the production platform hosted?

engineering · Q124 · Vendor Security Review row 125

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

125. Which transfer mechanism do you rely on for transfers out of the EEA?

legal · Q125 · Vendor Security Review row 126

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

126. How frequently are Tier 1 vendors reassessed?

security · Q126 · Vendor Security Review row 127

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

127. Do you maintain a formal risk register? How frequently is it reviewed?

security · Q127 · Vendor Security Review row 128

Yes, Kestrel Data maintains a formal risk register, which is hosted in Vanta with a mirrored export in the `SEC-GOV` repository to preserve version history (Risk Management and Security Governance, Section 4: "The risk register"). The risk register is reviewed monthly by the Security Steering Group and is formally re-scored on a quarterly basis. Each entry includes a unique identifier, description, named individual owner, inherent score, applied controls, residual score, treatment decision (accept, mitigate, transfer, avoid), and review date, evaluated using a 5×5 likelihood-by-impact matrix. Additionally, Kestrel performs a full risk assessment annually, with interim assessments triggered by events such as material architectural changes, new subprocessors, or high-severity findings (Risk Management and Security Governance, Section 6: "Risk assessment cadence").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] risk-management-and-governance — 5. Worked examples from the register — relevance 0.64

5. Worked examples from the register

| Risk | Description | Treatment | Residual |

|---|---|---|---|

| RISK-2025-0031 | SMS and TOTP factors phishable | Mitigate — hardware factors mandated 30 June 2025 | Low |

| RISK-2024-0017 | No file-scanning anti-malware on container hosts | Accept — immutable hosts, signed images, runtime detection | Low |

|

| RISK-2025-0044 | Single-cloud concentration on AWS

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[2] risk-management-and-governance — 4. The risk register — relevance 0.64

4. The risk register

****Kestrel maintains a formal risk register, reviewed monthly by the Security Steering Group and formally re-scored quarterly.**** It is held in Vanta with a mirrored export in the `SEC-GOV` repository so that history is preserved even if the tooling changes.

Each risk carries an identifier (`RISK-YYYY-NNNN`), a description, an owner who is a named individual rather than a team,

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[3] risk-management-and-governance — 6. Risk assessment cadence — relevance 0.64

6. Risk assessment cadence

A full risk assessment is performed annually, most recently completed on 20 January 2026. Additional assessments are triggered by: a new subprocessor handling customer data, a material architecture change, a Sev-1 incident, entry into a new regulated market, and any finding rated High or above from an external test.

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[4] risk-management-and-governance — Risk Management and Security Governance — relevance 0.62

Risk Management and Security Governance

****Document ID:**** KD-SEC-018 · ****Version:**** 3.0 · ****Owner:**** Marcus Oyelaran, CISO

****Approved:**** 26 January 2026 · ****Next review:**** 26 January 2027

****Maps to:**** SOC 2 CC1.1, CC1.2, CC1.3, CC3.1, CC3.2, CC3.4 · ISO 27001:2022 A.5.1–A.5.4, Clauses 5–6, 9

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[5] information-security-policy — 4. Risk management — relevance 0.61

4. Risk management

Kestrel maintains a risk register in Vanta, reviewed monthly by the Security Council. Risks are scored on a 5×5 likelihood/impact matrix. Any risk scoring 15 or above requires a documented treatment plan with a named owner and a due date, and is reported to the Board Audit & Risk Committee at the next quarterly meeting.

As of the February 2026 review the register holds 34 open

gs://attestor-505506-corporus/security/information-security-policy.txt

128. Can a single customer be restored without affecting other tenants?

engineering · Q128 · Vendor Security Review row 129

Yes, a single customer can be restored without affecting other tenants. Under our tenant-scoped restore procedure, data is first restored into an isolated account, after which only that specific tenant's rows are exported back into production (backup-restore-procedure, Section 5. Tenant-scoped restore and Section 3. Restore procedure). Restoring directly over production is strictly prohibited; all restores are staged in an isolated account where an integrity verification suite is run before any data is exported or cut over (backup-restore-procedure, Section 3. Restore procedure).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] backup-restore-procedure — 5. Tenant-scoped restore — relevance 0.70

5. Tenant-scoped restore

A single customer can be restored without affecting others, by restoring to an isolated account and exporting that tenant rows back. This was exercised once in production, on 22 September 2025, at a customer request following an erroneous bulk delete on their side. Time to complete was 5 hours 10 minutes.

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[2] backup-restore-procedure — 3. Restore procedure — relevance 0.65

3. Restore procedure

1. Declare the restore scope: point in time, and whether tenant-scoped or full.

2. Provision an isolated restore account from the Terraform module `restore-target`.
3. Restore the RDS snapshot or PITR target into the isolated account.
4. Run the integrity suite: 1,240 assertions covering row counts, referential integrity, tenant isolation invariants, and known-value spo

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[3] api-and-integration-standard — 2. Customer control of API credentials — relevance 0.59

2. Customer control of API credentials

****Customers create, scope, rotate, and revoke their own API credentials**** from the tenant administrator console, without involving Kestrel support. A credential can be limited to read-only, to specific datasets, and to a source IP allowlist. Revocation takes effect within 30 seconds across all regions.

****Kestrel support cannot recover a customer API key.**** K

gs://attestor-505506-corporus/engineering/api-and-integration-standard.txt

[4] backup-restore-procedure — 6. Backup deletion — relevance 0.59

6. Backup deletion

Backups expire automatically. When a customer terminates and the tenant purge runs, backups containing that data expire on the normal cycle, a maximum of ****35 days**** later. Kestrel does not selectively surgically remove a tenant from historical backup images, and says so rather than implying otherwise.

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[5] backup-restore-procedure — 4. Test results — relevance 0.57

4. Test results

Restore is tested ****quarterly****, and the test is a real restore, not a backup-listing check.

Quarter	Date	Duration	Assertions	Outcome
---------	------	----------	------------	---------

---	---	---	---	---
-----	-----	-----	-----	-----

Q1 2026	17 Jan 2026	2h 41m	1,240 / 1,240	Pass
---------	-------------	--------	---------------	------

Q4 2025	11 Oct 2025	3h 02m	1,238 / 1,240	Pass, 2 known-stale fixtures corrected
---------	-------------	--------	---------------	--

Q3 2025	19 Jul 2025	3h 20m	1,240 / 1,240	Pass
---------	-------------	--------	---------------	------

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

129. Do you process special category personal data?

legal · Q129 · Vendor Security Review row 130

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

130. Will you notify customers of a government request for their data?

legal · Q130 · Vendor Security Review row 131

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

131. What is the export window available after termination?

legal · Q131 · Vendor Security Review row 132

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

132. Do you subscribe to threat intelligence feeds?

security · Q132 · Vendor Security Review row 133

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

133. Describe your privileged access management approach for production systems.

security · Q133 · Vendor Security Review row 134

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

134. Do you support SAML or OIDC single sign-on?

security · Q134 · Vendor Security Review row 135

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] access-control-standard — 1. Identity provider — relevance 0.60

1. Identity provider

All Kestrel Data systems authenticate through Okta (tenant `kestreldata.okta.com`). Local accounts on production systems are prohibited except for two documented break-glass accounts held in a sealed 1Password vault, whose use triggers a PagerDuty alert to the CISO. Both break-glass credentials were last rotated on 3 January 2026 and last used on 14 August 2025 during the

gs://attestor-505506-corpus/security/access-control-standard.txt

[2] access-control-standard — 3. Role-based access — relevance 0.59

3. Role-based access

Access is granted to Okta groups, never to individuals. There are 41 defined roles, each mapping to a documented entitlement set in the Access Matrix (`SEC-GOV/access-matrix`), which is the authoritative record reviewed during audit. Standing production access is limited to 11 named Site Reliability Engineers. All other production access is just-in-time.

gs://attestor-505506-corpus/security/access-control-standard.txt

[3] access-control-standard — 2. Multi-factor authentication — relevance 0.57

2. Multi-factor authentication

Hardware-backed MFA (WebAuthn / FIDO2, YubiKey 5 series) is mandatory for every human account. SMS and TOTP were removed as acceptable factors on 30 June 2025 following the RISK-2025-0031 treatment plan. Coverage is 100% of the 187 active employee accounts and 100% of the 24 active contractor accounts, verified continuously by Vanta control AC-07.

gs://attestor-505506-corpus/security/access-control-standard.txt

[4] access-control-standard — 9. Password requirements — relevance 0.57

9. Password requirements

Where a password is used, minimum length is 14 characters, checked against the Have I Been Pwned breached-password corpus at set time. Rotation is not forced on a schedule, in line with NIST SP 800-63B guidance; rotation is forced on evidence of compromise.

gs://attestor-505506-corpus/security/access-control-standard.txt

[5] access-control-standard — 8. Service accounts and machine identity — relevance 0.56

8. Service accounts and machine identity

Workloads authenticate using short-lived credentials: AWS IAM Roles for Service Accounts (IRSA) in EKS, and Workload Identity Federation for GCP components. Long-lived static access keys are prohibited; the last was decommissioned on 17 November 2024. Automated detection for newly created static keys runs hourly and pages the on-call SRE.

gs://attestor-505506-corporus/security/access-control-standard.txt

135. For each applicable system: Is your organisation subject to any pending litigation relating to data protection?

legal · Q135 · Vendor Security Review row 136

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

136. Provide your security awareness training completion rate.

security · Q136 · Vendor Security Review row 137

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

137. For each applicable system: Is restore tested by performing an actual restore, or by verifying backup existence?

engineering · Q137 · Vendor Security Review row 138

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

138. Is production data ever copied to non-production environments?

engineering · Q138 · Vendor Security Review row 139

No, production data is never copied to non-production or lower environments. Under our SDLC policy, non-production environments are restricted to synthetic and anonymised data: - `local` (developer machines) and `ci` (automated testing) environments use synthetic fixtures only. - `staging` (pre-production verification) utilizes synthetic fixtures generated by automated tooling (`tools/gen\_fixtures.py`) and anonymised data. We do not maintain or allow any "sanitised production dump" processes, as sanitisation is unreliable and poses security risks (SDLC Policy, Section 2: Environments).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] sdlc-policy — 2. Environments — relevance 0.72

2. Environments

| Environment | Purpose | Data |

|---|---|---|

| `local` | Developer machines | Synthetic fixtures only |

| `ci` | Automated testing | Synthetic fixtures only |

| `staging` | Pre-production verification | Synthetic and anonymised data |

| `production` | Live service | Customer data |

****Production data is never copied to a lower environment.**** Staging fixtures are generated

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[2] backup-restore-procedure — 5. Tenant-scoped restore — relevance 0.63

5. Tenant-scoped restore

A single customer can be restored without affecting others, by restoring to an isolated account and exporting that tenant rows back. This was exercised once in production, on 22 September 2025, at a customer request following an erroneous bulk delete on their side. Time to complete was 5 hours 10 minutes.

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[3] sdlc-policy — 3. Testing requirements — relevance 0.61

3. Testing requirements

- Unit test coverage gate at ****80%**** on changed lines, enforced in CI.
- Integration tests run against ephemeral infrastructure provisioned per pull request.
- Tenant isolation tests run on every build: a suite of 84 assertions attempting cross-tenant reads through every public API surface.
- Load tests before any release expected to change the performance profile.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[4] backup-restore-procedure — 4. Test results — relevance 0.61

4. Test results

Restore is tested ****quarterly****, and the test is a real restore, not a backup-listing check.

Quarter	Date	Duration	Assertions	Outcome
Q1 2026	17 Jan 2026	2h 41m	1,240 / 1,240	Pass
Q4 2025	11 Oct 2025	3h 02m	1,238 / 1,240	Pass, 2 known-stale fixtures corrected
Q3 2025	19 Jul 2025	3h 20m	1,240 / 1,240	Pass

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[5] backup-restore-procedure — 3. Restore procedure — relevance 0.60

3. Restore procedure

1. Declare the restore scope: point in time, and whether tenant-scoped or full.
2. Provision an isolated restore account from the Terraform module ``restore-target``.
3. Restore the RDS snapshot or PITR target into the isolated account.
4. Run the integrity suite: 1,240 assertions covering row counts, referential integrity, tenant isolation invariants, and known-value spo

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

139. Do you accept SOC 2 and ISO 27001 reports in place of a customer audit?

legal · Q139 · Vendor Security Review row 140

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

140. Do you monitor for anomalous data export volumes?

security · Q140 · Vendor Security Review row 141

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

141. Are backups encrypted, and with which keys?

engineering · Q141 · Vendor Security Review row 142

All backups are encrypted using AES-256 via AWS KMS. To ensure isolation and prevent cascading risk, daily logical database dumps use a dedicated, separate Customer Master Key (CMK) distinct from the primary database key, ensuring that a compromise of the primary key does not compromise backups (``backup-restore-procedure``, §2. Encryption and location).

Evidence (5)

[1] backup-restore-procedure — 2. Encryption and location — relevance 0.71

2. Encryption and location

All backups are encrypted with AES-256 using AWS KMS. The daily logical dump uses a **separate CMK** from the primary database, so that compromise of the primary key does not compromise the backups.

Cross-region replication stays inside the residency boundary: `us-east-1` replicates to `us-west-2`, `eu-west-1` replicates to `eu-central-1`. EU customer data never le

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[2] backup-restore-procedure — 1. What is backed up — relevance 0.66

1. What is backed up

Asset	Method	Frequency	Retention
-------	--------	-----------	-----------

---	---	---	---
-----	-----	-----	-----

RDS PostgreSQL	Automated snapshots + WAL archiving (PITR)	Continuous	35 days
----------------	--	------------	----------------

RDS logical dump	`pg_dump` to S3, encrypted with a separate CMK	Daily 03:00 UTC	90 days
------------------	--	-----------------	---------

S3 objects	Versioning + cross-region replication	Continuous	90 days for non-current versions
------------	---------------------------------------	------------	----------------------------------

Snowflake	Time Tr		
-----------	---------	--	--

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[3] backup-restore-procedure — Backup and Restore Procedure — relevance 0.62

Backup and Restore Procedure

Document ID: KD-ENG-004 · **Version:** 2.5 · **Owner:** Sofia Brenner, Head of IT

Approved: 29 January 2026 · **Maps to:** SOC 2 A1.2 · ISO 27001:2022 A.8.13

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[4] backup-restore-procedure — 4. Test results — relevance 0.61

4. Test results

Restore is tested **quarterly**, and the test is a real restore, not a backup-listing check.

Quarter	Date	Duration	Assertions	Outcome
---------	------	----------	------------	---------

---	---	---	---	---
-----	-----	-----	-----	-----

Q1 2026	17 Jan 2026	2h 41m	1,240 / 1,240	Pass
---------	-------------	--------	---------------	------

Q4 2025	11 Oct 2025	3h 02m	1,238 / 1,240	Pass, 2 known-stale fixtures corrected
---------	-------------	--------	---------------	--

Q3 2025	19 Jul 2025	3h 20m	1,240 / 1,240	Pass
---------	-------------	--------	---------------	------

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[5] data-flow-and-shared-responsibility — 1. Data flow, end to end — relevance 0.59

1. Data flow, end to end

1. **Ingress.** A customer's browser or API client resolves `app.kestreldata.com` or `api.kestreldata.com` to Cloudflare, which terminates TLS 1.3 (1.2 minimum) and applies WAF and rate limiting.

2. **Instance selection.** DNS and tenant routing send the request to the instance chosen at contract signature: `us-east-1` or `eu-west-1`. **A tenant's requests never c**

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

142. Who is accountable for information security at executive level?

security · Q142 · Vendor Security Review row 143

Marcus Oyelaran, Chief Information Security Officer (CISO), is accountable for information security at Kestrel Data. The CISO reports directly to the Chief Executive Officer rather than engineering or technology leadership, ensuring independent oversight, and maintains a standing right of direct access to the board of directors (citing **risk-management-and-governance**, Section 1: "Executive accountability").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] risk-management-and-governance — 1. Executive accountability — relevance 0.72

1. Executive accountability

****Marcus Oyelaran**, Chief Information Security Officer, is accountable for information security at Kestrel Data. ****The CISO reports to the Chief Executive Officer, not to the VP Engineering or the CTO, so that a security objection cannot be resolved by the person whose delivery schedule it obstructs. The CISO has a standing right of direct access to the board and exercises**

gs://attestor-505506-corporate/security/risk-management-and-governance.txt

[2] information-security-policy — 2. Governance — relevance 0.66

2. Governance

Security governance sits with the Security Council, chaired by the CISO and meeting monthly. Standing members are the CISO, VP Engineering (Dana Whitfield), General Counsel (Aaron Feldstein), Head of IT (Sofia Brenner), and the Data Protection Officer (Priya Raghunathan). Minutes are retained for seven years in Confluence space `SEC-GOV`.

The Board Audit & Risk Committee receives a

gs://attestor-505506-corporate/security/information-security-policy.txt

[3] risk-management-and-governance — 2. Board oversight — relevance 0.66

2. Board oversight

The board receives a formal information security report at each quarterly meeting, presented by the CISO. The standing agenda covers: the risk register movement since the last meeting, incidents and their classification, certification and audit status, the results of penetration testing, and any exception granted above the CISO's own approval threshold. Board meetings covering s

gs://attestor-505506-corporate/security/risk-management-and-governance.txt

[4] company-and-security-programme-overview — 4. Governance — relevance 0.65

4. Governance

The CISO reports to the CEO and to the board quarterly. A Security Steering Group meets monthly. The risk register holds 41 open risks and is reviewed monthly and re-scored quarterly. Full detail is in KD-SEC-018.

gs://attestor-505506-corporate/security/company-and-security-programme-overview.txt

[5] risk-management-and-governance — 3. Security Steering Group — relevance 0.65

3. Security Steering Group

A Security Steering Group meets ****monthly**** and comprises the CISO (chair), VP Engineering, Head of IT, General Counsel, and DPO. It approves policy changes, reviews the risk register, and decides on exceptions. Minutes are retained for seven years and are made available to auditors; they are not shared with customers, but the decisions they record are reflected in the S

gs://attestor-505506-corporate/security/risk-management-and-governance.txt

143. Have you appointed a Data Protection Officer? Provide contact details.

legal · Q143 · Vendor Security Review row 144

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

144. How long is customer data retained after contract termination?

legal · Q144 · Vendor Security Review row 145

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

145. Which cloud service providers do you use?

engineering · Q145 · Vendor Security Review row 146

Kestrel runs its production environments on Amazon Web Services (AWS) across two independent instances: a US instance in `us-east-1` (with backup replication in `us-west-2`) and an EU instance in `eu-west-1` (with backup replication in `eu-central-1`) (`infrastructure-architecture-overview`, "1. Cloud footprint"). In addition, Cloudflare is used for edge ingress (`infrastructure-architecture-overview`, "6. Network"; `cloud-exit-and-portability-plan`, "3. Portability by design"). A small number of internal, non-customer-facing workloads run on Google Cloud (BigQuery for internal finance reporting), but no customer data is processed there (`infrastructure-architecture-overview`, "1. Cloud footprint").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (5)

[1] infrastructure-architecture-overview — 1. Cloud footprint — relevance 0.66

1. Cloud footprint

Kestrel runs on **Amazon Web Services**. There are two independent production instances:

| Instance | Region | Serves |

|---|---|---|

| US | `us-east-1` (3 AZs) | North America, and customers with no residency requirement |

| EU | `eu-west-1` (3 AZs) | EEA, UK, and Swiss customers electing EU residency |

Backup replication targets `us-west-2` and `eu-central-1` respecti

gs://attestor-505506-corpus/engineering/infrastructure-architecture-overview.txt

[2] infrastructure-architecture-overview — 4. Data layer — relevance 0.58

4. Data layer

| Store | Technology | Purpose |

|---|---|---|

| Primary OLTP | Amazon RDS PostgreSQL 16, Multi-AZ | Application state |

| Analytics | Snowflake | Customer analytics workloads |

| Object storage | Amazon S3 | Uploads, exports, backups |

| Cache | Amazon ElastiCache (Redis 7) | Session and query cache |

| Search | OpenSearch 2.13 | In-product search |

gs://attestor-505506-corpus/engineering/infrastructure-architecture-overview.txt

[3] infrastructure-architecture-overview — 6. Network — relevance 0.57

6. Network

Private subnets for all compute and data. No public IP addresses on workload instances.

Ingress is exclusively through Cloudflare, then an AWS Application Load Balancer, then the Istio ingress gateway. Egress is through NAT gateways with an allowlist for known destinations.

Security groups are managed in Terraform and default-deny. There are no `0.0.0.0/0` ingress rules in produc

gs://attestor-505506-corpus/engineering/infrastructure-architecture-overview.txt

[4] cloud-exit-and-portability-plan — 1. Why this exists — relevance 0.56

1. Why this exists

Kestrel runs entirely on AWS. That is a concentration risk, recorded as `RISK-2025-0044` and **accepted** rather than mitigated by multi-cloud, on the reasoning that operating two clouds badly is worse than operating one well at this size. Accepting a risk obliges you to know what you would do if it materialised, which is what this document is. It is reviewed annually and was la

gs://attestor-505506-corpus/engineering/cloud-exit-and-portability-plan.txt

[5] cloud-exit-and-portability-plan — 3. Portability by design — relevance 0.56

3. Portability by design

The architecture is deliberately biased toward portable components, and the exceptions are listed rather than glossed over:

Layer	Technology	Portability
Compute	Kubernetes (EKS)	High — standard manifests, no EKS-specific APIs in workloads
Container images	OCI in ECR	High — registry is a copy operation
Data warehouse	Snowflake	Hi

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

146. What is your personal data breach notification commitment to customers?

legal · Q146 · Vendor Security Review row 147

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

147. Do you use a VPN for internal application access, or a zero-trust approach?

security · Q147 · Vendor Security Review row 148

We do not use a traditional VPN. Instead, we employ a zero-trust architecture where internal applications are published through Cloudflare Access, requiring Okta identity authentication and device posture verification on every request (`network-security-standard`, Section 6: "Internal application access"). Under this model, network position confers no implicit trust or access. Device posture checks enforce requirements including full-disk encryption, an up-to-date operating system, and an enrolled MDM profile via Kandji (`access-control-standard`, Section 10: "Remote access").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] network-security-standard — 6. Internal application access — relevance 0.73

6. Internal application access

There is no traditional VPN. Internal applications are published through Cloudflare Access with device posture and Okta identity required on every request. This is a zero-trust model in the practical sense: there is no network position that grants access, and being "inside" confers nothing.

gs://attestor-505506-corporus/security/network-security-standard.txt

[2] access-control-standard — 10. Remote access — relevance 0.57

10. Remote access

There is no traditional VPN. Access to internal applications is mediated by Cloudflare Access with device posture checks requiring disk encryption, a current OS, and an enrolled MDM profile (Kandji for macOS, 163 devices as of 1 February 2026).

gs://attestor-505506-corporus/security/access-control-standard.txt

[3] access-control-standard — 3. Role-based access — relevance 0.54

3. Role-based access

Access is granted to Okta groups, never to individuals. There are 41 defined roles, each mapping to a documented entitlement set in the Access Matrix (`SEC-GOV/access-matrix`), which is the authoritative record reviewed during audit. Standing production access is limited to 11 named Site Reliability Engineers. All other production access is just-in-time.

gs://attestor-505506-corporus/security/access-control-standard.txt

[4] network-security-standard — 10. Testing — relevance 0.54

10. Testing

Network controls are exercised annually by the external penetration test. The February 2026 test (Include Security, INSEC-2026-0219) attempted lateral movement from a compromised application container and did not achieve it; the finding raised was the rate limiting gap on the password reset endpoint, remediated on 27 February 2026.

gs://attestor-505506-corporus/security/network-security-standard.txt

[5] network-security-standard — 8. Wireless — relevance 0.54

8. Wireless

The Austin office wireless network is WPA3-Enterprise with certificate-based authentication for the corporate SSID and a fully segregated guest SSID that routes straight to the internet. Neither network grants any access to production; production is reached the same way from the office as from a coffee shop, which is deliberate.

gs://attestor-505506-corporus/security/network-security-standard.txt

148. Have you completed a Transfer Impact Assessment?

legal · Q148 · Vendor Security Review row 149

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

149. Will you certify deletion of customer data on request? Provide supporting evidence.

legal · Q149 · Vendor Security Review row 150

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

150. Describe your secure development lifecycle.

engineering · Q150 · Vendor Security Review row 151

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

151. May a customer object to a new subprocessor? What is the remedy?

legal · Q151 · Vendor Security Review row 152

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

152. What audit rights do you grant customers?

legal · Q152 · Vendor Security Review row 153

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

153. How do you support California consumer rights requests?

legal · Q153 · Vendor Security Review row 154

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (7)

[1] data-subject-rights-procedure — Data Subject Rights Procedure — relevance 0.71

Data Subject Rights Procedure

****Document ID:**** KD-LEG-007 · ****Version:**** 2.3 · ****Owner:**** Priya Raghunathan, DPO

****Approved:**** 20 January 2026 · ****Next review:**** 20 January 2027

****Maps to:**** GDPR Articles 12, 15–22, 28(3)(e) · CCPA/CPRA §1798.100–130

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[2] data-subject-rights-procedure — 8. California and other US state rights — relevance 0.68

8. California and other US state rights

Kestrel acts as a ****service provider**** under the CCPA/CPRA in respect of customer content, and the DPA contains the required service provider terms: no sale, no sharing for cross-context behavioural advertising, no retention or use outside the business purpose, and no combining with data from other sources. The same terms are applied for the Virginia, Colora

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[3] data-processing-agreement — 6. Data subject rights — relevance 0.66

6. Data subject rights

Kestrel provides self-service functionality allowing Customer to access, correct, export, and delete Personal Data within the Service. Where a data subject contacts Kestrel directly, Kestrel refers them to Customer and does not respond substantively, unless legally obliged to do so.

Where the Service functionality is insufficient, Kestrel assists Customer within ****10**

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[4] data-subject-rights-procedure — 9. Records — relevance 0.65

9. Records

Every request, its route, and its resolution date are recorded in the DSR register held by the DPO and retained for three years. The register is available to auditors and, in redacted form, to customers exercising their audit rights under the DPA.

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[5] privacy-policy — 5. Your rights — relevance 0.65

5. Your rights

Data subjects in the EEA, UK, and Switzerland have rights of access, rectification, erasure, restriction, portability, and objection, and the right to withdraw consent. California residents have rights under the CCPA as amended by the CPRA, including the right to know, delete, correct, and opt out of sharing.

Requests to ``privacy@kestreldata.com`` are acknowledged within 5 busi

gs://attestor-505506-corporus/legal/privacy-policy.txt

[6] data-subject-rights-procedure — 1. Which rights, and against whom — relevance 0.64

1. Which rights, and against whom

For customer content, Kestrel is the ****processor**** and the customer is the controller. A data subject who approaches Kestrel directly about customer content is redirected to the relevant customer without undue delay and, where Kestrel can identify the customer, within ****3 business days****. Kestrel does not respond substantively on the controller's behalf.

For data

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[7] privacy-policy — 3. What we do not do — relevance 0.57

3. What we do not do

- We do not sell personal data, and have never done so.
- We do not share personal data with advertising networks.
- We do not use customer content to train machine learning models, our own or anyone else. This is stated contractually in the MSA and is not merely a policy statement.
- We do not engage in automated decision-making producing legal or similarly significant

gs://attestor-505506-corporus/legal/privacy-policy.txt

154. Describe your security incident classification scheme.

security · Q154 · Vendor Security Review row 155

Kestrel Data classifies security incidents into four severity levels according to impact and urgency: * **SEV1**: Confirmed unauthorised access to customer production data or a full platform outage. This triggers immediate 24/7 paging and notification of both the CEO and CISO within 30 minutes. * **SEV2**: A suspected compromise, a partial outage affecting more than 10% of tenants, or a confirmed data integrity fault. This triggers immediate 24/7 paging and notification of the CISO within 1 hour. * **SEV3**: A security-relevant defect with no evidence of exploitation. Escalation occurs during business hours and is included in weekly executive reporting. * **SEV4**: Informational or hygiene findings. These require no active paging and are tracked via monthly reporting. *(Source: `incident-response-runbook`, Section 1. "Severity definitions")*

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] incident-response-runbook — 1. Severity definitions — relevance 0.65

1. Severity definitions

| Sev | Definition | Page | Exec notify |

|---|---|---|---|

| **SEV1** | Confirmed unauthorised access to customer production data, or full platform outage | Immediate, 24/7 | CEO + CISO within 30 min |

| **SEV2** | Suspected compromise, partial outage affecting more than 10% of tenants, or confirmed data integrity fault | Immediate, 24/7 | CISO within 1 hour |

| **SEV3**

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[2] incident-response-runbook — 3. Lifecycle — relevance 0.65

3. Lifecycle

Detect, triage, contain, eradicate, recover, learn.

Detection sources are Datadog Security Monitoring, AWS GuardDuty, AWS Security Hub, Okta ThreatInsight, Snyk, customer reports to `security@kestreldata.com`, and the disclosure address published at `kestreldata.com/.well-known/security.txt`.

Triage target is 15 minutes from alert to severity assignment for SEV1 and SEV2, meas

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[3] incident-response-runbook — 8. Post-incident review — relevance 0.64

8. Post-incident review

Every SEV1 and SEV2 requires a blameless post-incident review within 5 business days, published internally, with action items tracked to closure in Jira. Reviews are shared with affected customers on request.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[4] incident-response-runbook — 2. Roles — relevance 0.63

2. Roles

The Incident Commander owns the response and is deliberately not the person fixing the problem; ICs are drawn from a rota of 6 trained staff. The Communications Lead owns customer, internal, and regulator messaging. A Scribe maintains the timeline for every SEV1 and SEV2. Subject matter experts are pulled in as needed.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[5] incident-response-runbook — 6. Evidence handling — relevance 0.62

6. Evidence handling

The IC directs preservation before remediation wherever containment allows. EBS snapshots, memory captures where feasible, and relevant log ranges are exported to a dedicated forensics S3 bucket with Object Lock in compliance mode, retention 1 year. Chain of custody is recorded in the incident ticket.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

155. Will you certify deletion of customer data on request?

legal · Q155 · Vendor Security Review row 156

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

156. How are security responsibilities communicated to personnel?

security · Q156 · Vendor Security Review row 157

Security responsibilities are communicated to personnel through four deliberately overlapping channels: 1. **Offer Pack and Onboarding Session:** Initial responsibilities and expectations are established during the onboarding process. 2. **Annual Policy Acknowledgement:** Personnel must complete an annual review and formal acknowledgement of security policies. 3. **Monthly All-Hands Updates:** A standing security update is delivered directly by the CISO during the monthly company-wide all-hands meeting. 4. **Dedicated Slack Channel (#security):** The #security channel serves as the documented communication route for reporting suspicious activity and asking security-related questions, monitored during business hours and supported by PagerDuty escalation outside of them. *(Citations: KD-SEC-013 Personnel Security and Security Training Programme, Section 7: "How security responsibilities are communicated")*

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] personnel-security-and-training — 7. How security responsibilities are communicated — relevance 0.71

7. How security responsibilities are communicated
Responsibilities are communicated four ways, deliberately overlapping: the offer pack and onboarding session; the annual policy acknowledgement; a standing item in the monthly all-hands delivered by the CISO; and the #security Slack channel, which is the documented route for reporting anything suspicious and is monitored during business hours with

gs://attestor-505506-corpus/security/personnel-security-and-training.txt

[2] personnel-security-and-training — 4. Security awareness training — relevance 0.64

4. Security awareness training
Security awareness training is **mandatory** for all personnel, annually, plus at onboarding within the first 14 days. Training is delivered through Curricula and runs approximately 45 minutes, covering phishing, credential handling, data classification, secure remote working, and incident reporting.

Measured completion for the 2025 cycle was **99.5%** (210 of 211 i

gs://attestor-505506-corpus/security/personnel-security-and-training.txt

[3] risk-management-and-governance — 8. Policy management — relevance 0.64

8. Policy management
All security policies carry a document ID, a version, a named owner, an approval date, and a review date. Policies are reviewed at least annually and on material change. The 2026 review cycle covered 14 policies between 8 January and 12 February 2026; three were revised, and the changes were communicated at the February all-hands and through the annual acknowledgement cycle.

gs://attestor-505506-corpus/security/risk-management-and-governance.txt

[4] personnel-security-and-training — Personnel Security and Security Training Programme — relevance 0.63

Personnel Security and Security Training Programme
Document ID: KD-SEC-013 · **Version:** 2.1 · **Owner:** Sofia Brenner, Head of IT
Approved: 22 January 2026 · **Next review:** 22 January 2027
Maps to: SOC 2 CC1.1, CC1.4, CC2.1, CC6.2 · ISO 27001:2022 A.6.1, A.6.2, A.6.3, A.6.6

gs://attestor-505506-corpus/security/personnel-security-and-training.txt

[5] incident-response-runbook — 2. Roles — relevance 0.61

2. Roles

The Incident Commander owns the response and is deliberately not the person fixing the problem; ICs are drawn from a rota of 6 trained staff. The Communications Lead owns customer, internal, and regulator messaging. A Scribe maintains the timeline for every SEV1 and SEV2. Subject matter experts are pulled in as needed.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

157. Who holds the encryption keys for customer data?

engineering · Q157 · Vendor Security Review row 158

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (9)

[1] data-flow-and-shared-responsibility — 1. Data flow, end to end — relevance 0.68

1. Data flow, end to end

1. **Ingress.** A customer's browser or API client resolves `app.kestreldata.com` or `api.kestreldata.com` to Cloudflare, which terminates TLS 1.3 (1.2 minimum) and applies WAF and rate limiting.
2. **Instance selection.** DNS and tenant routing send the request to the instance chosen at contract signature: `us-east-1` or `eu-west-1`. **A tenant's requests never c**

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[2] secrets-management-standard — 6. Customer-issued API credentials — relevance 0.67

6. Customer-issued API credentials

API keys issued to customers are stored as Argon2id hashes; Kestrel cannot recover the plaintext of a customer API key and will not do so on request. Keys are displayed once at creation. Customers can create, scope, and revoke keys through the console, and each key carries a last-used timestamp so stale keys are visible.

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

[3] backup-restore-procedure — 2. Encryption and location — relevance 0.67

2. Encryption and location

All backups are encrypted with AES-256 using AWS KMS. The daily logical dump uses a **separate CMK** from the primary database, so that compromise of the primary key does not compromise the backups.

Cross-region replication stays inside the residency boundary: `us-east-1` replicates to `us-west-2`, `eu-west-1` replicates to `eu-central-1`. EU customer data never le

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[4] data-flow-and-shared-responsibility — 3. The shared responsibility model — relevance 0.65

3. The shared responsibility model

Security of the platform is Kestrel's. Security of what the customer does with it is the customer's. The line is drawn here rather than left implicit, because an unstated boundary is where a breach lands on whoever is less able to argue.

Kestrel is responsible for:

* physical and environmental security of the infrastructure (through AWS), and the cloud co

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[5] data-flow-and-shared-responsibility — 6. Where processing occurs — relevance 0.64

6. Where processing occurs

Processing occurs in AWS `us-east-1` (US instance) and AWS `eu-west-1` (EU instance), by personnel located in the United States, the European Union, the United Kingdom, and Canada, under the access controls in KD-SEC-002. **No processing occurs outside the stated regions**, and no support is subcontracted to a third-party provider in another

jurisdiction.

gs://attestor-505506-corpus/engineering/data-flow-and-shared-responsibility.txt

[6] secrets-management-standard — Secrets Management Standard — relevance 0.58

Secrets Management Standard

Document ID: KD-ENG-006 · **Version:** 2.1 · **Owner:** Dana Whitfield, VP Engineering

Approved: 22 January 2026 · **Maps to:** SOC 2 CC6.1 · ISO 27001:2022 A.8.24

gs://attestor-505506-corpus/engineering/secrets-management-standard.txt

[7] secrets-management-standard — 1. Where secrets live — relevance 0.54

1. Where secrets live

| Secret class | Store | Rotation |

---|---|---

| Application secrets, API keys | AWS Secrets Manager | 90 days, automated |

| Database credentials | AWS Secrets Manager with RDS-managed rotation | 30 days, automated |

| Encryption keys | AWS KMS (key material never leaves KMS) | Annual, automated |

| TLS certificates | AWS Certificate Manager | Automatic before expiry

gs://attestor-505506-corpus/engineering/secrets-management-standard.txt

[8] secrets-management-standard — 4. Runtime access — relevance 0.54

4. Runtime access

Workloads obtain secrets at runtime through the AWS Secrets Manager CSI driver, mounted as in-memory `tmpfs` volumes. Secrets are never written to disk, never baked into container images, and never passed as environment variables where they could leak into a crash dump or a process listing.

gs://attestor-505506-corpus/engineering/secrets-management-standard.txt

[9] secrets-management-standard — 2. What is prohibited — relevance 0.51

2. What is prohibited

- Secrets in source code, including test fixtures, comments, and commit history.

- Secrets in environment files committed to a repository.

- Secrets in CI logs, container image layers, or Terraform state in plaintext.

- Long-lived static AWS access keys. The last was decommissioned 17 November 2024, and creation of a new one triggers an hourly detection that pages the o

gs://attestor-505506-corpus/engineering/secrets-management-standard.txt

158. Do you support SCIM user provisioning? Provide supporting evidence.

security · Q158 · Vendor Security Review row 159

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

159. Do you encrypt customer data at rest?

security · Q159 · Vendor Security Review row 160

Yes. All customer data at rest is encrypted using **AES-256-GCM**, and no customer data is stored unencrypted at any tier (*Encryption Standard*, Section 1: "Data at rest"; *Information Security Policy*, Section 8: "Cryptography"). Encryption is implemented across storage layers as follows (*Encryption Standard*, Section 1: "Data at rest"): - **Amazon RDS (PostgreSQL 16):** Storage-level encryption using per-environment AWS KMS Customer Managed Keys (CMKs). - **Amazon S3:** Server-side encryption (SSE-KMS) with per-bucket AWS KMS CMKs. - **Snowflake:** Native encryption with Tri-Secret Secure using customer-managed keys in AWS KMS. - **Amazon EBS:** Encrypted volumes enforced at the AWS Organization level using AWS KMS CMKs. - **Backups:** Encrypted using the same CMK class as the source. Additionally, application-level field encryption using AES-256-GCM is applied to authentication secrets, API tokens, and OAuth refresh tokens, with keys stored in AWS Secrets Manager and rotated every 90 days (*Encryption Standard*, Section 1: "Data at rest"). All customer-facing AWS KMS CMKs have automatic annual rotation enabled, access restricted to named service roles, and strict separation of duties between key

administrators and key users enforced via AWS Service Control Policies (*Encryption Standard*, Section 3: "Key management").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] encryption-standard — 1. Data at rest — relevance 0.73

1. Data at rest

All customer data at rest is encrypted using **AES-256-GCM**. No customer data is stored unencrypted at any tier.

| Store | Mechanism | Key custody |

|---|---|---|

| Amazon RDS (PostgreSQL 16) | Storage-level encryption | AWS KMS CMK, per-environment |

| Amazon S3 | SSE-KMS | AWS KMS CMK, per-bucket |

| Snowflake | Native encryption, Tri-Secret Secure | Customer-managed key

gs://attestor-505506-corpus/security/encryption-standard.txt

[2] encryption-standard — 3. Key management — relevance 0.65

3. Key management

Customer-facing encryption keys are AWS KMS Customer Managed Keys. Key policies restrict use to named service roles. Key administrators and key users are disjoint sets: no individual holds both roles, enforced by a Service Control Policy at the AWS Organization level.

Automatic annual rotation is enabled on all CMKs. Manual rotation is triggered on suspected compromise. Ke

gs://attestor-505506-corpus/security/encryption-standard.txt

[3] physical-and-environmental-security — 1. Production infrastructure — relevance 0.65

1. Production infrastructure

Kestrel Data operates **no owned or leased data centre**. All production infrastructure runs in AWS: `us-east-1` for the US instance and `eu-west-1` for the EU instance.

Physical and environmental controls for those facilities — perimeter security, biometric access, CCTV, fire suppression, power redundancy, environmental monitoring, and media destruction — are AWS's re

gs://attestor-505506-corpus/security/physical-and-environmental-security.txt

[4] information-security-policy — 8. Cryptography — relevance 0.64

8. Cryptography

Data at rest is encrypted with AES-256-GCM. Data in transit is protected with TLS 1.3; TLS 1.0 and 1.1 were disabled on 12 April 2024 and TLS 1.2 remains enabled only for a single legacy integration scheduled for removal in Q3 2026. Key management is described in the Encryption Standard (KD-SEC-003) and the Secrets Management Standard (KD-ENG-006).

gs://attestor-505506-corpus/security/information-security-policy.txt

[5] encryption-standard — Encryption Standard — relevance 0.62

Encryption Standard

Document ID: KD-SEC-003 · **Version:** 2.4 · **Owner:** Marcus Oyelaran, CISO

Approved: 8 January 2026 · **Next review:** 8 January 2027

Maps to: SOC 2 CC6.7 · ISO 27001:2022 A.8.24 · GDPR Art. 32(1)(a)

gs://attestor-505506-corpus/security/encryption-standard.txt

160. Do you offer EU data residency?

legal · Q160 · Vendor Security Review row 161

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

161. For each applicable system: How much notice is given before scheduled maintenance?

engineering · Q161 · Vendor Security Review row 162

For scheduled maintenance across Kestrel Data systems, notice periods are structured as follows: *

****Customer-Affecting Scheduled Maintenance:**** Customers receive at least ****7 days' notice**** for any scheduled maintenance expected to be customer-affecting or cause degraded service (*Service Operations, Maintenance and Support (KD-ENG-009)*, Section 2; *Change Management Procedure (KD-ENG-002)*, Section 6). Standard maintenance windows occur on Sundays between 06:00 and 10:00 UTC, though standard deployments are rolling and zero-downtime (*Service Operations, Maintenance and Support*, Section 2). * ****Maintenance Requiring Customer Action:**** If a scheduled maintenance change requires action on the customer's part, at least ****30 days' notice**** is provided (*Service Operations, Maintenance and Support*, Section 2). * ****Breaking API Changes:**** Breaking API changes follow a deprecation policy requiring a minimum of ****12 months' notice****, with the deprecated version remaining operational throughout (*Change Management Procedure*, Section 6). * ****Emergency Maintenance:**** For urgent security fixes that cannot wait, maintenance may be performed under the emergency change path with shorter notice, with customer notifications dispatched as soon as the change is scheduled (*Service Operations, Maintenance and Support*, Section 2). All scheduled maintenance notices are communicated via direct email to tenant administrators and published on the status page at `status.kestreldata.com` (*Service Operations, Maintenance and Support*, Sections 1 and 2).

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (7)

[1] service-operations-and-support — 2. Scheduled maintenance — relevance 0.70

2. Scheduled maintenance

The standard maintenance window is ****Sundays 06:00–10:00 UTC****. Most changes do not use it: deployments are rolling and zero-downtime, and 2025 saw 1,412 production deployments with no customer-visible downtime.

****Customers receive at least 7 days' notice of scheduled maintenance expected to be customer-affecting****, and 30 days' notice where the change requires customer a

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[2] change-management-procedure — 6. Customer notification — relevance 0.64

6. Customer notification

Customers are notified at least ****7 days**** in advance of any change expected to cause degraded service or to require action on their part. Breaking API changes follow the deprecation policy: minimum ****12 months**** notice, with the deprecated version remaining available throughout.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[3] service-operations-and-support — Service Operations, Maintenance and Support — relevance 0.61

Service Operations, Maintenance and Support

****Document ID:**** KD-ENG-009 · ****Version:**** 2.2 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 23 January 2026 · ****Next review:**** 23 January 2027

****Maps to:**** SOC 2 A1.1, A1.2, CC7.3, CC8.1 · ISO 27001:2022 A.5.29, A.8.6, A.8.32

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[4] service-operations-and-support — 7. Incident communication to customers — relevance 0.60

7. Incident communication to customers

Customer-facing incident communication is owned by the incident commander and follows the commitments in KD-SEC-008 §4. In practice: status page inside 15 minutes, direct email to affected tenant administrators inside 60 minutes for a Sev 1, and a written post-incident review within 5 business days for any Sev 1 or Sev 2, shared with affected customers on req

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[5] change-management-procedure — 7. Change freeze — relevance 0.60

7. Change freeze

A change freeze applies from 20 December to 2 January, and during any active SEV1. Only Emergency changes are permitted during a freeze.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[6] service-operations-and-support — 1. Status page — relevance 0.58

1. Status page

Service status is published at `status.kestreldata.com`, hosted by Statuspage on infrastructure independent of Kestrel's own — a status page that shares a failure domain with the service is worthless during exactly the event it exists for. The page shows per-component status for the US and EU instances, current and historical incidents, and scheduled maintenance. Customers may s

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[7] change-management-procedure — 4. Infrastructure changes — relevance 0.57

4. Infrastructure changes

Infrastructure is managed exclusively through Terraform in the `kestrel-infra` repository. Manual changes through the AWS console are prohibited in production; drift detection runs every 6 hours and raises a SEV3 on any unmanaged change. Drift was detected 4 times in 2025, all traced to AWS-initiated maintenance rather than human action.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

162. Is 24x7 support available for production-down incidents?

engineering · Q162 · Vendor Security Review row 163

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

163. Provide your standard Data Processing Agreement.

legal · Q163 · Vendor Security Review row 164

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

164. Are backups replicated across regions? Do they leave the residency boundary?

engineering · Q164 · Vendor Security Review row 165

Yes, backups are replicated across regions while strictly adhering to data residency boundaries. Specifically: - Backups originating in the US production environment (`us-east-1`) replicate to `us-west-2`. - Backups originating in the EU production environment (`eu-west-1`) replicate to `eu-central-1`. Backups do not leave their designated residency boundary; EU customer data never leaves the European Economic Area (EEA), including in backups (`backup-restore-procedure`, Section 2; `infrastructure-architecture-overview`, Section 1). All backups are encrypted with AES-256 using AWS KMS (`backup-restore-procedure`, Section 2).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] backup-restore-procedure — 2. Encryption and location — relevance 0.67

2. Encryption and location

All backups are encrypted with AES-256 using AWS KMS. The daily logical dump uses a `separate CMK` from the primary database, so that compromise of the primary key does not compromise the backups.

Cross-region replication stays inside the residency boundary: `us-east-1` replicates to `us-west-2`, `eu-west-1` replicates to `eu-central-1`. EU customer data never le

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[2] backup-restore-procedure — 1. What is backed up — relevance 0.60

1. What is backed up
| Asset | Method | Frequency | Retention |
|---|---|---|---|
| RDS PostgreSQL | Automated snapshots + WAL archiving (PITR) | Continuous | ****35 days**** |
| RDS logical dump | `pg\_dump` to S3, encrypted with a separate CMK | Daily 03:00 UTC | 90 days |
| S3 objects | Versioning + cross-region replication | Continuous | 90 days for non-current versions |
| Snowflake | Time Tr

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[3] backup-restore-procedure — 4. Test results — relevance 0.59

4. Test results
Restore is tested ****quarterly****, and the test is a real restore, not a backup-listing check.

Quarter	Date	Duration	Assertions	Outcome
Q1 2026	17 Jan 2026	2h 41m	1,240 / 1,240	Pass
Q4 2025	11 Oct 2025	3h 02m	1,238 / 1,240	Pass, 2 known-stale fixtures corrected
Q3 2025	19 Jul 2025	3h 20m	1,240 / 1,240	Pass

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[4] infrastructure-architecture-overview — 1. Cloud footprint — relevance 0.59

1. Cloud footprint
Kestrel runs on ****Amazon Web Services****. There are two independent production instances:

Instance	Region	Serves
US	`us-east-1` (3 AZs)	North America, and customers with no residency requirement
EU	`eu-west-1` (3 AZs)	EEA, UK, and Swiss customers electing EU residency

Backup replication targets `us-west-2` and `eu-central-1` respecti

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[5] backup-restore-procedure — 5. Tenant-scoped restore — relevance 0.57

5. Tenant-scoped restore
A single customer can be restored without affecting others, by restoring to an isolated account and exporting that tenant rows back. This was exercised once in production, on 22 September 2025, at a customer request following an erroneous bulk delete on their side. Time to complete was 5 hours 10 minutes.

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

165. How much notice do you give customers before a breaking API change?

engineering · Q165 · Vendor Security Review row 166

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

166. Describe your process for responding to government requests for customer data.

legal · Q166 · Vendor Security Review row 167

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

167. Do you maintain Records of Processing Activities under Article 30?

legal · Q167 · Vendor Security Review row 168

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

168. Do you publish a modern slavery or supply chain labour statement?

legal · Q168 · Vendor Security Review row 169

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] security-addendum — 4. Incident notification — relevance 0.53

4. Incident notification

- Personal data breach: notification within **72 hours** of confirmation.
- Confirmed unauthorised access to customer production data: **24 hours**.
- Notification content as set out in the DPA Section 7.

gs://attestor-505506-corporate/legal/security-addendum.txt

[2] security-addendum — 3. Access commitments — relevance 0.50

3. Access commitments

- Multi-factor authentication mandatory for all Kestrel personnel with production access.
- Production access on a least-privilege, just-in-time basis, expiring within 8 hours.
- No routine Kestrel access to customer production data; support access requires per-incident customer authorisation.
- Access revoked within 24 hours of personnel departure. Measured median in 2

gs://attestor-505506-corporate/legal/security-addendum.txt

[3] security-addendum — 1. Certifications maintained — relevance 0.49

1. Certifications maintained

Kestrel will maintain, for the term of the Agreement, a SOC 2 Type II report covering Security, Availability, and Confidentiality, and ISO/IEC 27001:2022 certification. Current reports are made available annually within 30 days of issuance.

If a certification lapses or an audit opinion is qualified, Kestrel will notify affected customers within **10 business days**

gs://attestor-505506-corporate/legal/security-addendum.txt

[4] security-addendum — Security Addendum — relevance 0.49

Security Addendum

Document ID: KD-LEG-008 · **Version:** 3.1 · **Owner:** Marcus Oyelaran, CISO
Effective: 1 February 2026 · Forms part of the Master Subscription Agreement

This addendum states the security commitments Kestrel makes contractually. It is deliberately narrower than the Information Security Policy: everything here is an obligation, not an aspiration.

gs://attestor-505506-corporate/legal/security-addendum.txt

[5] security-addendum — 8. Changes — relevance 0.48

8. Changes

Kestrel may update this addendum, provided that no update materially reduces the commitments during a paid term. Material changes are notified 30 days in advance.

gs://attestor-505506-corporate/legal/security-addendum.txt

169. What authorisation is required for support access to customer data?

security · Q169 · Vendor Security Review row 170

Kestrel personnel do not access customer production data as a matter of routine. Access to customer data for support purposes requires explicit, per-incident customer authorisation recorded in Zendesk. This access is strictly limited to

the specific tenant and automatically expires after 24 hours (`access-control-standard`, Section 5. Customer data access).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] access-control-standard — 5. Customer data access — relevance 0.66

5. Customer data access

Kestrel personnel do not access customer production data as a matter of routine. Access for support purposes requires explicit per-incident customer authorisation recorded in Zendesk, is limited to the specific tenant, and expires after 24 hours.

Between 1 January and 31 December 2025 there were 19 such authorised accesses across 7 customers, each evidenced in the SOC

gs://attestor-505506-corpus/security/access-control-standard.txt

[2] acceptable-use-policy — 4. Data handling — relevance 0.62

4. Data handling

Restricted data may not be copied to personal cloud storage, personal email, USB media, or unmanaged devices. USB mass storage is blocked at the OS level on all managed devices.

Screen sharing during customer calls must use a dedicated demo tenant, never production.

gs://attestor-505506-corpus/security/acceptable-use-policy.txt

[3] data-handling-standard — 2. Categories of customer data processed — relevance 0.61

2. Categories of customer data processed

Kestrel Insight processes exactly four categories of customer data, defined in the DPA and in the Records of Processing Activities (KD-LEG-004):

1. **Account identity data** — end-user name, business email address, role, tenant ID.
2. **Product usage events** — timestamps, feature identifiers, tenant ID, session ID.
3. **Customer-uploaded analytics dataset**

gs://attestor-505506-corpus/security/data-handling-standard.txt

[4] access-control-standard — 3. Role-based access — relevance 0.59

3. Role-based access

Access is granted to Okta groups, never to individuals. There are 41 defined roles, each mapping to a documented entitlement set in the Access Matrix (`SEC-GOV/access-matrix`), which is the authoritative record reviewed during audit. Standing production access is limited to 11 named Site Reliability Engineers. All other production access is just-in-time.

gs://attestor-505506-corpus/security/access-control-standard.txt

[5] information-security-policy — 9. Incident response — relevance 0.58

9. Incident response

Security incidents are handled under the Incident Response Runbook (KD-SEC-005). Kestrel commits contractually to notifying affected customers within 72 hours of confirming a personal data breach, and within 24 hours for incidents involving confirmed unauthorised access to customer production data.

gs://attestor-505506-corpus/security/information-security-policy.txt

170. Summarise the supplementary measures identified in your Transfer Impact Assessment.

legal · Q170 · Vendor Security Review row 171

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

171. For each applicable system: How do you support California consumer rights requests?

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

172. Do you hold HITRUST certification?

security · Q172 · Vendor Security Review row 173

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] information-security-policy — 3. Certifications and attestations — relevance 0.65

3. Certifications and attestations

| Framework | Status | Evidence |

|---|---|---|

| SOC 2 Type II | Current | Report issued 14 March 2026 by Prescient Assurance LLP, covering 1 January – 31 December 2025. No exceptions noted. |

| ISO/IEC 27001:2022 | Certified | Certificate IS-2025-44817, issued by BSI on 22 September 2025, valid to 21 September 2028 |

| ISO/IEC 27701:2019 | Certified | Extension

gs://attestor-505506-corpus/security/information-security-policy.txt

[2] company-and-security-programme-overview — 8. How to obtain evidence — relevance 0.64

8. How to obtain evidence

The SOC 2 Type II report, the ISO 27001 certificate, the penetration test executive summary, and the standard DPA are available to customers and prospects under NDA through the account team, usually within two business days. The certificate and the trust page are available without an NDA.

gs://attestor-505506-corpus/security/company-and-security-programme-overview.txt

[3] company-and-security-programme-overview — 6. Scope of certification — relevance 0.60

6. Scope of certification

The ISO 27001 certificate scope statement reads: **"The information security management system supporting the development, operation, and support of the Kestrel Insight analytics platform, including supporting corporate functions, at Austin, Texas and for remote personnel."** The SOC 2 report covers the Security, Availability, and Confidentiality Trust Services Criteria. Pr

gs://attestor-505506-corpus/security/company-and-security-programme-overview.txt

[4] company-and-security-programme-overview — 3. Security programme in summary — relevance 0.60

3. Security programme in summary

The programme is built on four commitments, each evidenced elsewhere in this corpus rather than asserted here:

1. ****Independent verification.**** SOC 2 Type II (Prescient Assurance LLP, report issued 14 March 2026 covering 1 January – 31 December 2025, ****no exceptions****) and ISO 27001:2022 (BSI certificate `IS-2025-44817`, issued 22 September 2025, valid to 21

gs://attestor-505506-corpus/security/company-and-security-programme-overview.txt

[5] information-security-policy — 6. Personnel security — relevance 0.59

6. Personnel security

All employees and contractors undergo background screening appropriate to jurisdiction before their start date, conducted by Checkr. Screening covers identity verification, right to work, criminal records where lawful, and employment history for the preceding seven years.

Security awareness training is delivered through Curricula at onboarding and annually thereafter. Comple

gs://attestor-505506-corporate/security/information-security-policy.txt

173. Do you have a documented AI governance policy?

legal · Q173 · Vendor Security Review row 174

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

174. What is the minimum password length enforced?

security · Q174 · Vendor Security Review row 175

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] access-control-standard — 9. Password requirements — relevance 0.69

9. Password requirements

Where a password is used, minimum length is 14 characters, checked against the Have I Been Pwned breached-password corpus at set time. Rotation is not forced on a schedule, in line with NIST SP 800-63B guidance; rotation is forced on evidence of compromise.

gs://attestor-505506-corporate/security/access-control-standard.txt

[2] access-control-standard — 2. Multi-factor authentication — relevance 0.57

2. Multi-factor authentication

Hardware-backed MFA (WebAuthn / FIDO2, YubiKey 5 series) is mandatory for every human account. SMS and TOTP were removed as acceptable factors on 30 June 2025 following the RISK-2025-0031 treatment plan. Coverage is 100% of the 187 active employee accounts and 100% of the 24 active contractor accounts, verified continuously by Vanta control AC-07.

gs://attestor-505506-corporate/security/access-control-standard.txt

[3] access-control-standard — Access Control Standard — relevance 0.54

Access Control Standard

Document ID: KD-SEC-002 · **Version:** 3.1 · **Owner:** Sofia Brenner, Head of IT
Approved: 8 January 2026 · **Next review:** 8 January 2027
Maps to: SOC 2 CC6.1, CC6.2, CC6.3 · ISO 27001:2022 A.5.15, A.5.16, A.5.18, A.8.2

gs://attestor-505506-corporate/security/access-control-standard.txt

[4] access-control-standard — 1. Identity provider — relevance 0.51

1. Identity provider

All Kestrel Data systems authenticate through Okta (tenant `kestreldata.okta.com`). Local accounts on production systems are prohibited except for two documented break-glass accounts held in a sealed 1Password vault, whose use triggers a PagerDuty alert to the CISO. Both break-glass credentials were last rotated on 3 January 2026 and last used on 14 August 2025 during the

gs://attestor-505506-corporate/security/access-control-standard.txt

[5] access-control-standard — 6. Joiners, movers, leavers — relevance 0.50

6. Joiners, movers, leavers

Joiners are provisioned via Okta Lifecycle Management from Rippling (HRIS); no access is granted before the background check clears. Movers have entitlements recalculated on role change, with the previous role revoked within 1 business day. Leavers have all access revoked automatically on the HRIS termination event: the target is 1 hour, and the measured median for

gs://attestor-505506-corporate/security/access-control-standard.txt

175. For each applicable system: How do you handle a vulnerability with no available upstream fix?

When a vulnerability has no available upstream fix, Kestrel Data records the finding in the risk register under a named owner and implements one of three mitigation strategies: 1. **Component Removal:** Removing the affected component entirely. 2. **Network/WAF Controls:** Blocking the attack path at the network or Web Application Firewall (WAF) layer. 3. **Vendored Patching:** Applying and maintaining an internal vendored patch (per KD-ENG-007 §7). The vulnerability is re-reviewed on a weekly cadence until an upstream patch is released and deployed (Cloud Security Posture Standard, Section 6, "Handling a vulnerability with no upstream fix").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (9)

[1] cloud-security-posture-standard — 6. Handling a vulnerability with no upstream fix — relevance 0.72

6. Handling a vulnerability with no upstream fix

Where no upstream fix exists, the finding is recorded in the risk register with a named owner and the mitigation is chosen from: removing the affected component, blocking the attack path at the network or WAF layer, or applying a vendored patch maintained by Kestrel (see KD-ENG-007 §7). The vulnerability is re-reviewed weekly until an upstream fix

|

gs://attestor-505506-corporus/security/cloud-security-posture-standard.txt

[2] risk-management-and-governance — 5. Worked examples from the register — relevance 0.66

5. Worked examples from the register

Risk	Description	Treatment	Residual
---	---	---	---
RISK-2025-0031	SMS and TOTP factors phishable	Mitigate — hardware factors mandated 30 June 2025	Low
RISK-2024-0017	No file-scanning anti-malware on container hosts	Accept — immutable hosts, signed images, runtime detection	Low
RISK-2025-0044	Single-cloud concentration on AWS		

|

| RISK-2025-0031 | SMS and TOTP factors phishable | Mitigate — hardware factors mandated 30 June 2025 | Low |

| RISK-2024-0017 | No file-scanning anti-malware on container hosts | Accept — immutable hosts, signed images, runtime detection | Low |

|

| RISK-2025-0044 | Single-cloud concentration on AWS

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[3] vulnerability-management-policy — Vulnerability Management Policy — relevance 0.65

Vulnerability Management Policy

Document ID: KD-SEC-006 · **Version:** 3.3 · **Owner:** Dana Whitfield, VP Engineering

Approved: 22 January 2026 · **Next review:** 22 January 2027

Maps to: SOC 2 CC7.1, CC7.2 · ISO 27001:2022 A.8.8

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[4] vulnerability-management-policy — 1. Remediation SLAs — relevance 0.63

1. Remediation SLAs

Severity is assigned from CVSS v3.1 base score, adjusted for exploitability and exposure.

Internet-facing findings are escalated one level.

Severity	CVSS	Remediation SLA	Measured 2025 compliance
---	---	---	---
Critical	9.0-10.0	7 days	100% (11 of 11)
High	7.0-8.9	30 days	96% (74 of 77)
Medium	4.0-6.9	90 days	91%

|

| Critical | 9.0-10.0 | **7 days** | 100% (11 of 11) |

| High | 7.0-8.9 | **30 days** | 96% (74 of 77) |

| Medium | 4.0-6.9 | **90 days** | 91% |

|

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[5] risk-management-and-governance — Risk Management and Security Governance — relevance 0.62

Risk Management and Security Governance

Document ID: KD-SEC-018 · **Version:** 3.0 · **Owner:** Marcus Oyelaran, CISO

Approved: 26 January 2026 · **Next review:** 26 January 2027

Maps to: SOC 2 CC1.1, CC1.2, CC1.3, CC3.1, CC3.2, CC3.4 · ISO 27001:2022 A.5.1–A.5.4, Clauses 5–6, 9

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[6] pen-test-executive-summary — 5. Medium findings, in brief — relevance 0.60

5. Medium findings, in brief

1. Session cookie missing `SameSite=Strict` on one legacy subdomain. Fixed 2 March 2026.

2. Verbose error messages disclosing library versions on 4 API endpoints. Fixed 4 March 2026.
3. S3 bucket `kestrel-public-assets` permitted `s3:ListBucket` to authenticated AWS principals outside the Organization. Fixed 27 February 2026 with an explicit bucket policy den

gs://attestor-505506-corporus/security/pen-test-executive-summary.txt

[7] pen-test-executive-summary — 3. Findings summary — relevance 0.58

3. Findings summary
| Severity | Found | Remediated | Retest verified |
|---|---|---|---|
| Critical | 0 | - | - |
| High | 1 | 1 | 18 March 2026 |
| Medium | 4 | 4 | 18 March 2026 |
| Low | 7 | 5 | 18 March 2026 |
| Informational | 9 | Accepted / tracked | - |

****No cross-tenant data access was achieved.**** Tenant isolation held under every tested condition, including direct object refere

gs://attestor-505506-corporus/security/pen-test-executive-summary.txt

[8] pen-test-executive-summary — 6. Two accepted low findings — relevance 0.57

6. Two accepted low findings
- ****L6**** - Username enumeration remains possible through the SAML metadata endpoint for customers using IdP-initiated flows. Accepted; mitigation would break a documented integration pattern. Tracked as RISK-2026-0004.
- ****L7**** - TLS 1.2 remains enabled on the legacy SFTP endpoint. Accepted until the Q3 2026 decommission. Tracked as RISK-2025-0088.

gs://attestor-505506-corporus/security/pen-test-executive-summary.txt

[9] vulnerability-management-policy — 2. Scanning coverage — relevance 0.56

2. Scanning coverage
| Layer | Tool | Cadence |
|---|---|---|
| Dependencies (SCA) | Snyk Open Source | Every pull request, plus daily on `main` |
| Static analysis (SAST) | Semgrep + GitHub CodeQL | Every pull request |
| Container images | Amazon ECR enhanced scanning (Inspector) | On push, plus continuous rescan |
| Infrastructure | AWS Inspector, AWS Security Hub | Continuous |
| IaC | C

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

176. What security evidence do you require from subprocessors before engagement?

security · Q176 · Vendor Security Review row 177

Under Kestrel Data's Vendor Risk Management Policy (KD-SEC-008), subprocessors processing customer production data are classified as Tier 1 vendors and must undergo a full security review before engagement. Prior to onboarding, Tier 1 subprocessors are required to provide the following security evidence and documentation: ****Security Attestation:**** A current SOC 2 Type II report or ISO 27001 certificate, reviewed and validated by the Security team (Section 1, "1. Tiering"; Section 2, "2. Onboarding requirements"). ****Data Processing Agreement (DPA):**** An executed DPA, including the 2021 EU Standard Contractual Clauses (SCCs) whenever personal data leaves the EEA (Section 2, "2. Onboarding requirements"). ****Data Flows and Retention:**** Documented data flows and defined retention schedules (Section 2, "2. Onboarding requirements"). ****Exit Strategy:**** A recorded exit plan (Section 2, "2. Onboarding requirements"). All vendor onboarding reviews—including reviewer details, review dates, evaluated evidence, and residual risk—are recorded in Vanta, and Tier 1 vendor engagements additionally require formal sign-off from the Security Council (Section 2, "2. Onboarding requirements").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (7)

[1] vendor-risk-management-policy — 1. Tiering — relevance 0.68

1. Tiering

Vendors are tiered on data sensitivity and operational dependency.

| Tier | Definition | Diligence | Review |

|---|---|---|---|

| **Tier 1** | Processes customer production data, or an outage stops the platform | Full security review, SOC 2 or ISO 27001 evidence required, DPA required | Annual |

| **Tier 2** | Processes Kestrel internal or employee data | Security questionnaire, a

gs://attestor-505506-corporus/security/vendor-risk-management-policy.txt

[2] vendor-risk-management-policy — 2. Onboarding requirements — relevance 0.67

2. Onboarding requirements

No Tier 1 vendor is engaged without: a current SOC 2 Type II report or ISO 27001 certificate reviewed by the Security team; an executed DPA including the 2021 EU Standard Contractual Clauses where personal data leaves the EEA; documented data flows and retention; and a recorded exit plan.

Reviews are recorded in Vanta with the reviewer, date, evidence reviewed, and

gs://attestor-505506-corporus/security/vendor-risk-management-policy.txt

[3] vendor-risk-management-policy — Vendor Risk Management Policy — relevance 0.67

Vendor Risk Management Policy

Document ID: KD-SEC-008 · **Version:** 2.0 · **Owner:** Aaron Feldstein, General Counsel

Approved: 4 February 2026 · **Next review:** 4 February 2027

Maps to: SOC 2 CC9.2 · ISO 27001:2022 A.5.19-A.5.22 · GDPR Art. 28

gs://attestor-505506-corporus/security/vendor-risk-management-policy.txt

[4] vendor-risk-management-policy — 5. Ongoing monitoring — relevance 0.65

5. Ongoing monitoring

Tier 1 vendors are monitored continuously through SecurityScorecard, with a score drop of more than 10 points in 30 days triggering review. Attestation expiry is tracked in Vanta, with a reminder at 60 days before lapse.

gs://attestor-505506-corporus/security/vendor-risk-management-policy.txt

[5] vendor-risk-management-policy — 3. Subprocessors — relevance 0.63

3. Subprocessors

Subprocessors engaged for customer personal data are listed publicly in the Subprocessor List (KD-LEG-002) at `kestreldata.com/subprocessors`. Customers may subscribe to change notifications and receive **30 days** advance notice of any addition, during which they may object on reasonable data-protection grounds.

gs://attestor-505506-corporus/security/vendor-risk-management-policy.txt

[6] company-and-security-programme-overview — 8. How to obtain evidence — relevance 0.62

8. How to obtain evidence

The SOC 2 Type II report, the ISO 27001 certificate, the penetration test executive summary, and the standard DPA are available to customers and prospects under NDA through the account team, usually within two business days. The certificate and the trust page are available without an NDA.

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[7] information-security-policy — 10. Exceptions — relevance 0.59

10. Exceptions

Exceptions to this policy require written approval from the CISO, a documented compensating control, and an expiry date not exceeding 180 days. Four exceptions are open as of 11 February 2026, all tracked in Vanta and all with expiry dates before 30 September 2026.

gs://attestor-505506-corporus/security/information-security-policy.txt

177. Describe how tenant isolation is enforced. If not, describe compensating controls.

engineering · Q177 · Vendor Security Review row 178

Kestrel Insight is a multi-tenant platform with logical isolation enforced across three distinct layers (infrastructure-architecture-overview, Section 5. Tenant isolation): 1. **Database Layer:** Isolation is enforced using PostgreSQL row-level security (RLS) policies keyed on `tenant\_id`. These policies are applied at the connection level via an authenticated session variable, and no application query can opt out. 2. **Application Layer:** Every incoming request carries a validated tenant claim. The data access layer refuses any query lacking a tenant predicate, enforced programmatically via a repository base class rather than by convention. 3. **Storage Layer:** Amazon S3 object keys are tenant-prefixed, and AWS IAM policies strictly constrain access by prefix. Tenant isolation is continuously verified on every build through an 84-assertion test suite and was independently validated during the February 2026 penetration test, where no cross-tenant access was achieved (infrastructure-architecture-overview, Section 5. Tenant isolation).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] infrastructure-architecture-overview — 5. Tenant isolation — relevance 0.63

5. Tenant isolation

Kestrel Insight is **multi-tenant** with logical isolation. There is no per-customer infrastructure, no single-tenant deployment option, and no customer-VPC option.

Isolation is enforced at three layers:

1. **Database** - PostgreSQL row-level security policies keyed on `tenant\_id`, applied at the connection level from an authenticated session variable. No application

gs://attestor-505506-corporis/engineering/infrastructure-architecture-overview.txt

[2] infrastructure-architecture-overview — 6. Network — relevance 0.61

6. Network

Private subnets for all compute and data. No public IP addresses on workload instances. Ingress is exclusively through Cloudflare, then an AWS Application Load Balancer, then the Istio ingress gateway. Egress is through NAT gateways with an allowlist for known destinations.

Security groups are managed in Terraform and default-deny. There are no `0.0.0.0/0` ingress rules in produc

gs://attestor-505506-corporis/engineering/infrastructure-architecture-overview.txt

[3] data-flow-and-shared-responsibility — 4. Complementary user entity controls — relevance 0.60

4. Complementary user entity controls

The SOC 2 report lists these as complementary user entity controls; they are restated here because a customer reading only this document should still see them. If a customer does not operate the controls in the second list, Kestrel's controls in the first do not compensate: Kestrel cannot detect that a departed employee of the customer still holds a valid sess

gs://attestor-505506-corporis/engineering/data-flow-and-shared-responsibility.txt

[4] data-flow-and-shared-responsibility — 3. The shared responsibility model — relevance 0.59

3. The shared responsibility model

Security of the platform is Kestrel's. Security of what the customer does with it is the customer's. The line is drawn here rather than left implicit, because an unstated boundary is where a breach lands on whoever is less able to argue.

Kestrel is responsible for:

* physical and environmental security of the infrastructure (through AWS), and the cloud co

gs://attestor-505506-corporis/engineering/data-flow-and-shared-responsibility.txt

[5] infrastructure-architecture-overview — 3. Compute — relevance 0.57

3. Compute

Amazon EKS (Kubernetes 1.31) with managed node groups spanning three availability zones. Workloads run as containers built from distroless base images, as non-root, with read-only root filesystems and dropped Linux capabilities. Pod Security Standards are enforced at

the `restricted` level.

Node images are immutable; nodes are recycled with a maximum age of 30 days rather than pa

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

178. Please confirm: Provide your ISO 27001 certificate and its scope statement.

security · Q178 · Vendor Security Review row 179

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

179. In what year was the company founded, and where is it incorporated?

legal · Q179 · Vendor Security Review row 180

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

180. How frequently are user access reviews performed?

security · Q180 · Vendor Security Review row 181

User access reviews are performed quarterly across all production systems, the AWS Organization, Snowflake, GitHub, and Okta itself. These reviews are conducted by the respective system owners and formally attested in Vanta (access-control-standard, Section 7: Access reviews).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] access-control-standard — 7. Access reviews — relevance 0.72

7. Access reviews

Quarterly user access reviews cover all production systems, the AWS Organization, Snowflake, GitHub, and Okta itself. Reviews are performed by the system owner and attested in Vanta. The Q4 2025 review completed on 12 January 2026 and removed 23 entitlements, of which 9 were stale contractor accesses.

gs://attestor-505506-corporus/security/access-control-standard.txt

[2] access-control-standard — 3. Role-based access — relevance 0.66

3. Role-based access

Access is granted to Okta groups, never to individuals. There are 41 defined roles, each mapping to a documented entitlement set in the Access Matrix (`SEC-GOV/access-matrix`), which is the authoritative record reviewed during audit. Standing production access is limited to 11 named Site Reliability Engineers. All other production access is just-in-time.

gs://attestor-505506-corporus/security/access-control-standard.txt

[3] risk-management-and-governance — 8. Policy management — relevance 0.64

8. Policy management

All security policies carry a document ID, a version, a named owner, an approval date, and a review date. Policies are reviewed at least annually and on material change. The 2026 review cycle covered 14 policies between 8 January and 12 February 2026; three were revised, and the changes were communicated at the February all-hands and through the annual acknowledgement cycle.

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[4] access-control-standard — 6. Joiners, movers, leavers — relevance 0.64

6. Joiners, movers, leavers

Joiners are provisioned via Okta Lifecycle Management from Rippling (HRIS); no access is granted before the background check clears. Movers have entitlements recalculated on role change, with the previous role revoked within 1 business day. Leavers have all access revoked automatically on the HRIS termination event: the target is 1 hour, and the measured median for

gs://attestor-505506-corporus/security/access-control-standard.txt

[5] access-control-standard — 4. Just-in-time production access — relevance 0.63

4. Just-in-time production access

Engineers request elevated production access through the `/access` Slack workflow. A request requires a written business justification, a linked incident or change ticket, and approval from a second engineer holding the SRE role. Self-approval is blocked.

Granted access expires automatically after **8 hours**. All commands executed in an elevated session are

gs://attestor-505506-corporus/security/access-control-standard.txt

181. For each applicable system: Do you operate active-active failover between regions?

engineering · Q181 · Vendor Security Review row 182

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

182. Please confirm: Do you encrypt customer data at rest?

security · Q182 · Vendor Security Review row 183

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

183. Do you have data loss prevention controls on endpoints?

security · Q183 · Vendor Security Review row 184

Yes, Kestrel Data implements data loss prevention (DLP) controls directly on endpoints. According to the Endpoint Protection and Data Loss Prevention Standard (KD-SEC-015, Section 5: "Data loss prevention") and the Asset Management Standard (Section 6: "Removable media"), endpoint DLP controls are enforced via Kandji device management policy across all laptops: * **Removable Media:** Write access to USB mass storage is blocked on all managed endpoints by policy, and there is no approved workflow for transferring customer data to removable media. * **Local Sharing:** AirDrop to non-Kestrel devices is disabled. These endpoint controls operate in conjunction with email DLP inspection and cloud egress monitoring.

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] endpoint-protection-standard — Endpoint Protection and Data Loss Prevention Standard — relevance 0.68

Endpoint Protection and Data Loss Prevention Standard

Document ID: KD-SEC-015 · **Version:** 2.2 · **Owner:** Sofia Brenner, Head of IT

Approved: 19 January 2026 · **Next review:** 19 January 2027

Maps to: SOC 2 CC6.6, CC6.8, CC7.1 · ISO 27001:2022 A.8.1, A.8.7, A.8.12, A.8.16

gs://attestor-505506-corporus/security/endpoint-protection-standard.txt

[2] endpoint-protection-standard — 5. Data loss prevention — relevance 0.67

5. Data loss prevention

DLP controls operate at three points rather than relying on a single agent:

* **Endpoint** — Kandji policy blocks USB mass storage write access on all laptops. AirDrop

to non-Kestrel devices is disabled.

* **Email** — Google Workspace DLP inspects outbound mail for tenant identifiers, bulk personal data patterns, and credential-shaped strings, quarantining matches for

gs://attestor-505506-corporate/security/endpoint-protection-standard.txt

[3] asset-management-standard — 6. Removable media — relevance 0.63

6. Removable media

Write access to USB mass storage is blocked on all managed endpoints by policy. There is no approved workflow for moving customer data onto removable media, and none has been requested since the control was introduced in March 2024.

gs://attestor-505506-corporate/security/asset-management-standard.txt

[4] endpoint-protection-standard — 4. Disk encryption — relevance 0.61

4. Disk encryption

FileVault 2 is enforced on all macOS devices, with recovery keys held in Kandji custody; LUKS is enforced on Linux workstations. Compliance is 100% of 174 devices, verified continuously by Vanta control DE-03.

gs://attestor-505506-corporate/security/endpoint-protection-standard.txt

[5] asset-management-standard — 3. Endpoint lifecycle — relevance 0.61

3. Endpoint lifecycle

Devices are procured centrally, enrolled in Kandji before issue, and issued with a recorded serial number against the person in Rippling. A device is never issued unenrolled, because an unenrolled device cannot be wiped remotely.

At offboarding the device is returned within 5 business days, remotely wiped, and either re-issued or disposed of. Where a remote contractor does not

gs://attestor-505506-corporate/security/asset-management-standard.txt

184. How many security incidents were recorded in the last calendar year? If not, describe compensating controls.

security · Q184 · Vendor Security Review row 185

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] incident-response-runbook — 9. 2025 incident summary — relevance 0.68

9. 2025 incident summary

41 security events recorded. Zero SEV1. Two SEV2, both resolved without customer data exposure:

- **INC-2025-0044** (14 August 2025) - RDS failover fault causing 41 minutes of degraded service. No data loss; RPO and RTO both met. Root cause was a misconfigured connection pool ceiling.
- **INC-2025-0071** (2 November 2025) - a contractor account remained active for

gs://attestor-505506-corporate/security/incident-response-runbook.txt

[2] soc2-control-matrix — Common Criteria — relevance 0.65

Common Criteria

Control	Description	Evidence	Test result
CC1.1	Board oversight of security; Audit and Risk Committee meets quarterly	Committee minutes, 4 meetings in 2025	No exceptions
CC1.4	Security awareness training at hire and annually	Curricula completion records, 100% of active staff	No exceptions
CC2.1	Internal communication of security		

gs://attestor-505506-corporate/security/soc2-control-matrix.txt

[3] incident-response-runbook — 3. Lifecycle — relevance 0.64

3. Lifecycle

Detect, triage, contain, eradicate, recover, learn.

Detection sources are Datadog Security Monitoring, AWS GuardDuty, AWS Security Hub, Okta ThreatInsight, Snyk, customer reports to `security@kestreldata.com`, and the disclosure address published at `kestreldata.com/.well-known/security.txt`.

Triage target is 15 minutes from alert to severity assignment for SEV1 and SEV2, meas

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[4] personnel-security-and-training — 5. Simulated phishing — relevance 0.62

5. Simulated phishing

Kestrel runs simulated phishing exercises **quarterly** through Curricula, targeting all personnel with a Kestrel mailbox. Results for 2025:

Quarter	Sent	Click rate	Credential submission	Reported to security
Q1 2025	198	6.1%	1.0%	41%
Q2 2025	203	4.4%	0.5%	52%
Q3 2025	208	3.4%	0.0%	58%
Q4 2025	211			2

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

[5] incident-response-runbook — 1. Severity definitions — relevance 0.62

1. Severity definitions

Sev	Definition	Page	Exec notify
-----	------------	------	-------------

--	--	--	--

SEV1	Confirmed unauthorised access to customer production data, or full platform outage	Immediate, 24/7	CEO + CISO within 30 min
-------------	--	-----------------	--------------------------

SEV2	Suspected compromise, partial outage affecting more than 10% of tenants, or confirmed data integrity fault	Immediate, 24/7	CISO within 1 hour
-------------	--	-----------------	--------------------

SEV3			
-------------	--	--	--

gs://attestor-505506-corporus/security/incident-response-runbook.txt

185. Do you retain an external incident response firm?

security · Q185 · Vendor Security Review row 186

Yes. Kestrel Data retains Mandiant on a pre-negotiated incident response retainer (contract MNMT-2025-1180, effective 1 September 2025, with 40 hours pre-paid annually) providing a 4-hour response SLA for SEV1 incidents. In addition, outside breach counsel is retained through Fenwick and West LLP (Incident Response Runbook, Section 7. External support).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] incident-response-runbook — 7. External support — relevance 0.67

7. External support

Kestrel retains **Mandiant** on a pre-negotiated incident response retainer (contract MNMT-2025-1180, effective 1 September 2025, 40 hours pre-paid annually) with a 4-hour response SLA for SEV1. Outside breach counsel is Fenwick and West LLP.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[2] incident-response-runbook — Incident Response Runbook — relevance 0.59

Incident Response Runbook

Document ID: KD-SEC-005 · **Version:** 5.0 · **Owner:** Marcus Oyelaran, CISO

Approved: 27 January 2026 · **Last exercised:** 3 December 2025 (tabletop)

Maps to: SOC 2 CC7.3, CC7.4, CC7.5 · ISO 27001:2022 A.5.24-A.5.28 · GDPR Art. 33, 34

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[3] incident-response-runbook — 6. Evidence handling — relevance 0.59

6. Evidence handling

The IC directs preservation before remediation wherever containment allows. EBS snapshots, memory captures where feasible, and relevant log ranges are exported to a dedicated forensics S3 bucket with Object Lock in compliance mode, retention 1 year. Chain of custody is recorded in the incident ticket.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[4] incident-response-runbook — 2. Roles — relevance 0.58

2. Roles

The Incident Commander owns the response and is deliberately not the person fixing the problem; ICs are drawn from a rota of 6 trained staff. The Communications Lead owns customer, internal, and regulator messaging. A Scribe maintains the timeline for every SEV1 and SEV2. Subject matter experts are pulled in as needed.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[5] incident-response-runbook — 9. 2025 incident summary — relevance 0.57

9. 2025 incident summary

41 security events recorded. Zero SEV1. Two SEV2, both resolved without customer data exposure:

- **INC-2025-0044** (14 August 2025) - RDS failover fault causing 41 minutes of degraded service. No data loss; RPO and RTO both met. Root cause was a misconfigured connection pool ceiling.
- **INC-2025-0071** (2 November 2025) - a contractor account remained active f

gs://attestor-505506-corporus/security/incident-response-runbook.txt

186. What is your backup retention period?

engineering · Q186 · Vendor Security Review row 187

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

187. How frequently do you commission independent penetration testing?

security · Q187 · Vendor Security Review row 188

Kestrel Data commissions an independent penetration test annually at minimum, as well as prior to any significant architectural changes (Vulnerability Management Policy, Section 4 "Penetration testing"). The most recent independent penetration test was conducted by Include Security from February 3 to February 14, 2026 (engagement INSEC-2026-0219) (Vulnerability Management Policy, Section 4 "Penetration testing"; Penetration Test Executive Summary, "Penetration Test Executive Summary").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] vulnerability-management-policy — 4. Penetration testing — relevance 0.68

4. Penetration testing

An independent penetration test is commissioned **annually** at minimum, and additionally before any significant architectural change. The most recent was performed by Include Security from 3 to 14 February 2026 (engagement INSEC-2026-0219). See the Penetration Test Executive Summary (KD-SEC-007).

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[2] network-security-standard — 10. Testing — relevance 0.62

10. Testing

Network controls are exercised annually by the external penetration test. The February 2026 test (Include Security, INSEC-2026-0219) attempted lateral movement from a compromised application container and did not achieve it; the finding raised was the rate limiting gap on the password reset endpoint, remediated on 27 February 2026.

gs://attestor-505506-corporus/security/network-security-standard.txt

[3] pen-test-executive-summary — Penetration Test Executive Summary — relevance 0.61

Penetration Test Executive Summary

Document ID: KD-SEC-007 · **Engagement:** INSEC-2026-0219

Tester: Include Security, Inc. · **Dates:** 3-14 February 2026

Report issued: 24 February 2026 · **Retest completed:** 18 March 2026

Classification: Confidential - shareable with customers under NDA

gs://attestor-505506-corporus/security/pen-test-executive-summary.txt

[4] company-and-security-programme-overview — 4. Governance — relevance 0.60

4. Governance

The CISO reports to the CEO and to the board quarterly. A Security Steering Group meets monthly. The risk register holds 41 open risks and is reviewed monthly and re-scored quarterly. Full detail is in KD-SEC-018.

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[5] company-and-security-programme-overview — 3. Security programme in summary — relevance 0.60

3. Security programme in summary

The programme is built on four commitments, each evidenced elsewhere in this corpus rather than asserted here:

1. ****Independent verification.**** SOC 2 Type II (Prescient Assurance LLP, report issued 14 March 2026 covering 1 January – 31 December 2025, ****no exceptions****) and ISO 27001:2022 (BSI certificate `IS-2025-44817`, issued 22 September 2025, valid to 21

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

188. Do you carry professional indemnity insurance?

legal · Q188 · Vendor Security Review row 189

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

189. Do you operate anti-malware controls on servers?

security · Q189 · Vendor Security Review row 190

Production compute runs immutable, minimal container images on Bottlerocket hosts. Rather than deploying traditional file-scanning anti-malware on these hosts, Kestrel Data relies on a set of compensating controls: * Read-only root filesystems * No interactive shell access in normal operation * Image signing enforced at admission * CrowdStrike Falcon sensors running in Linux mode across all production compute nodes for runtime behavioral detection This architecture is documented as an accepted risk (RISK-2024-0017) and was reviewed without exception by auditors during the 2025 SOC 2 evaluation period (`endpoint-protection-standard`, "3. Anti-malware on servers" and "2. Endpoint detection and response").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] endpoint-protection-standard — 3. Anti-malware on servers — relevance 0.69

3. Anti-malware on servers

Production compute runs immutable, minimal container images on Bottlerocket hosts. Traditional file-scanning anti-malware is not deployed on those hosts; the compensating controls are read-only root filesystems, no interactive shell access in normal operation, image signing enforced at admission, and the Falcon sensor running in Linux mode for runtime behavioural detecti

gs://attestor-505506-corporus/security/endpoint-protection-standard.txt

[2] endpoint-protection-standard — 8. Patching of endpoints — relevance 0.60

8. Patching of endpoints

Operating system updates are enforced within 14 days of release for standard updates and 72 hours for updates addressing a Critical vulnerability, with a Kandji deferral window that cannot be extended by the user. Measured compliance at the last audit point (1 February 2026) was 168 of 174 devices within policy, the remaining six being on extended leave with access suspend

gs://attestor-505506-corporus/security/endpoint-protection-standard.txt

[3] endpoint-protection-standard — 4. Disk encryption — relevance 0.60

4. Disk encryption

FileVault 2 is enforced on all macOS devices, with recovery keys held in Kandji custody; LUKS is enforced on Linux workstations. Compliance is 100% of 174 devices, verified continuously by Vanta control DE-03.

gs://attestor-505506-corporus/security/endpoint-protection-standard.txt

[4] endpoint-protection-standard — 2. Endpoint detection and response — relevance 0.57

2. Endpoint detection and response

CrowdStrike Falcon is deployed on 100% of managed endpoints and on all production compute nodes. Coverage is reconciled nightly against the Kandji and AWS inventories, and a device present in inventory but absent from Falcon raises a ticket to the Head of IT within one business day. The reconciliation found two gaps during 2025, both new contractor laptops, b

gs://attestor-505506-corporus/security/endpoint-protection-standard.txt

[5] network-security-standard — 2. Web application firewall — relevance 0.57

2. Web application firewall

Cloudflare WAF is enabled on all production hostnames, running the Cloudflare Managed Ruleset, the OWASP Core Ruleset at paranoia level 2, and 14 Kestrel-authored rules. Rules are deployed in log mode for 7 days before enforcement so that a false positive is found before it blocks a customer. Blocked request volume averaged 41,000 per day during 2025, of which the l

gs://attestor-505506-corporus/security/network-security-standard.txt

190. Do you share personal data with advertising networks?

legal · Q190 · Vendor Security Review row 191

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

191. Is there board-level oversight of information security? If not, describe compensating controls.

security · Q191 · Vendor Security Review row 192

Yes, Kestrel Data maintains formal board-level oversight of information security. The Board of Directors receives a formal information security report at each quarterly meeting, presented directly by the Chief Information Security Officer (CISO). This standing agenda covers movements in the risk register since the prior meeting, incident reports and classifications, certification and audit statuses, penetration testing results, and any policy exceptions granted above the CISO's approval threshold ('risk-management-and-governance', Section 2. Board oversight; 'soc2-control-matrix', Section Common Criteria, CC1.1). Additionally, the board has designated Elaine Vasquez, a non-executive director and former CIO of a regulated financial services firm, as the specific director holding security oversight responsibility ('risk-management-and-governance', Section 2. Board oversight). Because direct board oversight is fully established and operational, compensating controls are not required.

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] risk-management-and-governance — Risk Management and Security Governance — relevance 0.64

Risk Management and Security Governance

Document ID: KD-SEC-018 · **Version:** 3.0 · **Owner:** Marcus Oyelaran, CISO

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[2] risk-management-and-governance — 9. Exceptions — relevance 0.62

9. Exceptions

Exceptions to policy require: a written business justification, a compensating control, CISO approval, and an expiry date no later than 90 days out. Exceptions above residual score 12 additionally require Security Steering Group approval. Two exceptions were open as of 1 February 2026.

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[3] risk-management-and-governance — 2. Board oversight — relevance 0.62

2. Board oversight

The board receives a formal information security report at each quarterly meeting, presented by the CISO. The standing agenda covers: the risk register movement since the last meeting, incidents and their classification, certification and audit status, the results of penetration testing, and any exception granted above the CISO's own approval threshold. Board meetings covering s

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[4] soc2-control-matrix — Common Criteria — relevance 0.61

Common Criteria

Control	Description	Evidence	Test result
---------	-------------	----------	-------------

---	---	---	---
-----	-----	-----	-----

CC1.1	Board oversight of security; Audit and Risk Committee meets quarterly	Committee minutes, 4 meetings in 2025	No exceptions
-------	---	---------------------------------------	---------------

CC1.4	Security awareness training at hire and annually	Curricula completion records, 100% of active staff	No exceptions
-------	--	--	---------------

CC2.1	Internal communication of securit		
-------	-----------------------------------	--	--

gs://attestor-505506-corporus/security/soc2-control-matrix.txt

[5] company-and-security-programme-overview — 4. Governance — relevance 0.61

4. Governance

The CISO reports to the CEO and to the board quarterly. A Security Steering Group meets monthly. The risk register holds 41 open risks and is reviewed monthly and re-scored quarterly. Full detail is in KD-SEC-018.

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

192. Do you follow OWASP secure coding guidance?

engineering · Q192 · Vendor Security Review row 193

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

193. Have you completed a cryptographic inventory?

security · Q193 · Vendor Security Review row 194

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] encryption-standard — Encryption Standard — relevance 0.58

Encryption Standard

****Document ID:**** KD-SEC-003 · ****Version:**** 2.4 · ****Owner:**** Marcus Oyelaran, CISO

****Approved:**** 8 January 2026 · ****Next review:**** 8 January 2027

****Maps to:**** SOC 2 CC6.7 · ISO 27001:2022 A.8.24 · GDPR Art. 32(1)(a)

gs://attestor-505506-corporus/security/encryption-standard.txt

[2] encryption-standard — 6. Post-quantum posture — relevance 0.57

6. Post-quantum posture

Kestrel completed a cryptographic inventory (`SEC-GOV/crypto-inventory`, 19 January 2026) as the first step toward post-quantum readiness. TLS connections terminated at Cloudflare already negotiate the hybrid X25519MLKEM768 key agreement where the client supports it. No migration commitment date has been set for internal services.

gs://attestor-505506-corporus/security/encryption-standard.txt

[3] encryption-standard — 3. Key management — relevance 0.55

3. Key management

Customer-facing encryption keys are AWS KMS Customer Managed Keys. Key policies restrict use to named service roles. Key administrators and key users are disjoint sets: no individual holds both roles, enforced by a Service Control Policy at the AWS Organization level.

Automatic annual rotation is enabled on all CMKs. Manual rotation is triggered on suspected compromise. Ke

gs://attestor-505506-corporus/security/encryption-standard.txt

[4] encryption-standard — 5. Algorithm policy — relevance 0.54

5. Algorithm policy

Approved: AES-256-GCM, AES-256-CBC (legacy read paths only), RSA-2048 and above, ECDSA P-256 and P-384, SHA-256 and above, Argon2id and bcrypt (cost factor 12 or higher) for password hashing.

Prohibited: DES, 3DES, RC4, MD5 and SHA-1 for any security purpose, RSA below 2048 bits, and any custom cryptographic construction. Kestrel does not implement its own cryptographic

gs://attestor-505506-corporus/security/encryption-standard.txt

[5] encryption-standard — 1. Data at rest — relevance 0.52

1. Data at rest

All customer data at rest is encrypted using ****AES-256-GCM****. No customer data is stored unencrypted at any tier.

| Store | Mechanism | Key custody |

|---|---|---|

| Amazon RDS (PostgreSQL 16) | Storage-level encryption | AWS KMS CMK, per-environment |

| Amazon S3 | SSE-KMS | AWS KMS CMK, per-bucket |

| Snowflake | Native encryption, Tri-Secret Secure | Customer-managed key

gs://attestor-505506-corporus/security/encryption-standard.txt

194. What is your target time to revoke access when personnel depart?

security · Q194 · Vendor Security Review row 195

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

195. How do you communicate security changes to customers?

engineering · Q195 · Vendor Security Review row 196

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

196. Provide the executive summary of your most recent penetration test.

security · Q196 · Vendor Security Review row 197

Quarantined: Model Armor blocked this question.

Release status: No — quarantined by the guardrail · confidence low · drafted by ArmorGuard

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

197. How frequently are production operating systems patched?

engineering · Q197 · Vendor Security Review row 198

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

198. Are there any unrestricted inbound network rules in production?

engineering · Q198 · Vendor Security Review row 199

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] infrastructure-architecture-overview — Infrastructure Architecture Overview — relevance 0.64

Infrastructure Architecture Overview

Document ID: KD-ENG-003 · **Version:** 3.4 · **Owner:** Dana Whitfield, VP Engineering

Last updated: 5 February 2026 · **Classification:** Confidential, NDA required

gs://attestor-505506-corpus/engineering/infrastructure-architecture-overview.txt

[2] infrastructure-architecture-overview — 6. Network — relevance 0.57

6. Network

Private subnets for all compute and data. No public IP addresses on workload instances. Ingress is exclusively through Cloudflare, then an AWS Application Load Balancer, then the Istio ingress gateway. Egress is through NAT gateways with an allowlist for known destinations.

Security groups are managed in Terraform and default-deny. There are no `0.0.0.0/0` ingress rules in produc

gs://attestor-505506-corpus/engineering/infrastructure-architecture-overview.txt

[3] infrastructure-architecture-overview — 2. Account structure — relevance 0.54

2. Account structure

AWS Organizations with 9 accounts: `management`, `security-tooling`, `log-archive`, `shared-services`, `prod-us`, `prod-eu`, `staging`, `dev`, `sandbox`. Service Control Policies enforce guardrails at the Organization level, including mandatory EBS encryption, denial of root user actions, and denial of CloudTrail or GuardDuty disablement.

The `log-archive` account has no

gs://attestor-505506-corpus/engineering/infrastructure-architecture-overview.txt

[4] infrastructure-architecture-overview — 3. Compute — relevance 0.53

3. Compute

Amazon EKS (Kubernetes 1.31) with managed node groups spanning three availability zones. Workloads run as containers built from distroless base images, as non-root, with read-only root filesystems and dropped Linux capabilities. Pod Security Standards are enforced at the `restricted` level.

Node images are immutable; nodes are recycled with a maximum age of 30 days rather than pa

gs://attestor-505506-corporate-engineering/infrastructure-architecture-overview.txt

[5] infrastructure-architecture-overview — 4. Data layer — relevance 0.51

4. Data layer
| Store | Technology | Purpose |
|---|---|---|
| Primary OLTP | Amazon RDS PostgreSQL 16, Multi-AZ | Application state |
| Analytics | Snowflake | Customer analytics workloads |
| Object storage | Amazon S3 | Uploads, exports, backups |
| Cache | Amazon ElastiCache (Redis 7) | Session and query cache |
| Search | OpenSearch 2.13 | In-product search |

gs://attestor-505506-corporate-engineering/infrastructure-architecture-overview.txt

199. Do you perform software composition analysis for third-party dependencies?

engineering · Q199 · Vendor Security Review row 200

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

200. Do you have a published responsible disclosure policy?

security · Q200 · Vendor Security Review row 201

Yes, Kestrel maintains a published responsible disclosure process. Security contact details are published at `kestreldata.com/.well-known/security.txt`, and Kestrel commits to acknowledging submitted reports within two business days. Researchers acting in good faith under the published policy will not be pursued legally. While Kestrel does not currently operate a paid bug bounty programme, all external vulnerability reports are handled through this responsible disclosure process (Vulnerability Management Policy, Section 5. Responsible disclosure).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (10)

[1] vulnerability-management-policy — 5. Responsible disclosure — relevance 0.68

5. Responsible disclosure
Kestrel publishes a security contact at `kestreldata.com/.well-known/security.txt` and commits to acknowledging reports within 2 business days. Researchers acting in good faith under the published policy will not be pursued legally.

****Kestrel does not currently operate a paid bug bounty programme.**** Reports are handled through the responsible disclosure process above

gs://attestor-505506-corporate-engineering/security/vulnerability-management-policy.txt

[2] vulnerability-management-policy — Vulnerability Management Policy — relevance 0.67

Vulnerability Management Policy
****Document ID:**** KD-SEC-006 · ****Version:**** 3.3 · ****Owner:**** Dana Whitfield, VP Engineering
****Approved:**** 22 January 2026 · ****Next review:**** 22 January 2027
****Maps to:**** SOC 2 CC7.1, CC7.2 · ISO 27001:2022 A.8.8

gs://attestor-505506-corporate-engineering/security/vulnerability-management-policy.txt

[3] acceptable-use-policy — 7. Reporting — relevance 0.64

7. Reporting
Suspected security issues must be reported to `security@kestreldata.com` or the `#security-incidents` Slack channel immediately. Kestrel operates a no-blame reporting culture: reporting a mistake promptly is treated as the correct behaviour, and no disciplinary action has ever followed a good-faith self-report.

gs://attestor-505506-corporate-engineering/security/acceptable-use-policy.txt

[4] incident-response-runbook — 8. Post-incident review — relevance 0.62

8. Post-incident review

Every SEV1 and SEV2 requires a blameless post-incident review within 5 business days, published internally, with action items tracked to closure in Jira. Reviews are shared with affected customers on request.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[5] vulnerability-management-policy — 2. Scanning coverage — relevance 0.62

2. Scanning coverage

| Layer | Tool | Cadence |

|---|---|---|

| Dependencies (SCA) | Snyk Open Source | Every pull request, plus daily on `main` |

| Static analysis (SAST) | Semgrep + GitHub CodeQL | Every pull request |

| Container images | Amazon ECR enhanced scanning (Inspector) | On push, plus continuous rescan |

| Infrastructure | AWS Inspector, AWS Security Hub | Continuous |

| IaC | C

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[6] information-security-policy — 11. Enforcement — relevance 0.61

11. Enforcement

Violation of this policy may result in disciplinary action up to and including termination of employment or contract, and referral to law enforcement where warranted.

Kestrel Data, Inc. · 1401 Lavaca Street, Suite 210, Austin, TX 78701 · Delaware C-corporation, incorporated 2019

gs://attestor-505506-corporus/security/information-security-policy.txt

[7] company-and-security-programme-overview — 7. Communicating change to customers — relevance 0.61

7. Communicating change to customers

Material security changes are communicated through the trust page at `trust.kestreldata.com`, through the subprocessor change notice mailing list (30 days' notice, see KD-LEG-001 §5), and through the account team for changes affecting a specific contract. Incident communications follow the commitments in KD-SEC-008 §4.

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[8] vulnerability-management-policy — 6. Exceptions — relevance 0.60

6. Exceptions

A finding that cannot be remediated within SLA requires a documented exception approved by the CISO, with a compensating control and an expiry date not exceeding 180 days.

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[9] information-security-policy — 9. Incident response — relevance 0.60

9. Incident response

Security incidents are handled under the Incident Response Runbook (KD-SEC-005). Kestrel commits contractually to notifying affected customers within 72 hours of confirming a personal data breach, and within 24 hours for incidents involving confirmed unauthorised access to customer production data.

gs://attestor-505506-corporus/security/information-security-policy.txt

[10] vulnerability-management-policy — no section recorded — relevance 0.60

Researchers acting in good faith under the published policy will not be pursued legally. **Kestrel does not currently operate a paid bug bounty programme.** ...

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

201. Do you offer source code escrow arrangements?

engineering · Q201 · Vendor Security Review row 202

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] secrets-management-standard — 2. What is prohibited — relevance 0.52

2. What is prohibited

- Secrets in source code, including test fixtures, comments, and commit history.
- Secrets in environment files committed to a repository.
- Secrets in CI logs, container image layers, or Terraform state in plaintext.
- Long-lived static AWS access keys. The last was decommissioned 17 November 2024, and creation of a new one triggers an hourly detection that pages the o

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

[2] secrets-management-standard — 3. Detection — relevance 0.50

3. Detection

Three layers, because one is not enough:

1. **Pre-commit** - Gitleaks runs locally through a managed pre-commit hook.
2. **Push protection** - GitHub secret scanning with push protection enabled organisation-wide, which blocks the push rather than alerting after the fact.
3. **Continuous** - GitHub Advanced Security scans all repository history daily, including private re

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

[3] secrets-management-standard — Secrets Management Standard — relevance 0.48

Secrets Management Standard

Document ID: KD-ENG-006 · **Version:** 2.1 · **Owner:** Dana Whitfield, VP Engineering
Approved: 22 January 2026 · **Maps to:** SOC 2 CC6.1 · ISO 27001:2022 A.8.24

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

[4] secrets-management-standard — 4. Runtime access — relevance 0.47

4. Runtime access

Workloads obtain secrets at runtime through the AWS Secrets Manager CSI driver, mounted as in-memory `tmpfs` volumes. Secrets are never written to disk, never baked into container images, and never passed as environment variables where they could leak into a crash dump or a process listing.

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

[5] secrets-management-standard — 6. Customer-issued API credentials — relevance 0.47

6. Customer-issued API credentials

API keys issued to customers are stored as Argon2id hashes; Kestrel cannot recover the plaintext of a customer API key and will not do so on request. Keys are displayed once at creation. Customers can create, scope, and revoke keys through the console, and each key carries a last-used timestamp so stale keys are visible.

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

202. Is production data used in test environments?

engineering · Q202 · Vendor Security Review row 203

Production data is never used in or copied to lower environments. Testing across local development and CI environments relies exclusively on synthetic fixtures, while staging uses synthetic and anonymized data generated by dedicated tooling (`tools/gen\_fixtures.py`). Kestrel Data strictly prohibits sanitized production data dumps in non-production environments (`sdlc-policy`, Section 2: Environments).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] sdlc-policy — 2. Environments — relevance 0.70

2. Environments

| Environment | Purpose | Data |

---|---|---

| `local` | Developer machines | Synthetic fixtures only |

| `ci` | Automated testing | Synthetic fixtures only |

| `staging` | Pre-production verification | Synthetic and anonymised data |
| `production` | Live service | Customer data |

****Production data is never copied to a lower environment.**** Staging fixtures are generated

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[2] sdlc-policy — 3. Testing requirements — relevance 0.59

3. Testing requirements

- Unit test coverage gate at ****80%**** on changed lines, enforced in CI.
- Integration tests run against ephemeral infrastructure provisioned per pull request.
- Tenant isolation tests run on every build: a suite of 84 assertions attempting cross-tenant reads through every public API surface.
- Load tests before any release expected to change the performance profile.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[3] sdlc-policy — 6. Release — relevance 0.54

6. Release

Releases are continuous: merge to `main` triggers a deployment to staging, an automated verification suite, and then a progressive rollout to production. Rollout is canary-based: 5% of traffic for 15 minutes, then 25%, then 100%, with automatic rollback on error-rate or latency regression.

Median lead time from merge to production in 2025 was ****34 minutes****. Change failure rate w

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[4] sdlc-policy — Secure Software Development Lifecycle Policy — relevance 0.52

Secure Software Development Lifecycle Policy

****Document ID:**** KD-ENG-001 · ****Version:**** 4.1 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 20 January 2026 · ****Next review:**** 20 January 2027

****Maps to:**** SOC 2 CC8.1 · ISO 27001:2022 A.8.25-A.8.31

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[5] sdlc-policy — 7. Separation of duties — relevance 0.51

7. Separation of duties

Engineers cannot deploy their own change to production without the automated pipeline: no human has the ability to push a container image to the production registry directly. The deployment role is held by the CI service identity, which authenticates through OIDC and holds no long-lived credentials.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

203. How do you manage cookie consent on your web properties?

legal · Q203 · Vendor Security Review row 204

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

204. How do you handle a vulnerability with no available upstream fix?

security · Q204 · Vendor Security Review row 205

When a vulnerability has no available upstream fix, Kestrel Data records the finding in the risk register with a designated named owner (*Cloud Security Posture Standard*, Section 6). Mitigation is implemented by selecting from the following options: * Removing the affected component, * Blocking the attack path at the network or Web Application Firewall (WAF) layer, or * Applying a vendored patch maintained internally by Kestrel (*Cloud Security Posture Standard*, Section 6). The vulnerability is re-reviewed on a weekly basis until an upstream fix is released (*Cloud Security Posture Standard*, Section 6). Furthermore, any finding that cannot be remediated within its defined SLA requires a formal documented exception approved by the CISO, complete with a compensating control and an

expiration date not exceeding 180 days (*Vulnerability Management Policy*, Section 6).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] cloud-security-posture-standard — 6. Handling a vulnerability with no upstream fix — relevance 0.71

6. Handling a vulnerability with no upstream fix

Where no upstream fix exists, the finding is recorded in the risk register with a named owner and the mitigation is chosen from: removing the affected component, blocking the attack path at the network or WAF layer, or applying a vendored patch maintained by Kestrel (see KD-ENG-007 §7). The vulnerability is re-reviewed weekly until an upstream fix

gs://attestor-505506-corporus/security/cloud-security-posture-standard.txt

[2] vulnerability-management-policy — 6. Exceptions — relevance 0.60

6. Exceptions

A finding that cannot be remediated within SLA requires a documented exception approved by the CISO, with a compensating control and an expiry date not exceeding 180 days.

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[3] pen-test-executive-summary — 3. Findings summary — relevance 0.60

3. Findings summary

Severity	Found	Remediated	Retest verified
Critical	0	-	-
High	1	1	18 March 2026
Medium	4	4	18 March 2026
Low	7	5	18 March 2026
Informational	9	Accepted / tracked	-

No cross-tenant data access was achieved. Tenant isolation held under every tested condition, including direct object refere

gs://attestor-505506-corporus/security/pen-test-executive-summary.txt

[4] vulnerability-management-policy — 1. Remediation SLAs — relevance 0.60

1. Remediation SLAs

Severity is assigned from CVSS v3.1 base score, adjusted for exploitability and exposure. Internet-facing findings are escalated one level.

Severity	CVSS	Remediation SLA	Measured 2025 compliance
Critical	9.0-10.0	**7 days**	100% (11 of 11)
High	7.0-8.9	**30 days**	96% (74 of 77)
Medium	4.0-6.9	**90 days**	91%

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[5] pen-test-executive-summary — 6. Two accepted low findings — relevance 0.59

6. Two accepted low findings

- **L6** - Username enumeration remains possible through the SAML metadata endpoint for customers using IdP-initiated flows. Accepted; mitigation would break a documented integration pattern. Tracked as RISK-2026-0004.
- **L7** - TLS 1.2 remains enabled on the legacy SFTP endpoint. Accepted until the Q3 2026 decommission. Tracked as RISK-2025-0088.

gs://attestor-505506-corporus/security/pen-test-executive-summary.txt

205. Do you perform static application security testing on every code change?

security · Q205 · Vendor Security Review row 206

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Evidence (5)

[1] vulnerability-management-policy — 2. Scanning coverage — relevance 0.65

2. Scanning coverage

| Layer | Tool | Cadence |

|---|---|---|

| Dependencies (SCA) | Snyk Open Source | Every pull request, plus daily on `main` |

| Static analysis (SAST) | Semgrep + GitHub CodeQL | Every pull request |

| Container images | Amazon ECR enhanced scanning (Inspector) | On push, plus continuous rescan |

| Infrastructure | AWS Inspector, AWS Security Hub | Continuous |

| IaC | C

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[2] vulnerability-management-policy — 4. Penetration testing — relevance 0.57

4. Penetration testing

An independent penetration test is commissioned **annually** at minimum, and additionally before any significant architectural change. The most recent was performed by Include Security from 3 to 14 February 2026 (engagement INSEC-2026-0219). See the Penetration Test Executive Summary (KD-SEC-007).

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[3] vulnerability-management-policy — Vulnerability Management Policy — relevance 0.55

Vulnerability Management Policy

Document ID: KD-SEC-006 · **Version:** 3.3 · **Owner:** Dana Whitfield, VP Engineering

Approved: 22 January 2026 · **Next review:** 22 January 2027

Maps to: SOC 2 CC7.1, CC7.2 · ISO 27001:2022 A.8.8

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[4] vulnerability-management-policy — 5. Responsible disclosure — relevance 0.54

5. Responsible disclosure

Kestrel publishes a security contact at `kestreldata.com/.well-known/security.txt` and commits to acknowledging reports within 2 business days. Researchers acting in good faith under the published policy will not be pursued legally.

Kestrel does not currently operate a paid bug bounty programme. Reports are handled through the responsible disclosure process above

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[5] vulnerability-management-policy — 1. Remediation SLAs — relevance 0.52

1. Remediation SLAs

Severity is assigned from CVSS v3.1 base score, adjusted for exploitability and exposure. Internet-facing findings are escalated one level.

| Severity | CVSS | Remediation SLA | Measured 2025 compliance |

|---|---|---|

| Critical | 9.0-10.0 | **7 days** | 100% (11 of 11) |

| High | 7.0-8.9 | **30 days** | 96% (74 of 77) |

| Medium | 4.0-6.9 | **90 days** | 91% |

|

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

206. Do you use customer content to train machine learning models?

legal · Q206 · Vendor Security Review row 207

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

207. Are manual production console changes permitted? If not, describe compensating controls.

engineering · Q207 · Vendor Security Review row 208

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

208. What is your Recovery Time Objective?

engineering · Q208 · Vendor Security Review row 209

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

209. How do you support customer responses to data subject access requests?

legal · Q209 · Vendor Security Review row 210

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (8)

[1] data-subject-rights-procedure — Data Subject Rights Procedure — relevance 0.74

Data Subject Rights Procedure

****Document ID:**** KD-LEG-007 · ****Version:**** 2.3 · ****Owner:**** Priya Raghunathan, DPO

****Approved:**** 20 January 2026 · ****Next review:**** 20 January 2027

****Maps to:**** GDPR Articles 12, 15–22, 28(3)(e) · CCPA/CPRA §1798.100–130

gs://attestor-505506-corpus/legal/data-subject-rights-procedure.txt

[2] data-subject-rights-procedure — 9. Records — relevance 0.68

9. Records

Every request, its route, and its resolution date are recorded in the DSR register held by the DPO and retained for three years. The register is available to auditors and, in redacted form, to customers exercising their audit rights under the DPA.

gs://attestor-505506-corpus/legal/data-subject-rights-procedure.txt

[3] data-subject-rights-procedure — 2. Assisting customers as processor — relevance 0.67

2. Assisting customers as processor

****Kestrel commits to assist a customer with a data subject request within 5 business days of a written request****, which is the commitment in the DPA (KD-LEG-001 §6). Assistance means one of three things:

1. Pointing the customer at the self-service tooling that lets them do it themselves, which is the fastest route and covers the majority of requests;

2. Pro

gs://attestor-505506-corpus/legal/data-subject-rights-procedure.txt

[4] data-processing-agreement — 6. Data subject rights — relevance 0.66

6. Data subject rights

Kestrel provides self-service functionality allowing Customer to access, correct, export, and delete Personal Data within the Service. Where a data subject contacts Kestrel directly, Kestrel refers them to Customer and does not respond substantively, unless legally obliged to do so.

Where the Service functionality is insufficient, Kestrel assists Customer within ****10**

gs://attestor-505506-corpus/legal/data-processing-agreement.txt

[5] government-requests-and-transparency-report — 2. How a request is handled — relevance 0.66

2. How a request is handled

1. **Log.** The request is recorded in the government request register on the day of receipt, with the requesting authority, the legal instrument, and the data sought.
2. **Validate.** The General Counsel, with outside counsel where warranted, assesses whether the instrument is valid, whether it is binding on Kestrel in the jurisdiction concerned, and whether i

gs://attestor-505506-corpus/legal/government-requests-and-transparency-report.txt

[6] data-subject-rights-procedure — 1. Which rights, and against whom — relevance 0.65

1. Which rights, and against whom

For customer content, Kestrel is the **processor** and the customer is the controller. A data subject who approaches Kestrel directly about customer content is redirected to the relevant customer without undue delay and, where Kestrel can identify the customer, within **3 business days**. Kestrel does not respond substantively on the controller's behalf.

For data

gs://attestor-505506-corpus/legal/data-subject-rights-procedure.txt

[7] data-subject-rights-procedure — 7. Objection, restriction, and automated decision-making — relevance 0.60

7. Objection, restriction, and automated decision-making

Objection and restriction requests concerning customer content are directed to the controller. Kestrel performs no automated decision-making producing legal or similarly significant effects, so Article 22 is not engaged; the machine learning features in the product are described in KD-SEC-019 §2.

gs://attestor-505506-corpus/legal/data-subject-rights-procedure.txt

[8] data-subject-rights-procedure — 4. Access requests (Article 15) — relevance 0.60

4. Access requests (Article 15)

Where Kestrel acts as controller, an access request is acknowledged within 5 business days and answered within **30 calendar days**, extendable by a further 60 days for complex requests with notice to the data subject. Identity is verified through the requester's registered email address plus one additional factor; where identity cannot be established, the request i

gs://attestor-505506-corpus/legal/data-subject-rights-procedure.txt

210. Which generative AI tools are approved for internal use?

security · Q210 · Vendor Security Review row 211

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

211. Can customers scope and revoke their own API credentials? Provide supporting evidence.

engineering · Q211 · Vendor Security Review row 212

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] api-and-integration-standard — 2. Customer control of API credentials — relevance 0.69

2. Customer control of API credentials

Customers create, scope, rotate, and revoke their own API credentials from the tenant administrator console, without involving Kestrel support. A credential can be limited to read-only, to specific datasets, and to a source IP allowlist. Revocation takes effect within 30 seconds across all regions.

Kestrel support cannot recover a customer API key. K

gs://attestor-505506-corporus/engineering/api-and-integration-standard.txt

[2] secrets-management-standard — 6. Customer-issued API credentials — relevance 0.63

6. Customer-issued API credentials

API keys issued to customers are stored as Argon2id hashes; Kestrel cannot recover the plaintext of a customer API key and will not do so on request. Keys are displayed once at creation. Customers can create, scope, and revoke keys through the console, and each key carries a last-used timestamp so stale keys are visible.

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

[3] api-and-integration-standard — 1. API authentication — relevance 0.60

1. API authentication

The public API at `https://api.kestreldata.com/v2` accepts two credential types:

****OAuth 2.0 bearer tokens**** issued through the client-credentials flow, valid for 60 minutes, scoped to a single tenant and to an explicit permission set. This is the recommended integration path.

****API keys**** for simple server-to-server use, presented as a bearer token, scoped the same

gs://attestor-505506-corporus/engineering/api-and-integration-standard.txt

[4] secrets-management-standard — 2. What is prohibited — relevance 0.58

2. What is prohibited

- Secrets in source code, including test fixtures, comments, and commit history.
- Secrets in environment files committed to a repository.
- Secrets in CI logs, container image layers, or Terraform state in plaintext.
- Long-lived static AWS access keys. The last was decommissioned 17 November 2024, and creation of a new one triggers an hourly detection that pages the owner

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

[5] api-and-integration-standard — 7. Versioning and deprecation — relevance 0.56

7. Versioning and deprecation

The API is versioned in the path (`/v1`, `/v2`). Backwards-incompatible changes are made only in a new version.

****The deprecation policy is 12 months' notice**** for a whole API version and ****90 days' notice**** for an individual endpoint or field, delivered by email to tenant administrators, by a `Deprecation` and `Sunset` response header, and on the developer changelog

gs://attestor-505506-corporus/engineering/api-and-integration-standard.txt

212. Provide your measured median access revocation time for the last 12 months.

security · Q212 · Vendor Security Review row 213

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

213. Can customers scope and revoke their own API credentials?

security · Q213 · Vendor Security Review row 214

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] access-control-standard — 3. Role-based access — relevance 0.64

3. Role-based access

Access is granted to Okta groups, never to individuals. There are 41 defined roles, each mapping to a documented entitlement set in the Access Matrix (`SEC-GOV/access-matrix`),

which is the authoritative record reviewed during audit. Standing production access is limited to 11 named Site Reliability Engineers. All other production access is just-in-time.

gs://attestor-505506-corporus/security/access-control-standard.txt

[2] information-security-policy — 7. Access control — relevance 0.60

7. Access control

Access follows least privilege and is governed by the Access Control Standard (KD-SEC-002). Identity is federated through Okta with SAML 2.0. Hardware-backed multi-factor authentication (WebAuthn / FIDO2 security keys) is mandatory for all staff; SMS and TOTP were retired as authentication factors on 30 June 2025.

Production access requires a documented business justification, e

gs://attestor-505506-corporus/security/information-security-policy.txt

[3] pen-test-executive-summary — 2. Methodology — relevance 0.59

2. Methodology

Grey-box testing against OWASP ASVS 4.0 Level 2 and the OWASP API Security Top 10. Testers were given standard-tier and admin-tier credentials for each seeded tenant plus API documentation. 74 person-hours across two testers.

gs://attestor-505506-corporus/security/pen-test-executive-summary.txt

[4] access-control-standard — 8. Service accounts and machine identity — relevance 0.59

8. Service accounts and machine identity

Workloads authenticate using short-lived credentials: AWS IAM Roles for Service Accounts (IRSA) in EKS, and Workload Identity Federation for GCP components. Long-lived static access keys are prohibited; the last was decommissioned on 17 November 2024. Automated detection for newly created static keys runs hourly and pages the on-call SRE.

gs://attestor-505506-corporus/security/access-control-standard.txt

[5] access-control-standard — 1. Identity provider — relevance 0.58

1. Identity provider

All Kestrel Data systems authenticate through Okta (tenant `kestreldata.okta.com`). Local accounts on production systems are prohibited except for two documented break-glass accounts held in a sealed 1Password vault, whose use triggers a PagerDuty alert to the CISO. Both break-glass credentials were last rotated on 3 January 2026 and last used on 14 August 2025 during the

gs://attestor-505506-corporus/security/access-control-standard.txt

214. Do you offer Canadian or Australian data residency?

legal · Q214 · Vendor Security Review row 215

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

215. Do you perform automated decision-making with legal or significant effects?

legal · Q215 · Vendor Security Review row 216

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

216. Describe your break-glass access procedure.

security · Q216 · Vendor Security Review row 217

Quarantined: Model Armor blocked this question.

Release status: No — quarantined by the guardrail · confidence low · drafted by ArmorGuard

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

217. Are you controller or processor for customer data?

legal · Q217 · Vendor Security Review row 218

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

218. Provide the name and contact details of your primary security contact.

security · Q218 · Vendor Security Review row 219

Quarantined: Model Armor blocked this question.

Release status: No — quarantined by the guardrail · confidence low · drafted by ArmorGuard

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

219. Which Trust Services Criteria are in scope for your SOC 2 report?

security · Q219 · Vendor Security Review row 220

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

220. How many BAAs are currently executed?

legal · Q220 · Vendor Security Review row 221

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

221. How is cloud provider concentration risk managed?

engineering · Q221 · Vendor Security Review row 222

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

222. What is your committed customer notification window for a personal data breach?

legal · Q222 · Vendor Security Review row 223

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

223. How frequently do you test restoration from backup?

engineering · Q223 · Vendor Security Review row 224

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] backup-restore-procedure — 4. Test results — relevance 0.73

4. Test results

Restore is tested **quarterly**, and the test is a real restore, not a backup-listing check.

Quarter	Date	Duration	Assertions	Outcome
---	---	---	---	---
Q1 2026	17 Jan 2026	2h 41m	1,240 / 1,240	Pass
Q4 2025	11 Oct 2025	3h 02m	1,238 / 1,240	Pass, 2 known-stale fixtures corrected
Q3 2025	19 Jul 2025	3h 20m	1,240 / 1,240	Pass

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[2] backup-restore-procedure — 5. Tenant-scoped restore — relevance 0.63

5. Tenant-scoped restore

A single customer can be restored without affecting others, by restoring to an isolated account and exporting that tenant rows back. This was exercised once in production, on 22 September 2025, at a customer request following an erroneous bulk delete on their side. Time to complete was 5 hours 10 minutes.

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[3] backup-restore-procedure — 3. Restore procedure — relevance 0.61

3. Restore procedure

1. Declare the restore scope: point in time, and whether tenant-scoped or full.
2. Provision an isolated restore account from the Terraform module `restore-target`.
3. Restore the RDS snapshot or PITR target into the isolated account.
4. Run the integrity suite: 1,240 assertions covering row counts, referential integrity, tenant isolation invariants, and known-value spo

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[4] backup-restore-procedure — Backup and Restore Procedure — relevance 0.60

Backup and Restore Procedure

Document ID: KD-ENG-004 · **Version:** 2.5 · **Owner:** Sofia Brenner, Head of IT
Approved: 29 January 2026 · **Maps to:** SOC 2 A1.2 · ISO 27001:2022 A.8.13

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[5] backup-restore-procedure — 1. What is backed up — relevance 0.59

1. What is backed up

Asset	Method	Frequency	Retention
---	---	---	---
RDS PostgreSQL	Automated snapshots + WAL archiving (PITR)	Continuous	35 days
RDS logical dump	`pg_dump` to S3, encrypted with a separate CMK	Daily 03:00 UTC	90 days
S3 objects	Versioning + cross-region replication	Continuous	90 days for non-current versions
Snowflake	Time Tr		

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

224. Are workloads deployed with least-privilege container security contexts?

security · Q224 · Vendor Security Review row 225

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (10)

[1] cloud-security-posture-standard — 1. Account structure and guardrails — relevance 0.61

1. Account structure and guardrails

Kestrel runs an AWS Organization with six accounts and a dedicated management account that holds no workloads. **Organisation-level Service Control Policies enforce security configuration centrally**, so a misconfiguration in a member account is refused by the platform rather than caught later by a report. The enforced SCPs are:


```
| SCP | Effect |  
|---|---|  
| de
```

gs://attestor-505506-corporus/security/cloud-security-posture-standard.txt

[2] network-security-standard — 7. Container security — relevance 0.59

7. Container security

Workloads run on EKS with:

- * non-root user enforced (`runAsNonRoot: true`) and read-only root filesystems;
- * all Linux capabilities dropped except `NET\_BIND\_SERVICE`;
- * Pod Security Admission in `restricted` mode at the namespace level, which rejects a non-conforming workload at admission rather than reporting it later;
- * network policies denying pod-to-pod traffic by default

gs://attestor-505506-corporus/security/network-security-standard.txt

[3] cloud-security-posture-standard — 7. Cloud identity — relevance 0.58

7. Cloud identity

Human access to AWS is federated from Okta through IAM Identity Center; there are **no** IAM users with long-lived access keys in any account, and the SCP set prevents their creation. Workloads use IAM Roles for Service Accounts. The last static access key in the estate was decommissioned on 17 November 2024.

gs://attestor-505506-corporus/security/cloud-security-posture-standard.txt

[4] cloud-security-posture-standard — Cloud Security Posture and Configuration Standard — relevance 0.58

Cloud Security Posture and Configuration Standard

Document ID: KD-SEC-017 · **Version:** 1.8 · **Owner:** Dana Whitfield, VP Engineering
Approved: 29 January 2026 · **Next review:** 29 January 2027
Maps to: SOC 2 CC6.1, CC7.1, CC8.1 · ISO 27001:2022 A.8.9, A.8.19, A.8.32

gs://attestor-505506-corporus/security/cloud-security-posture-standard.txt

[5] cloud-security-posture-standard — 8. Logging and evidence — relevance 0.57

8. Logging and evidence

CloudTrail (all regions, all accounts), VPC flow logs, GuardDuty findings, and Config history are delivered to a dedicated `kd-security` account that no engineering role can write to, with object lock set to 400 days. This is the arrangement that makes the audit trail defensible: the accounts that generate the evidence cannot alter it.

gs://attestor-505506-corporus/security/cloud-security-posture-standard.txt

[6] cloud-security-posture-standard — 5. Vulnerability and patch posture of cloud compute — relevance 0.57

5. Vulnerability and patch posture of cloud compute

Production compute nodes are immutable: they are replaced, never patched in place. The node group is recycled on a rolling basis so that **no** production compute node is older than 30 days; the measured maximum node age during 2025 was 27 days. Container base images are rebuilt nightly from upstream and redeployed if the digest changes.

Operati

gs://attestor-505506-corporus/security/cloud-security-posture-standard.txt

[7] network-security-standard — 3. Segmentation — relevance 0.53

3. Segmentation

Each environment is a separate AWS account inside the AWS Organization (`kd-prod-us`, `kd-prod-eu`, `kd-staging`, `kd-dev`, `kd-security`, `kd-shared-services`). There is **no** VPC peering and no transit gateway route between production and non-production; the boundary is an account boundary, not a firewall rule that can be edited.

Within a production VPC there are three subnet t

gs://attestor-505506-corporus/security/network-security-standard.txt

[8] network-security-standard — 5. Egress — relevance 0.52

5. Egress

Production workloads egress through NAT gateways with a domain allowlist enforced by AWS Network Firewall. The allowlist contains 23 destinations, each with a named owner and a business justification. An attempted connection to a destination outside the allowlist is blocked and alerted; 61 such alerts in 2025 were all traced to dependency mirrors being retired upstream.

gs://attestor-505506-corporus/security/network-security-standard.txt

[9] network-security-standard — 4. Inbound rules — relevance 0.50

4. Inbound rules

****There are no unrestricted inbound rules (`0.0.0.0/0`) in any production security group other than ports 80 and 443 on the load balancer security group, which are themselves restricted to Cloudflare ranges.**** SSH ingress is closed entirely; administrative access is through AWS Systems Manager Session Manager, which requires an IAM identity and produces a recorded session.

Config

gs://attestor-505506-corporus/security/network-security-standard.txt

[10] network-security-standard — Network Security Standard — relevance 0.49

Network Security Standard

****Document ID:**** KD-SEC-016 · ****Version:**** 2.0 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 5 February 2026 · ****Next review:**** 5 February 2027

****Maps to:**** SOC 2 CC6.6, CC6.7, CC7.1 · ISO 27001:2022 A.8.20, A.8.21, A.8.22, A.8.23

gs://attestor-505506-corporus/security/network-security-standard.txt

225. How long do elevated production access grants remain valid?

security · Q225 · Vendor Security Review row 226

Elevated production access grants expire automatically after 8 hours. Requests for just-in-time production access require a written business justification, a linked incident or change ticket, and approval from a second engineer holding the SRE role, with self-approval blocked. All session activity is recorded via AWS Systems Manager Session Manager and sent to an immutable log archive (Access Control Standard, Section 4: Just-in-time production access).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] access-control-standard — 4. Just-in-time production access — relevance 0.65

4. Just-in-time production access

Engineers request elevated production access through the `/access` Slack workflow. A request requires a written business justification, a linked incident or change ticket, and approval from a second engineer holding the SRE role. Self-approval is blocked.

Granted access expires automatically after ****8 hours****. All commands executed in an elevated session are

gs://attestor-505506-corporus/security/access-control-standard.txt

[2] access-control-standard — 3. Role-based access — relevance 0.62

3. Role-based access

Access is granted to Okta groups, never to individuals. There are 41 defined roles, each mapping to a documented entitlement set in the Access Matrix (`SEC-GOV/access-matrix`), which is the authoritative record reviewed during audit. Standing production access is limited to 11 named Site Reliability Engineers. All other production access is just-in-time.

gs://attestor-505506-corporus/security/access-control-standard.txt

[3] access-control-standard — 7. Access reviews — relevance 0.59

7. Access reviews

Quarterly user access reviews cover all production systems, the AWS Organization,

Snowflake, GitHub, and Okta itself. Reviews are performed by the system owner and attested in Vanta. The Q4 2025 review completed on 12 January 2026 and removed 23 entitlements, of which 9 were stale contractor accesses.

gs://attestor-505506-corporus/security/access-control-standard.txt

[4] access-control-standard — 8. Service accounts and machine identity — relevance 0.58

8. Service accounts and machine identity

Workloads authenticate using short-lived credentials: AWS IAM Roles for Service Accounts (IRSA) in EKS, and Workload Identity Federation for GCP components. Long-lived static access keys are prohibited; the last was decommissioned on 17 November 2024. Automated detection for newly created static keys runs hourly and pages the on-call SRE.

gs://attestor-505506-corporus/security/access-control-standard.txt

[5] access-control-standard — 6. Joiners, movers, leavers — relevance 0.57

6. Joiners, movers, leavers

Joiners are provisioned via Okta Lifecycle Management from Rippling (HRIS); no access is granted before the background check clears. Movers have entitlements recalculated on role change, with the previous role revoked within 1 business day. Leavers have all access revoked automatically on the HRIS termination event: the target is 1 hour, and the measured median for

gs://attestor-505506-corporus/security/access-control-standard.txt

226. For each applicable system: Describe your approach to environmental sustainability and carbon reporting.

unassigned · Q226 · Vendor Security Review row 227

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

227. For each applicable system: Do you act as a service provider under the CCPA?

legal · Q227 · Vendor Security Review row 228

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

228. What is your remediation SLA for High severity vulnerabilities?

security · Q228 · Vendor Security Review row 229

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

229. Describe the shared responsibility model between you and your customers.

security · Q229 · Vendor Security Review row 230

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (16)

[1] pen-test-executive-summary — 2. Methodology — relevance 0.55

2. Methodology

Grey-box testing against OWASP ASVS 4.0 Level 2 and the OWASP API Security Top 10.

Testers were given standard-tier and admin-tier credentials for each seeded tenant plus API documentation. 74 person-hours across two testers.

gs://attestor-505506-corporus/security/pen-test-executive-summary.txt

[2] pen-test-executive-summary — 3. Findings summary — relevance 0.55

3. Findings summary
| Severity | Found | Remediated | Retest verified |
|---|---|---|---|
| Critical | 0 | - | - |
| High | 1 | 1 | 18 March 2026 |
| Medium | 4 | 4 | 18 March 2026 |
| Low | 7 | 5 | 18 March 2026 |
| Informational | 9 | Accepted / tracked | - |

****No cross-tenant data access was achieved.**** Tenant isolation held under every tested condition, including direct object refere

gs://attestor-505506-corporus/security/pen-test-executive-summary.txt

[3] personnel-security-and-training — 7. How security responsibilities are communicated — relevance 0.54

7. How security responsibilities are communicated
Responsibilities are communicated four ways, deliberately overlapping: the offer pack and onboarding session; the annual policy acknowledgement; a standing item in the monthly all-hands delivered by the CISO; and the `#security` Slack channel, which is the documented route for reporting anything suspicious and is monitored during business hours wit

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

[4] pen-test-executive-summary — 1. Scope — relevance 0.53

1. Scope
- Kestrel Insight web application (`app.kestreldata.com`), authenticated and unauthenticated surfaces
- Public REST API v2 (`api.kestreldata.com`), 89 endpoints
- Multi-tenant isolation testing across 3 seeded tenant accounts
- AWS cloud configuration review (IAM, S3, VPC, EKS)
- Authentication and session management, including the Okta SAML integration

Out of scope: physical se

gs://attestor-505506-corporus/security/pen-test-executive-summary.txt

[5] personnel-security-and-training — 3. Acceptable use and policy acknowledgement — relevance 0.52

3. Acceptable use and policy acknowledgement
Personnel acknowledge the Acceptable Use Policy (KD-SEC-005) and this standard at onboarding and annually thereafter. Acknowledgement is tracked in Vanta; the 2025 annual cycle closed on 30 November 2025 at ****100%**** completion across 187 employees and 24 contractors.

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

[6] personnel-security-and-training — 2. Confidentiality obligations — relevance 0.52

2. Confidentiality obligations
All personnel sign a confidentiality agreement as a condition of employment or engagement. ****The confidentiality obligation survives termination indefinitely for customer data and for five years for other Kestrel confidential information.**** Contractors sign the same obligation through their engagement contract, and the obligation flows down to any of their own person

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

[7] physical-and-environmental-security — 7. Equipment removal — relevance 0.52

7. Equipment removal
Company equipment may be removed from the office freely, as befits a remote-first company. Every device is enrolled in Kandji, encrypted, and remotely wipeable. Loss or theft must be reported to `#security` within 4 hours; the device is wiped remotely and the event

recorded as a security incident. Three devices were reported lost or stolen in 2025, all wiped successfully, none

gs://attestor-505506-corporate-security/physical-and-environmental-security.txt

[8] physical-and-environmental-security — 5. Home working — relevance 0.51

5. Home working

Personnel working from home are required to use a Kestrel-managed device with full-disk encryption, to avoid working on customer data in public spaces, and to use a privacy screen when travelling. Kestrel does not inspect home environments; the compensating control is that no customer data is stored locally — access is through the browser to systems inside the AWS boundary, and the

gs://attestor-505506-corporate-security/physical-and-environmental-security.txt

[9] physical-and-environmental-security — 4. Clear desk and clear screen — relevance 0.51

4. Clear desk and clear screen

Screens lock automatically after 5 minutes of inactivity, enforced by Kandji MDM policy rather than by request. Printed material classified Confidential or above must be stored in a locked cabinet when unattended and shredded on disposal via the cross-cut shredder in the suite; the office holds no long-term paper records.

gs://attestor-505506-corporate-security/physical-and-environmental-security.txt

[10] physical-and-environmental-security — 1. Production infrastructure — relevance 0.51

1. Production infrastructure

Kestrel Data operates **no owned or leased data centre**. All production infrastructure runs in AWS: `us-east-1` for the US instance and `eu-west-1` for the EU instance. Physical and environmental controls for those facilities — perimeter security, biometric access, CCTV, fire suppression, power redundancy, environmental monitoring, and media destruction — are AWS's re

gs://attestor-505506-corporate-security/physical-and-environmental-security.txt

[11] physical-and-environmental-security — Physical and Environmental Security Standard — relevance 0.50

Physical and Environmental Security Standard

Document ID: KD-SEC-014 · **Version:** 1.6 · **Owner:** Sofia Brenner, Head of IT
Approved: 12 January 2026 · **Next review:** 12 January 2027
Maps to: SOC 2 CC6.4, CC6.5 · ISO 27001:2022 A.7.1–A.7.14

gs://attestor-505506-corporate-security/physical-and-environmental-security.txt

[12] personnel-security-and-training — 8. Disciplinary process — relevance 0.50

8. Disciplinary process

Wilful violation of security policy is handled under the Kestrel disciplinary procedure and may result in termination. One formal disciplinary action was taken in 2025, relating to the storage of a customer dataset in a personal cloud drive; the data was deleted under supervision, the incident was recorded as INC-2025-0038, and the affected customer was notified within the

gs://attestor-505506-corporate-security/personnel-security-and-training.txt

[13] pen-test-executive-summary — 6. Two accepted low findings — relevance 0.49

6. Two accepted low findings

- **L6** - Username enumeration remains possible through the SAML metadata endpoint for customers using IdP-initiated flows. Accepted; mitigation would break a documented integration pattern. Tracked as RISK-2026-0004.
- **L7** - TLS 1.2 remains enabled on the legacy SFTP endpoint. Accepted until the Q3 2026 decommission. Tracked as RISK-2025-0088.

gs://attestor-505506-corporate-security/pen-test-executive-summary.txt

[14] pen-test-executive-summary — 7. Tester statement — relevance 0.49

7. Tester statement

Kestrel Data demonstrates a mature security posture for an organisation of its size. Tenant isolation is well implemented and defence in depth is evident throughout the platform. The single High finding was an availability and privacy concern rather than a

gs://attestor-505506-corporus/security/pen-test-executive-summary.txt

[15] physical-and-environmental-security — 3. Visitors — relevance 0.48

3. Visitors

Visitors sign in at the building reception, are issued a dated visitor badge, and are escorted at all times within the suite. The visitor log is retained for 12 months. No visitor is admitted to the network; guests use a segregated wireless SSID with no route to any internal or production system.

gs://attestor-505506-corporus/security/physical-and-environmental-security.txt

[16] personnel-security-and-training — Personnel Security and Security Training Programme — relevance 0.48

Personnel Security and Security Training Programme

Document ID: KD-SEC-013 · **Version:** 2.1 · **Owner:** Sofia Brenner, Head of IT

Approved: 22 January 2026 · **Next review:** 22 January 2027

Maps to: SOC 2 CC1.1, CC1.4, CC2.1, CC6.2 · ISO 27001:2022 A.6.1, A.6.2, A.6.3, A.6.6

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

230. Describe your rollback capability and typical rollback time.

engineering · Q230 · Vendor Security Review row 231

Deployments follow a continuous and progressive rollout process with automated rollback capabilities. Production releases use a canary deployment strategy: traffic is routed progressively at 5% for 15 minutes, then 25%, and finally 100%, with automated rollback triggered upon any error-rate or latency regression (`sdlc-policy`, Section 6, "Release"). In 2025, the mean time to restore across deployments was 18 minutes (`sdlc-policy`, Section 6, "Release"). Additionally, standard change management procedures require Normal changes to maintain a written rollback plan and ensure database schema migrations are backward-compatible for at least one release cycle, enabling rollbacks to execute without requiring data migrations (`change-management-procedure`, Section 2, "Normal change requirements").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (13)

[1] backup-restore-procedure — 4. Test results — relevance 0.66

4. Test results

Restore is tested **quarterly**, and the test is a real restore, not a backup-listing check.

Quarter	Date	Duration	Assertions	Outcome
Q1 2026	17 Jan 2026	2h 41m	1,240 / 1,240	Pass
Q4 2025	11 Oct 2025	3h 02m	1,238 / 1,240	Pass, 2 known-stale fixtures corrected
Q3 2025	19 Jul 2025	3h 20m	1,240 / 1,240	Pass

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[2] backup-restore-procedure — 5. Tenant-scoped restore — relevance 0.66

5. Tenant-scoped restore

A single customer can be restored without affecting others, by restoring to an isolated account and exporting that tenant rows back. This was exercised once in production, on 22 September 2025, at a customer request following an erroneous bulk delete on their side. Time to complete was 5 hours 10 minutes.

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[3] sdlc-policy — 6. Release — relevance 0.62

6. Release

Releases are continuous: merge to `main` triggers a deployment to staging, an automated verification suite, and then a progressive rollout to production. Rollout is canary-based: 5% of traffic for 15 minutes, then 25%, then 100%, with automatic rollback on error-rate or latency regression.

Median lead time from merge to production in 2025 was ****34 minutes****. Change failure rate w

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[4] backup-restore-procedure — 3. Restore procedure — relevance 0.59

3. Restore procedure

1. Declare the restore scope: point in time, and whether tenant-scoped or full.
2. Provision an isolated restore account from the Terraform module `restore-target`.
3. Restore the RDS snapshot or PITR target into the isolated account.
4. Run the integrity suite: 1,240 assertions covering row counts, referential integrity, tenant isolation invariants, and known-value spo

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[5] backup-restore-procedure — 1. What is backed up — relevance 0.59

1. What is backed up

| Asset | Method | Frequency | Retention |

|---|---|---|---|

| RDS PostgreSQL | Automated snapshots + WAL archiving (PITR) | Continuous | ****35 days**** |

| RDS logical dump | `pg\_dump` to S3, encrypted with a separate CMK | Daily 03:00 UTC | 90 days |

| S3 objects | Versioning + cross-region replication | Continuous | 90 days for non-current versions |

| Snowflake | Time Tr

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[6] sdlc-policy — 7. Separation of duties — relevance 0.59

7. Separation of duties

Engineers cannot deploy their own change to production without the automated pipeline: no human has the ability to push a container image to the production registry directly. The deployment role is held by the CI service identity, which authenticates through OIDC and holds no long-lived credentials.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[7] change-management-procedure — 2. Normal change requirements — relevance 0.58

2. Normal change requirements

A Normal change additionally requires a written rollback plan, a customer-impact assessment, and sign-off from the Change Advisory group (VP Engineering plus one SRE). Schema migrations must be backward compatible for at least one release, so that a rollback does not require a data migration.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[8] sdlc-policy — 3. Testing requirements — relevance 0.55

3. Testing requirements

- Unit test coverage gate at ****80%**** on changed lines, enforced in CI.
- Integration tests run against ephemeral infrastructure provisioned per pull request.
- Tenant isolation tests run on every build: a suite of 84 assertions attempting cross-tenant reads through every public API surface.
- Load tests before any release expected to change the performance profile.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[9] change-management-procedure — 1. Change classes — relevance 0.55

1. Change classes

| Class | Definition | Approval | Example |

|---|---|---|---|

| ****Standard**** | Pre-approved, low risk, automated | PR review + CI | Application code, config change through IaC |

| ****Normal**** | Material risk or customer-visible | PR review + Change Advisory sign-off | Schema migration, dependency major version |

| ****Emergency**** | Fixing an active SEV1/SEV2 | Retrospective with

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[10] sdlc-policy — 4. Security in the pipeline — relevance 0.55

4. Security in the pipeline

Static analysis (Semgrep, CodeQL), dependency scanning (Snyk), IaC scanning (Checkov), and secret scanning (Gitleaks pre-commit plus GitHub push protection) all run on every pull request. A Critical or High dependency finding blocks the merge.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[11] change-management-procedure — 3. Emergency changes — relevance 0.54

3. Emergency changes

An Emergency change may bypass the Change Advisory step but never bypasses code review or CI. The Incident Commander authorises it, and a retrospective record is filed within one business day covering what changed, why the normal path was bypassed, and whether the change should be reworked.

All 9 Emergency changes in 2025 have completed retrospectives on file.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[12] change-management-procedure — 5. Database changes — relevance 0.54

5. Database changes

Migrations run through Atlas with a plan-and-approve step. Destructive operations (column drop, table drop) require a two-phase deployment separated by at least one release: the column is first stopped being read, then dropped in a later release.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[13] sdlc-policy — 1. Branching and review — relevance 0.53

1. Branching and review

`main` is protected and always releasable. All work happens on short-lived branches merged by pull request. `main` requires:

- At least **one approving review** from an engineer other than the author. Self-approval is blocked at the platform level.
- Two approvals for changes touching authentication, authorisation, tenant isolation, or cryptography. These paths are

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

231. Do you subscribe to threat intelligence feeds? If not, describe compensating controls.

security · Q231 · Vendor Security Review row 232

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

232. Provide your ISO 27001 certificate and its scope statement.

security · Q232 · Vendor Security Review row 233

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

233. Are passwords checked against known-breached credential lists?

security · Q233 · Vendor Security Review row 234

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

234. What is your notification window for confirmed unauthorised access to production data? If not, describe compensating controls.

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

235. Describe your multi-region architecture.

engineering · Q235 · Vendor Security Review row 236

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

236. Provide your measured availability for the last 3 years.

engineering · Q236 · Vendor Security Review row 237

Kestrel's measured availability over the last three years is as follows: * **2025:** 99.97% measured availability, with 0 months below 99.9% and no service credits issued. * **2024:** 99.94% measured availability, with 1 month below 99.9% (March at 99.87%) and 1 customer credit issued. * **2023:** 99.91% measured availability, with 1 month below 99.9% (August at 99.82%) and 3 customer credits issued. **Source Citation:** * `availability-sla`, Section 5: *Historical performance*

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] availability-sla — 2. Definitions — relevance 0.72

2. Definitions

****Uptime**** is the percentage of minutes in a calendar month during which the Service is Available, calculated as:

$$\text{Uptime \%} = ((\text{Total Minutes} - \text{Downtime Minutes}) / \text{Total Minutes}) \times 100$$

****Downtime**** is any minute during which all requests to the production API from the external monitoring network return a 5xx error or fail to connect. Measurement is by independent third-p

gs://attestor-505506-corpus/engineering/availability-sla.txt

[2] availability-sla — 5. Historical performance — relevance 0.68

5. Historical performance

| Year | Measured availability | Months below 99.9% | Credits issued |

| --|---|---|---|

| 2025 | 99.97% | 0 | 0 |

| 2024 | 99.94% | 1 (March, 99.87%) | 1 customer, 10% |

| 2023 | 99.91% | 1 (August, 99.82%) | 3 customers, 10% |

gs://attestor-505506-corpus/engineering/availability-sla.txt

[3] service-operations-and-support — 6. Monitoring and alerting — relevance 0.66

6. Monitoring and alerting

Datadog holds infrastructure metrics, application performance monitoring, and synthetic checks running every 60 seconds from five geographic locations against both instances. Alerts are symptom-based — error rate, latency percentile, saturation, and synthetic failure — rather than cause-based, so a novel failure still pages someone.

Uptime is measured from the synthetic

gs://attestor-505506-corpus/engineering/service-operations-and-support.txt

[4] availability-sla — 1. Commitment — relevance 0.65

1. Commitment

Kestrel commits to ****99.9% monthly uptime**** for the Kestrel Insight platform on the

Enterprise and Growth tiers.

The ****Starter tier carries no availability commitment.**** It is offered on a reasonable efforts basis and is excluded from service credits.

gs://attestor-505506-corporus/engineering/availability-sla.txt

[5] service-operations-and-support — 8. Capacity and performance — relevance 0.64

8. Capacity and performance

Capacity is reviewed monthly against a 90-day forecast. Autoscaling handles ordinary variation; the review exists for the changes autoscaling cannot absorb, such as a large tenant onboarding. Two capacity increases were made ahead of demand in 2025, neither triggered by a saturation alert.

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

237. Do Kestrel personnel routinely access customer production data?

legal · Q237 · Vendor Security Review row 238

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

238. Do you maintain cyber liability insurance, and what are the coverage limits?

legal · Q238 · Vendor Security Review row 239

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

239. What is your scheduled maintenance window?

engineering · Q239 · Vendor Security Review row 240

Our standard scheduled maintenance window is Sundays from 06:00 to 10:00 UTC (service-operations-and-support, "2. Scheduled maintenance"). Most routine changes do not require using this window, as deployments are rolling and zero-downtime. When scheduled maintenance is expected to be customer-affecting, customers receive at least 7 days' advance notice (and 30 days' notice if the change requires customer action) via email to tenant administrators and on our status page (service-operations-and-support, "2. Scheduled maintenance"). Under our Availability SLA, scheduled maintenance is capped at 4 hours per month (availability-sla, "3. Exclusions").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (5)

[1] service-operations-and-support — 2. Scheduled maintenance — relevance 0.73

2. Scheduled maintenance

The standard maintenance window is ****Sundays 06:00–10:00 UTC****. Most changes do not use it: deployments are rolling and zero-downtime, and 2025 saw 1,412 production deployments with no customer-visible downtime.

****Customers receive at least 7 days' notice of scheduled maintenance expected to be customer-affecting**, and 30 days' notice where the change requires customer a**

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[2] availability-sla — 3. Exclusions — relevance 0.67

3. Exclusions

Downtime does not include unavailability caused by:

- Scheduled maintenance, notified at least 7 days in advance, in the window Sundays 04:00-06:00 UTC, capped at 4 hours per month.

- Emergency maintenance to address a security vulnerability, notified as soon as practicable.
- Customer configuration, customer code, or customer exceeding documented rate limits.
- Failure o

gs://attestor-505506-corporus/engineering/availability-sla.txt

[3] service-operations-and-support — Service Operations, Maintenance and Support — relevance 0.63

Service Operations, Maintenance and Support

Document ID: KD-ENG-009 · **Version:** 2.2 · **Owner:** Dana Whitfield, VP Engineering

Approved: 23 January 2026 · **Next review:** 23 January 2027

Maps to: SOC 2 A1.1, A1.2, CC7.3, CC8.1 · ISO 27001:2022 A.5.29, A.8.6, A.8.32

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[4] availability-sla — 6. Support response targets — relevance 0.61

6. Support response targets

Support targets are separate from this SLA and are not credit-bearing.

| Severity | First response | Coverage |

|---|---|---|

| Urgent (production down) | 1 hour | 24 x 7 |

| High (major feature impaired) | 4 business hours | Business hours |

| Normal | 1 business day | Business hours |

| Low | 3 business days | Business hours |

Business hours are 08:00-18:00

gs://attestor-505506-corporus/engineering/availability-sla.txt

[5] availability-sla — Availability Service Level Agreement — relevance 0.58

Availability Service Level Agreement

Document ID: KD-ENG-007 · **Version:** 3.0 · **Owner:** Aaron Feldstein, General Counsel

Effective: 1 January 2026 · Forms part of the Master Subscription Agreement

gs://attestor-505506-corporus/engineering/availability-sla.txt

240. Describe your vendor risk management programme and tiering approach.

security · Q240 · Vendor Security Review row 241

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

241. Are infrastructure configurations managed as code?

engineering · Q241 · Vendor Security Review row 242

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

242. Provide evidence of your most recent user access review.

security · Q242 · Vendor Security Review row 243

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

243. Describe your key rotation policy and frequency.

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

244. Please confirm: Do you accept SOC 2 and ISO 27001 reports in place of a customer audit?

legal · Q244 · Vendor Security Review row 245

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

245. Provide the technical and organisational measures annexed to your DPA.

legal · Q245 · Vendor Security Review row 246

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (8)

[1] dpa-annex-2-technical-measures — DPA Annex 2 - Technical and Organisational Measures — relevance 0.76

DPA Annex 2 - Technical and Organisational Measures

****Document ID:**** KD-LEG-009 · ****Version:**** 4.0 · ****Owner:**** Marcus Oyelaran, CISO

****Effective:**** 1 February 2026 · Annex to the DPA (KD-LEG-001)

****Maps to:**** GDPR Art. 32

Measures are described at a level that allows a controller to assess adequacy under Art. 32 without exposing information that would itself create risk.

gs://attestor-505506-corpus/legal/dpa-annex-2-technical-measures.txt

[2] dpa-annex-2-technical-measures — 4. Regular testing and evaluation (Art. 32(1)(d)) — relevance 0.66

4. Regular testing and evaluation (Art. 32(1)(d))

| Activity | Frequency | Last performed |

|---|---|---|

| Independent penetration test | Annual minimum | 3-14 February 2026 |

| SOC 2 Type II audit | Annual | Period ended 31 December 2025 |

| ISO 27001 surveillance audit | Annual | 22 September 2025 |

| Disaster recovery restore test | Quarterly | 17 January 2026 |

| User access review | Qu

gs://attestor-505506-corpus/legal/dpa-annex-2-technical-measures.txt

[3] data-processing-agreement — 4. Security — relevance 0.65

4. Security

Kestrel implements the technical and organisational measures set out in ****Annex 2****, including encryption at rest (AES-256-GCM) and in transit (TLS 1.3), least-privilege access control with mandatory hardware MFA, and continuous monitoring.

gs://attestor-505506-corpus/legal/data-processing-agreement.txt

[4] dpa-annex-2-technical-measures — 5. Organisational measures — relevance 0.65

5. Organisational measures

Security governance through a monthly Security Council with a direct board reporting line; background screening before start date; confidentiality obligations surviving employment; annual security awareness training at 100% completion; documented incident response with a trained IC rota; vendor risk management with tiered diligence.

gs://attestor-505506-corpus/legal/dpa-annex-2-technical-measures.txt

[5] dpa-annex-2-technical-measures — 3. Restoring availability (Art. 32(1)(c)) — relevance 0.65

3. Restoring availability (Art. 32(1)(c))
RTO 4 hours, RPO 15 minutes. The 17 January 2026 full failover exercise achieved
2 hours 41 minutes and 4 minutes respectively. Results are documented in KD-SEC-010.

gs://attestor-505506-corporus/legal/dpa-annex-2-technical-measures.txt

[6] transfer-impact-assessment — 5. Supplementary measures relied on — relevance 0.64

5. Supplementary measures relied on
Technical:

1. **Data residency by default** — EU customer content, including backups and the replicated log ship, never leaves `eu-west-1`.
2. **Encryption in transit** — TLS 1.3 (1.2 minimum) on every hop, including between Kestrel and each sub-processor.
3. **Encryption at rest** — AES-256-GCM with keys in AWS KMS. Keys for the EU instance are held i

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

[7] dpa-annex-2-technical-measures — 2. Confidentiality, integrity, availability, resilience (Art. 32(1)(b)) — relevance 0.63

2. Confidentiality, integrity, availability, resilience (Art. 32(1)(b))
Confidentiality. Least-privilege access via Okta with mandatory hardware MFA; just-in-time production elevation expiring in 8 hours; tenant isolation verified by independent penetration testing (no cross-tenant access achieved, February 2026).

Integrity. All changes reviewed and merged through pull request with a

gs://attestor-505506-corporus/legal/dpa-annex-2-technical-measures.txt

[8] dpa-annex-2-technical-measures — 1. Pseudonymisation and encryption (Art. 32(1)(a)) — relevance 0.62

1. Pseudonymisation and encryption (Art. 32(1)(a))
Data at rest is encrypted with AES-256-GCM across RDS, S3, EBS, and Snowflake. Data in transit uses TLS 1.3 externally and mutual TLS internally within the service mesh. Application logs are pseudonymised at emission: direct identifiers are replaced with opaque `tenant\_id` and `user\_id` values before the log leaves the process.

gs://attestor-505506-corporus/legal/dpa-annex-2-technical-measures.txt

246. What controls remain the responsibility of the customer?

security · Q246 · Vendor Security Review row 247

Under Kestrel Data's shared responsibility model as detailed in the SOC 2 report, six complementary user entity controls remain the responsibility of the customer. These customer responsibilities include: * Managing user accounts and access entitlements within their Kestrel tenant * Correctly configuring Single Sign-On (SSO) integrations * Protecting API credentials issued to their organization * Reviewing their own audit logs The complete list of these controls is documented in Section 4 of our SOC 2 report (`soc2-control-matrix`, section "Complementary user entity controls").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] soc2-control-matrix — Complementary user entity controls — relevance 0.68

Complementary user entity controls

The report identifies 6 controls that remain the customer responsibility, including managing their own user accounts and entitlements within the Kestrel tenant, configuring SSO correctly, protecting API credentials issued to them, and reviewing their own audit logs. These are reproduced in full in Section 4 of the SOC 2 report.

gs://attestor-505506-corporus/security/soc2-control-matrix.txt

[2] incident-response-runbook — 8. Post-incident review — relevance 0.65

8. Post-incident review

Every SEV1 and SEV2 requires a blameless post-incident review within 5 business days, published internally, with action items tracked to closure in Jira. Reviews are shared with affected customers on request.

gs://attestor-505506-corporate/security/incident-response-runbook.txt

[3] incident-response-runbook — 2. Roles — relevance 0.62

2. Roles

The Incident Commander owns the response and is deliberately not the person fixing the problem; ICs are drawn from a rota of 6 trained staff. The Communications Lead owns customer, internal, and regulator messaging. A Scribe maintains the timeline for every SEV1 and SEV2. Subject matter experts are pulled in as needed.

gs://attestor-505506-corporate/security/incident-response-runbook.txt

[4] incident-response-runbook — 6. Evidence handling — relevance 0.61

6. Evidence handling

The IC directs preservation before remediation wherever containment allows. EBS snapshots, memory captures where feasible, and relevant log ranges are exported to a dedicated forensics S3 bucket with Object Lock in compliance mode, retention 1 year. Chain of custody is recorded in the incident ticket.

gs://attestor-505506-corporate/security/incident-response-runbook.txt

[5] soc2-control-matrix — Common Criteria — relevance 0.61

Common Criteria

Control	Description	Evidence	Test result
---------	-------------	----------	-------------

CC1.1	Board oversight of security; Audit and Risk Committee meets quarterly	Committee minutes, 4 meetings in 2025	No exceptions
-------	---	---------------------------------------	---------------

CC1.4	Security awareness training at hire and annually	Curricula completion records, 100% of active staff	No exceptions
-------	--	--	---------------

CC2.1	Internal communication of security		
-------	------------------------------------	--	--

gs://attestor-505506-corporate/security/soc2-control-matrix.txt

247. Which transfer mechanism do you rely on for transfers out of the EEA? Provide supporting evidence.

legal · Q247 · Vendor Security Review row 248

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

248. Do you offer UK-only data residency?

legal · Q248 · Vendor Security Review row 249

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

249. Is tenant isolation tested continuously?

security · Q249 · Vendor Security Review row 250

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (10)

[1] business-continuity-dr-plan — 5. Restore testing — relevance 0.61

5. Restore testing

Restore is tested **quarterly**, not merely backed up. The test restores the previous day production snapshot into an isolated account and runs a data integrity suite of 1,240 assertions. Results for the last four quarters:

Quarter	Date	Restore duration	Integrity assertions	Result
Q1 2026	17 Jan 2026	2h 41m	1,240 / 1,240	Pass

gs://attestor-505506-corporus/security/business-continuity-dr-plan.txt

[2] vulnerability-management-policy — 3. Patch management — relevance 0.60

3. Patch management

Operating system patching is handled by rebuilding immutable AMIs; instances are replaced rather than patched in place. The base image is rebuilt weekly and on any Critical CVE affecting it. Kubernetes node groups are recycled on a rolling basis with a maximum node age of ****30 days****.

Managed services (RDS, ElastiCache, EKS control plane) follow AWS maintenance windows,

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[3] cloud-security-posture-standard — 5. Vulnerability and patch posture of cloud compute — relevance 0.60

5. Vulnerability and patch posture of cloud compute

Production compute nodes are immutable: they are replaced, never patched in place. The node group is recycled on a rolling basis so that ****no production compute node is older than 30 days****; the measured maximum node age during 2025 was 27 days. Container base images are rebuilt nightly from upstream and redeployed if the digest changes.

Operati

gs://attestor-505506-corporus/security/cloud-security-posture-standard.txt

[4] cloud-security-posture-standard — 4. Drift detection — relevance 0.59

4. Drift detection

Configuration drift is detected three ways:

1. ****Terraform Cloud drift detection**** runs every 24 hours against all 19 production workspaces and opens a PagerDuty ticket on any difference. Mean drift events per month in 2025: 1.4, nearly all from AWS-side attribute defaults changing.
2. ****AWS Config**** evaluates 147 rules continuously across every account, with the confo

gs://attestor-505506-corporus/security/cloud-security-posture-standard.txt

[5] pen-test-executive-summary — 3. Findings summary — relevance 0.59

3. Findings summary

| Severity | Found | Remediated | Retest verified |

|---|---|---|---|

| Critical | 0 | - | - |

| High | 1 | 1 | 18 March 2026 |

| Medium | 4 | 4 | 18 March 2026 |

| Low | 7 | 5 | 18 March 2026 |

| Informational | 9 | Accepted / tracked | - |

****No cross-tenant data access was achieved.**** Tenant isolation held under every tested condition, including direct object refere

gs://attestor-505506-corporus/security/pen-test-executive-summary.txt

[6] vulnerability-management-policy — 4. Penetration testing — relevance 0.59

4. Penetration testing

An independent penetration test is commissioned ****annually**** at minimum, and additionally before any significant architectural change. The most recent was performed by Include Security from 3 to 14 February 2026 (engagement INSEC-2026-0219). See the Penetration Test Executive Summary (KD-SEC-007).

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[7] network-security-standard — 6. Internal application access — relevance 0.56

6. Internal application access

There is no traditional VPN. Internal applications are published through Cloudflare Access

with device posture and Okta identity required on every request. This is a zero-trust model in the practical sense: there is no network position that grants access, and being "inside" confers nothing.

gs://attestor-505506-corporate/security/network-security-standard.txt

[8] pen-test-executive-summary — 7. Tester statement — relevance 0.55

7. Tester statement

"Kestrel Data demonstrates a mature security posture for an organisation of its size.

Tenant isolation is well implemented and defence in depth is evident throughout the platform. The single High finding was an availability and privacy concern rather than a confidentiality one."* - Include Security, 24 February 2026

gs://attestor-505506-corporate/security/pen-test-executive-summary.txt

[9] network-security-standard — 3. Segmentation — relevance 0.55

3. Segmentation

Each environment is a separate AWS account inside the AWS Organization ('kd-prod-us', 'kd-prod-eu', 'kd-staging', 'kd-dev', 'kd-security', 'kd-shared-services'). There is **no** VPC peering and no transit gateway route between production and non-production; the boundary is an account boundary, not a firewall rule that can be edited.

Within a production VPC there are three subnet t

gs://attestor-505506-corporate/security/network-security-standard.txt

[10] pen-test-executive-summary — 1. Scope — relevance 0.55

1. Scope

- Kestrel Insight web application ('app.kestreldata.com'), authenticated and unauthenticated surfaces
- Public REST API v2 ('api.kestreldata.com'), 89 endpoints
- Multi-tenant isolation testing across 3 seeded tenant accounts
- AWS cloud configuration review (IAM, S3, VPC, EKS)
- Authentication and session management, including the Okta SAML integration

Out of scope: physical se

gs://attestor-505506-corporate/security/pen-test-executive-summary.txt

250. Do you publish a transparency report of government data requests? If not, describe compensating controls.

legal · Q250 · Vendor Security Review row 251

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

251. When was your Information Security Policy last reviewed and approved? If not, describe compensating controls.

security · Q251 · Vendor Security Review row 252

Kestrel Data's Information Security Policy (KD-SEC-001, Version 4.2) was last reviewed and approved on 11 February 2026 by the Board Audit & Risk Committee, with the next scheduled review date set for 11 February 2027 (*Information Security Policy*, "Information Security Policy"). All security policies are reviewed at least annually and upon material change as part of our formal policy management process (*Risk Management and Governance*, "8. Policy management").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] risk-management-and-governance — 8. Policy management — relevance 0.73

8. Policy management

All security policies carry a document ID, a version, a named owner, an approval date, and a review date. Policies are reviewed at least annually and on material change. The 2026 review cycle covered 14 policies between 8 January and 12 February 2026; three were revised, and the changes were communicated at the February all-hands and through the annual acknowledgement cycle.

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[2] information-security-policy — Information Security Policy — relevance 0.72

Information Security Policy

****Document ID:**** KD-SEC-001

****Version:**** 4.2

****Owner:**** Marcus Oyelaran, Chief Information Security Officer

****Approved by:**** Board Audit & Risk Committee, 11 February 2026

****Last review:**** 11 February 2026 · ****Next review:**** 11 February 2027

****Classification:**** Internal — may be shared with customers under NDA

gs://attestor-505506-corporus/security/information-security-policy.txt

[3] company-and-security-programme-overview — Company and Security Programme Overview — relevance 0.67

Company and Security Programme Overview

****Document ID:**** KD-SEC-021 · ****Version:**** 4.2 · ****Owner:**** Marcus Oyelaran, CISO

****Approved:**** 6 February 2026 · ****Next review:**** 6 February 2027

****Maps to:**** SOC 2 CC1.1, CC1.2, CC2.1, CC2.3 · ISO 27001:2022 Clauses 4–5

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[4] personnel-security-and-training — 3. Acceptable use and policy acknowledgement — relevance 0.66

3. Acceptable use and policy acknowledgement

Personnel acknowledge the Acceptable Use Policy (KD-SEC-005) and this standard at onboarding and annually thereafter. Acknowledgement is tracked in Vanta; the 2025 annual cycle closed on 30 November 2025 at ****100%**** completion across 187 employees and 24 contractors.

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

[5] personnel-security-and-training — Personnel Security and Security Training Programme — relevance 0.66

Personnel Security and Security Training Programme

****Document ID:**** KD-SEC-013 · ****Version:**** 2.1 · ****Owner:**** Sofia Brenner, Head of IT

****Approved:**** 22 January 2026 · ****Next review:**** 22 January 2027

****Maps to:**** SOC 2 CC1.1, CC1.4, CC2.1, CC6.2 · ISO 27001:2022 A.6.1, A.6.2, A.6.3, A.6.6

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

252. Do you have a documented business continuity plan?

engineering · Q252 · Vendor Security Review row 253

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

253. Provide the results of your most recent disaster recovery test.

engineering · Q253 · Vendor Security Review row 254

Our disaster recovery restore capabilities are tested on a quarterly basis using full, real restores into an isolated environment rather than backup-listing verification (`backup-restore-procedure`, Section 4. Test results). The results of our most recent disaster recovery restore test are as follows: ****Test Date:**** 17 January 2026 (Q1 2026) ****Duration:**** 2 hours 41 minutes ****Integrity Assertions:**** 1,240 / 1,240 passed (validating row counts, referential integrity, tenant isolation invariants, and known-value spot checks) ****Outcome:**** Pass (`backup-restore-procedure`, Section 3. Restore procedure, Section 4. Test results)

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (6)

[1] backup-restore-procedure — 4. Test results — relevance 0.69

4. Test results

Restore is tested **quarterly**, and the test is a real restore, not a backup-listing check.

Quarter	Date	Duration	Assertions	Outcome
Q1 2026	17 Jan 2026	2h 41m	1,240 / 1,240	Pass
Q4 2025	11 Oct 2025	3h 02m	1,238 / 1,240	Pass, 2 known-stale fixtures corrected
Q3 2025	19 Jul 2025	3h 20m	1,240 / 1,240	Pass

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[2] backup-restore-procedure — 3. Restore procedure — relevance 0.63

3. Restore procedure

1. Declare the restore scope: point in time, and whether tenant-scoped or full.
2. Provision an isolated restore account from the Terraform module `restore-target`.
3. Restore the RDS snapshot or PITR target into the isolated account.
4. Run the integrity suite: 1,240 assertions covering row counts, referential integrity, tenant isolation invariants, and known-value spo

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[3] backup-restore-procedure — 5. Tenant-scoped restore — relevance 0.62

5. Tenant-scoped restore

A single customer can be restored without affecting others, by restoring to an isolated account and exporting that tenant rows back. This was exercised once in production, on 22 September 2025, at a customer request following an erroneous bulk delete on their side. Time to complete was 5 hours 10 minutes.

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[4] cloud-exit-and-portability-plan — 8. Testing — relevance 0.60

8. Testing

The plan is exercised annually as a tabletop with the SRE team, the VP Engineering, and the CISO. The 19 November 2025 exercise identified two gaps — the SQS/SNS adapter was not in place, and the KMS re-encryption path was undocumented — and both were closed by 14 January 2026. The next exercise is scheduled for November 2026.

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[5] backup-restore-procedure — Backup and Restore Procedure — relevance 0.56

Backup and Restore Procedure

Document ID: KD-ENG-004 · **Version:** 2.5 · **Owner:** Sofia Brenner, Head of IT
Approved: 29 January 2026 · **Maps to:** SOC 2 A1.2 · ISO 27001:2022 A.8.13

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[6] sdlc-policy — 3. Testing requirements — relevance 0.54

3. Testing requirements

- Unit test coverage gate at **80%** on changed lines, enforced in CI.
- Integration tests run against ephemeral infrastructure provisioned per pull request.
- Tenant isolation tests run on every build: a suite of 84 assertions attempting cross-tenant reads through every public API surface.
- Load tests before any release expected to change the performance profile.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

254. Describe your security monitoring and alerting capability.

security · Q254 · Vendor Security Review row 255

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] logging-monitoring-standard — 4. Alerting — relevance 0.65

4. Alerting

Detections run in Datadog Security Monitoring. Alert routing is by severity through PagerDuty. Current detection coverage includes impossible-travel sign-ins, MFA fatigue patterns, IAM policy changes granting broad permissions, disabling of CloudTrail or GuardDuty, unusual Snowflake export volume, and break-glass account use.

Alert quality is reviewed monthly. Alerts with a false

gs://attestor-505506-corporate/security/logging-monitoring-standard.txt

[2] soc2-control-matrix — Common Criteria — relevance 0.58

Common Criteria

Control	Description	Evidence	Test result
---------	-------------	----------	-------------

CC1.1	Board oversight of security; Audit and Risk Committee meets quarterly	Committee minutes, 4 meetings in 2025	No exceptions
-------	---	---------------------------------------	---------------

CC1.4	Security awareness training at hire and annually	Curricula completion records, 100% of active staff	No exceptions
-------	--	--	---------------

CC2.1	Internal communication of security		
-------	------------------------------------	--	--

gs://attestor-505506-corporate/security/soc2-control-matrix.txt

[3] logging-monitoring-standard — 5. Time synchronisation — relevance 0.56

5. Time synchronisation

All hosts synchronise to the Amazon Time Sync Service. Log timestamps are recorded in UTC in RFC 3339 format. Clock drift beyond 1 second triggers a SEV3.

gs://attestor-505506-corporate/security/logging-monitoring-standard.txt

[4] logging-monitoring-standard — Logging and Monitoring Standard — relevance 0.56

Logging and Monitoring Standard

Document ID: KD-SEC-009 · **Version:** 2.2 · **Owner:** Sofia Brenner, Head of IT

Approved: 15 January 2026 · **Next review:** 15 January 2027

Maps to: SOC 2 CC7.2 · ISO 27001:2022 A.8.15, A.8.16

gs://attestor-505506-corporate/security/logging-monitoring-standard.txt

[5] logging-monitoring-standard — 6. Customer access to logs — relevance 0.55

6. Customer access to logs

Enterprise-tier customers can retrieve tenant-scoped audit events for their own organisation through the Audit API (GET /v2/audit/events), covering the previous 365 days. Kestrel does not expose its own infrastructure logs to customers; relevant extracts are provided during incident response on request.

gs://attestor-505506-corporate/security/logging-monitoring-standard.txt

255. Please confirm: Can a developer approve their own pull request?

engineering · Q255 · Vendor Security Review row 256

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

256. Are long-lived static cloud access keys permitted?

security · Q256 · Vendor Security Review row 257

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

257. Are you PCI DSS compliant, and at what level?

security · Q257 · Vendor Security Review row 258

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

258. Please confirm: Do you use a VPN for internal application access, or a zero-trust approach?

security · Q258 · Vendor Security Review row 259

Kestrel Data uses a zero-trust architecture rather than a traditional VPN for internal application access. Access to internal applications is mediated through Cloudflare Access, requiring both Okta identity and device posture checks (including disk encryption, an up-to-date operating system, and an enrolled MDM profile) on every request. No network position confers access by default (`network-security-standard`, Section 6: "Internal application access"; `access-control-standard`, Section 10: "Remote access").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] network-security-standard — 6. Internal application access — relevance 0.75

6. Internal application access

There is no traditional VPN. Internal applications are published through Cloudflare Access with device posture and Okta identity required on every request. This is a zero-trust model in the practical sense: there is no network position that grants access, and being "inside" confers nothing.

`gs://attestor-505506-corporus/security/network-security-standard.txt`

[2] access-control-standard — 10. Remote access — relevance 0.62

10. Remote access

There is no traditional VPN. Access to internal applications is mediated by Cloudflare Access with device posture checks requiring disk encryption, a current OS, and an enrolled MDM profile (Kandji for macOS, 163 devices as of 1 February 2026).

`gs://attestor-505506-corporus/security/access-control-standard.txt`

[3] network-security-standard — 8. Wireless — relevance 0.60

8. Wireless

The Austin office wireless network is WPA3-Enterprise with certificate-based authentication for the corporate SSID and a fully segregated guest SSID that routes straight to the internet. Neither network grants any access to production; production is reached the same way from the office as from a coffee shop, which is deliberate.

`gs://attestor-505506-corporus/security/network-security-standard.txt`

[4] access-control-standard — 2. Multi-factor authentication — relevance 0.58

2. Multi-factor authentication

Hardware-backed MFA (WebAuthn / FIDO2, YubiKey 5 series) is mandatory for every human account. SMS and TOTP were removed as acceptable factors on 30 June 2025 following the RISK-2025-0031 treatment plan. Coverage is 100% of the 187 active employee accounts and 100% of the 24 active contractor accounts, verified continuously by Vanta control AC-07.

`gs://attestor-505506-corporus/security/access-control-standard.txt`

[5] network-security-standard — 5. Egress — relevance 0.57

5. Egress

Production workloads egress through NAT gateways with a domain allowlist enforced by AWS Network Firewall. The allowlist contains 23 destinations, each with a named owner and a business justification. An attempted connection to a destination outside the allowlist is blocked and alerted; 61 such alerts in 2025 were all traced to dependency mirrors being retired upstream.

`gs://attestor-505506-corporus/security/network-security-standard.txt`

259. Have you completed any Data Protection Impact Assessments?

legal · Q259 · Vendor Security Review row 260

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

260. Do you have a documented legal hold process?

legal · Q260 · Vendor Security Review row 261

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

261. Please confirm: Do you retain an external incident response firm?

security · Q261 · Vendor Security Review row 262

Yes. Kestrel Data retains Mandiant on a pre-negotiated incident response retainer (contract MNDT-2025-1180, effective September 1, 2025, with 40 pre-paid hours annually) providing a 4-hour response SLA for SEV1 incidents. Additionally, outside breach counsel is retained through Fenwick & West LLP (Incident Response Runbook, Section 7. External support).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] incident-response-runbook — 7. External support — relevance 0.67

7. External support

Kestrel retains **Mandiant** on a pre-negotiated incident response retainer (contract MNDT-2025-1180, effective 1 September 2025, 40 hours pre-paid annually) with a 4-hour response SLA for SEV1. Outside breach counsel is Fenwick and West LLP.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[2] incident-response-runbook — Incident Response Runbook — relevance 0.59

Incident Response Runbook

Document ID: KD-SEC-005 · **Version:** 5.0 · **Owner:** Marcus Oyelaran, CISO

Approved: 27 January 2026 · **Last exercised:** 3 December 2025 (tabletop)

Maps to: SOC 2 CC7.3, CC7.4, CC7.5 · ISO 27001:2022 A.5.24-A.5.28 · GDPR Art. 33, 34

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[3] incident-response-runbook — 6. Evidence handling — relevance 0.59

6. Evidence handling

The IC directs preservation before remediation wherever containment allows. EBS snapshots, memory captures where feasible, and relevant log ranges are exported to a dedicated forensics S3 bucket with Object Lock in compliance mode, retention 1 year. Chain of custody is recorded in the incident ticket.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[4] incident-response-runbook — 2. Roles — relevance 0.58

2. Roles

The Incident Commander owns the response and is deliberately not the person fixing the problem; ICs are drawn from a rota of 6 trained staff. The Communications Lead owns customer, internal, and regulator messaging. A Scribe maintains the timeline for every SEV1 and SEV2. Subject matter experts are pulled in as needed.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[5] incident-response-runbook — 9. 2025 incident summary — relevance 0.57

9. 2025 incident summary

41 security events recorded. Zero SEV1. Two SEV2, both resolved without customer data exposure:

- **INC-2025-0044** (14 August 2025) - RDS failover fault causing 41 minutes of degraded

service. No data loss; RPO and RTO both met. Root cause was a misconfigured connection pool ceiling.

- **INC-2025-0071** (2 November 2025) - a contractor account remained active f

gs://attestor-505506-corporus/security/incident-response-runbook.txt

262. What is your median time to triage a security alert?

security · Q262 · Vendor Security Review row 263

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

263. For each applicable system: Do you offer a single-tenant or dedicated instance deployment?

engineering · Q263 · Vendor Security Review row 264

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

264. Do you perform background checks on all personnel before their start date?

security · Q264 · Vendor Security Review row 265

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] personnel-security-and-training — 1. Pre-employment screening — relevance 0.65

1. Pre-employment screening

Every employee and every contractor is background screened before their start date. No system access — including email — is provisioned until the check clears; Okta Lifecycle Management is gated on the Rippling "screening cleared" attribute, so this is enforced by the provisioning pipeline rather than by a checklist.

Screening is performed by Checkr and covers, to the

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

[2] information-security-policy — 6. Personnel security — relevance 0.58

6. Personnel security

All employees and contractors undergo background screening appropriate to jurisdiction before their start date, conducted by Checkr. Screening covers identity verification, right to work, criminal records where lawful, and employment history for the preceding seven years.

Security awareness training is delivered through Curricula at onboarding and annually thereafter. Comple

gs://attestor-505506-corporus/security/information-security-policy.txt

[3] access-control-standard — 6. Joiners, movers, leavers — relevance 0.56

6. Joiners, movers, leavers

Joiners are provisioned via Okta Lifecycle Management from Rippling (HRIS); no access is granted before the background check clears. Movers have entitlements recalculated on role change, with the previous role revoked within 1 business day. Leavers have all access revoked automatically on the HRIS termination event: the target is 1 hour, and the measured median for

gs://attestor-505506-corporus/security/access-control-standard.txt

[4] information-security-policy — 11. Enforcement — relevance 0.56

11. Enforcement

Violation of this policy may result in disciplinary action up to and including termination of employment or contract, and referral to law enforcement where warranted.

Kestrel Data, Inc. · 1401 Lavaca Street, Suite 210, Austin, TX 78701 · Delaware C-corporation, incorporated 2019

gs://attestor-505506-corporus/security/information-security-policy.txt

[5] personnel-security-and-training — 2. Confidentiality obligations — relevance 0.55

2. Confidentiality obligations

All personnel sign a confidentiality agreement as a condition of employment or engagement. **The confidentiality obligation survives termination indefinitely for customer data and for five years for other Kestrel confidential information.** Contractors sign the same obligation through their engagement contract, and the obligation flows down to any of their own person

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

265. Can customers retrieve their own audit logs?

security · Q265 · Vendor Security Review row 266

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

266. How do you support erasure requests?

legal · Q266 · Vendor Security Review row 267

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

267. Describe your secure development lifecycle. If not, describe compensating controls.

engineering · Q267 · Vendor Security Review row 268

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (9)

[1] sdlc-policy — Secure Software Development Lifecycle Policy — relevance 0.76

Secure Software Development Lifecycle Policy

Document ID: KD-ENG-001 · **Version:** 4.1 · **Owner:** Dana Whitfield, VP Engineering

Approved: 20 January 2026 · **Next review:** 20 January 2027

Maps to: SOC 2 CC8.1 · ISO 27001:2022 A.8.25-A.8.31

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[2] data-flow-and-shared-responsibility — Data Flow and Shared Responsibility Model — relevance 0.69

Data Flow and Shared Responsibility Model

Document ID: KD-ENG-011 · **Version:** 2.0 · **Owner:** Dana Whitfield, VP Engineering

Approved: 2 February 2026 · **Next review:** 2 February 2027

Maps to: SOC 2 CC2.3, CC3.2, CC6.1 · ISO 27001:2022 A.5.2, A.5.8, A.8.9 · GDPR Article 28

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[3] third-party-library-policy — Third-Party Library Policy — relevance 0.69

Third-Party Library Policy

****Document ID:**** KD-ENG-008 · ****Version:**** 1.4 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 22 January 2026 · ****Maps to:**** SOC 2 CC7.1 · ISO 27001:2022 A.8.28

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[4] change-management-procedure — Change Management Procedure — relevance 0.68

Change Management Procedure

****Document ID:**** KD-ENG-002 · ****Version:**** 3.0 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 20 January 2026 · ****Maps to:**** SOC 2 CC8.1 · ISO 27001:2022 A.8.32

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[5] service-operations-and-support — Service Operations, Maintenance and Support — relevance 0.68

Service Operations, Maintenance and Support

****Document ID:**** KD-ENG-009 · ****Version:**** 2.2 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 23 January 2026 · ****Next review:**** 23 January 2027

****Maps to:**** SOC 2 A1.1, A1.2, CC7.3, CC8.1 · ISO 27001:2022 A.5.29, A.8.6, A.8.32

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[6] sdlc-policy — 4. Security in the pipeline — relevance 0.67

4. Security in the pipeline

Static analysis (Semgrep, CodeQL), dependency scanning (Snyk), IaC scanning (Checkov), and secret scanning (Gitleaks pre-commit plus GitHub push protection) all run on every pull request. A Critical or High dependency finding blocks the merge.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[7] sdlc-policy — 1. Branching and review — relevance 0.63

1. Branching and review

`main` is protected and always releasable. All work happens on short-lived branches merged by pull request. `main` requires:

- At least ****one approving review**** from a engineer other than the author. Self-approval is blocked at the platform level.

- Two approvals for changes touching authentication, authorisation, tenant isolation, or cryptography. These paths ar

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[8] sdlc-policy — 7. Separation of duties — relevance 0.61

7. Separation of duties

Engineers cannot deploy their own change to production without the automated pipeline: no human has the ability to push a container image to the production registry directly. The deployment role is held by the CI service identity, which authenticates through OIDC and holds no long-lived credentials.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[9] sdlc-policy — 5. Dependency policy — relevance 0.58

5. Dependency policy

New third-party dependencies require review against the Third-Party Library Policy (KD-ENG-008). Lockfiles are committed. Renovate opens automated upgrade pull requests weekly; security patches are auto-merged when CI is green and the change is a patch-level bump.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

268. Do you incorporate the UK International Data Transfer Addendum?

legal · Q268 · Vendor Security Review row 269

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

269. Provide your most recent SOC 2 Type II report.

security · Q269 · Vendor Security Review row 270

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

270. Is peer review mandatory for all code changes?

engineering · Q270 · Vendor Security Review row 271

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

271. What are your support response targets by severity?

engineering · Q271 · Vendor Security Review row 272

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

272. For each applicable system: Are passwords subject to a forced rotation schedule?

security · Q272 · Vendor Security Review row 273

Passwords are not subject to a forced rotation schedule, aligned with NIST SP 800-63B guidance ('access-control-standard', Section 9. Password requirements). Instead, rotation is enforced upon any evidence of compromise. Where passwords are used, they require a minimum length of 14 characters and are validated against the Have I Been Pwned breached-password corpus at creation.

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] access-control-standard — 9. Password requirements — relevance 0.69

9. Password requirements

Where a password is used, minimum length is 14 characters, checked against the Have I Been Pwned breached-password corpus at set time. Rotation is not forced on a schedule, in line with NIST SP 800-63B guidance; rotation is forced on evidence of compromise.

gs://attestor-505506-corporus/security/access-control-standard.txt

[2] access-control-standard — 1. Identity provider — relevance 0.60

1. Identity provider

All Kestrel Data systems authenticate through Okta (tenant `kestreldata.okta.com`). Local accounts on production systems are prohibited except for two documented break-glass accounts held in a sealed 1Password vault, whose use triggers a PagerDuty alert to the CISO. Both break-glass credentials were last rotated on 3 January 2026 and last used on 14 August 2025 during the

gs://attestor-505506-corporus/security/access-control-standard.txt

[3] access-control-standard — 2. Multi-factor authentication — relevance 0.58

2. Multi-factor authentication

Hardware-backed MFA (WebAuthn / FIDO2, YubiKey 5 series) is mandatory for every human account. SMS and TOTP were removed as acceptable factors on 30 June 2025 following the RISK-2025-0031 treatment plan. Coverage is 100% of the 187 active employee accounts and 100% of the 24 active contractor accounts, verified continuously by Vanta control AC-07.

gs://attestor-505506-corporus/security/access-control-standard.txt

[4] access-control-standard — 3. Role-based access — relevance 0.56

3. Role-based access

Access is granted to Okta groups, never to individuals. There are 41 defined roles, each mapping to a documented entitlement set in the Access Matrix (`SEC-GOV/access-matrix`), which is the authoritative record reviewed during audit. Standing production access is limited to 11 named Site Reliability Engineers. All other production access is just-in-time.

gs://attestor-505506-corporus/security/access-control-standard.txt

[5] access-control-standard — 6. Joiners, movers, leavers — relevance 0.56

6. Joiners, movers, leavers

Joiners are provisioned via Okta Lifecycle Management from Rippling (HRIS); no access is granted before the background check clears. Movers have entitlements recalculated on role change, with the previous role revoked within 1 business day. Leavers have all access revoked automatically on the HRIS termination event: the target is 1 hour, and the measured median for

gs://attestor-505506-corporus/security/access-control-standard.txt

273. Do you address Swiss FADP requirements?

legal · Q273 · Vendor Security Review row 274

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

274. Do you conduct post-incident reviews, and are they shared with customers? Provide supporting evidence.

security · Q274 · Vendor Security Review row 275

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

275. Are all company devices centrally managed and encrypted?

security · Q275 · Vendor Security Review row 276

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

276. How many internal forks of third-party libraries do you maintain?

engineering · Q276 · Vendor Security Review row 277

Kestrel deliberately maintains zero internal forks of third-party libraries. Any fork of a third-party library would require VP of Engineering approval and establish a requirement to manually track upstream security advisories (Third-Party Library Policy, Section 7: "Internal forks").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] third-party-library-policy — 7. Internal forks — relevance 0.72

7. Internal forks

Forking a third-party library requires VP Engineering approval and creates an obligation to track upstream security advisories manually. Kestrel currently maintains **zero** internal forks, deliberately.

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[2] sdlc-policy — 5. Dependency policy — relevance 0.62

5. Dependency policy

New third-party dependencies require review against the Third-Party Library Policy (KD-ENG-008). Lockfiles are committed. Renovate opens automated upgrade pull requests weekly; security patches are auto-merged when CI is green and the change is a patch-level bump.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[3] third-party-library-policy — 1. Adding a dependency — relevance 0.61

1. Adding a dependency

A new direct dependency requires a pull request that documents:

1. Why an existing dependency or the standard library is insufficient.
2. The licence, checked against the allowlist below.
3. Maintenance signal: last release date, open critical issues, number of maintainers.
4. Transitive dependency count added.

Review is by any engineer other than the author. Depend

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[4] third-party-library-policy — 6. Unmaintained dependencies — relevance 0.58

6. Unmaintained dependencies

A dependency with no release in 24 months and no active maintainer is flagged for replacement. Three such dependencies were identified in the January 2026 review, all scheduled for replacement by Q3 2026.

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[5] third-party-library-policy — 2. Licence policy — relevance 0.57

2. Licence policy

****Allowed:**** MIT, BSD-2-Clause, BSD-3-Clause, Apache-2.0, ISC, Python Software Foundation, Unlicense, CC0.

****Requires legal review:**** MPL-2.0, LGPL-2.1, LGPL-3.0, EPL-2.0.

****Prohibited:**** GPL-2.0, GPL-3.0, AGPL-1.0, AGPL-3.0, SSPL, BUSL, Commons Clause, and any licence without a clear grant. AGPL and SSPL are prohibited because Kestrel distributes a network service.

L

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

277. Do you offer customer-managed encryption keys?

engineering · Q277 · Vendor Security Review row 278

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] secrets-management-standard — 6. Customer-issued API credentials — relevance 0.59

6. Customer-issued API credentials

API keys issued to customers are stored as Argon2id hashes; Kestrel cannot recover the plaintext of a customer API key and will not do so on request. Keys are displayed once at creation. Customers can create, scope, and revoke keys through the console, and each key carries a last-used timestamp so stale keys are visible.

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

[2] data-flow-and-shared-responsibility — 1. Data flow, end to end — relevance 0.59

1. Data flow, end to end

1. ****Ingress.**** A customer's browser or API client resolves `app.kestreldata.com` or `api.kestreldata.com` to Cloudflare, which terminates TLS 1.3 (1.2 minimum) and applies

WAF and rate limiting.

2. **Instance selection.** DNS and tenant routing send the request to the instance chosen at contract signature: `us-east-1` or `eu-west-1`. **A tenant's requests never c**

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[3] secrets-management-standard — Secrets Management Standard — relevance 0.58

Secrets Management Standard

Document ID: KD-ENG-006 · **Version:** 2.1 · **Owner:** Dana Whitfield, VP Engineering

Approved: 22 January 2026 · **Maps to:** SOC 2 CC6.1 · ISO 27001:2022 A.8.24

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

[4] data-flow-and-shared-responsibility — 6. Where processing occurs — relevance 0.57

6. Where processing occurs

Processing occurs in AWS `us-east-1` (US instance) and AWS `eu-west-1` (EU instance), by personnel located in the United States, the European Union, the United Kingdom, and Canada, under the access controls in KD-SEC-002. **No processing occurs outside the stated regions**, and no support is subcontracted to a third-party provider in another jurisdiction.

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[5] secrets-management-standard — 4. Runtime access — relevance 0.57

4. Runtime access

Workloads obtain secrets at runtime through the AWS Secrets Manager CSI driver, mounted as in-memory `tmpfs` volumes. Secrets are never written to disk, never baked into container images, and never passed as environment variables where they could leak into a crash dump or a process listing.

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

278. Can a pull request merge with an unresolved Critical dependency finding?

engineering · Q278 · Vendor Security Review row 279

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

279. When was your Information Security Policy last reviewed and approved?

security · Q279 · Vendor Security Review row 280

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

280. For each applicable system: Is multi-factor authentication enforced for all personnel with production access?

security · Q280 · Vendor Security Review row 281

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

281. Is automatic email forwarding to external addresses permitted?

security · Q281 · Vendor Security Review row 282

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Evidence (5)

[1] acceptable-use-policy — 5. Email and communications — relevance 0.62

5. Email and communications

Kestrel uses Google Workspace with DMARC set to `p=reject`, SPF, and DKIM enforced on all sending domains. External email is banner-tagged. Automatic forwarding to external addresses is disabled at the tenant level and cannot be enabled by end users.

gs://attestor-505506-corporate/security/acceptable-use-policy.txt

[2] acceptable-use-policy — Acceptable Use Policy — relevance 0.54

Acceptable Use Policy

Document ID: KD-SEC-011 · **Version:** 2.3 · **Owner:** Sofia Brenner, Head of IT

Approved: 15 January 2026 · **Next review:** 15 January 2027

Applies to: all employees, contractors, and anyone issued Kestrel credentials

gs://attestor-505506-corporate/security/acceptable-use-policy.txt

[3] acceptable-use-policy — 3. Credentials — relevance 0.54

3. Credentials

Credentials are personal and may not be shared, including with other Kestrel staff. Shared team accounts are prohibited. Where a shared credential is unavoidable for a third-party service that does not support SSO, it is held in a 1Password shared vault with access logged, and the service is recorded on the SSO-gap register.

gs://attestor-505506-corporate/security/acceptable-use-policy.txt

[4] acceptable-use-policy — 4. Data handling — relevance 0.54

4. Data handling

Restricted data may not be copied to personal cloud storage, personal email, USB media, or unmanaged devices. USB mass storage is blocked at the OS level on all managed devices.

Screen sharing during customer calls must use a dedicated demo tenant, never production.

gs://attestor-505506-corporate/security/acceptable-use-policy.txt

[5] acceptable-use-policy — 6. Monitoring — relevance 0.51

6. Monitoring

Kestrel monitors use of its systems for security purposes as described in the Logging and Monitoring Standard. Monitoring is proportionate, is not used for productivity surveillance, and is disclosed to staff at onboarding.

gs://attestor-505506-corporate/security/acceptable-use-policy.txt

282. What is your turnaround commitment for data subject request assistance?

legal · Q282 · Vendor Security Review row 283

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

283. Have you completed a Transfer Impact Assessment? Provide supporting evidence.

legal · Q283 · Vendor Security Review row 284

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

284. Do you enforce API rate limiting?

engineering · Q284 · Vendor Security Review row 285

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

285. Are development, staging, and production environments separated?

engineering · Q285 · Vendor Security Review row 286

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (16)

[1] sdlc-policy — 2. Environments — relevance 0.69

2. Environments
| Environment | Purpose | Data |
|---|---|---|
| `local` | Developer machines | Synthetic fixtures only |
| `ci` | Automated testing | Synthetic fixtures only |
| `staging` | Pre-production verification | Synthetic and anonymised data |
| `production` | Live service | Customer data |

****Production data is never copied to a lower environment.**** Staging fixtures are generated

gs://attestor-505506-corpus/engineering/sdlc-policy.txt

[2] infrastructure-architecture-overview — 2. Account structure — relevance 0.66

2. Account structure
AWS Organizations with 9 accounts: `management`, `security-tooling`, `log-archive`, `shared-services`, `prod-us`, `prod-eu`, `staging`, `dev`, `sandbox`. Service Control Policies enforce guardrails at the Organization level, including mandatory EBS encryption, denial of root user actions, and denial of CloudTrail or GuardDuty disablement.

The `log-archive` account has no

gs://attestor-505506-corpus/engineering/infrastructure-architecture-overview.txt

[3] infrastructure-architecture-overview — 6. Network — relevance 0.65

6. Network
Private subnets for all compute and data. No public IP addresses on workload instances. Ingress is exclusively through Cloudflare, then an AWS Application Load Balancer, then the Istio ingress gateway. Egress is through NAT gateways with an allowlist for known destinations.

Security groups are managed in Terraform and default-deny. There are no `0.0.0.0/0` ingress rules in produc

gs://attestor-505506-corpus/engineering/infrastructure-architecture-overview.txt

[4] sdlc-policy — 7. Separation of duties — relevance 0.62

7. Separation of duties
Engineers cannot deploy their own change to production without the automated pipeline: no human has the ability to push a container image to the production registry directly. The deployment role is held by the CI service identity, which authenticates through OIDC and holds no long-lived credentials.

gs://attestor-505506-corpus/engineering/sdlc-policy.txt

[5] infrastructure-architecture-overview — 3. Compute — relevance 0.61

3. Compute
Amazon EKS (Kubernetes 1.31) with managed node groups spanning three availability zones. Workloads run as containers built from distroless base images, as non-root, with read-only root filesystems and dropped Linux capabilities. Pod Security Standards are enforced at the `restricted` level.

Node images are immutable; nodes are recycled with a maximum age of 30 days rather than pa

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[6] infrastructure-architecture-overview — Infrastructure Architecture Overview — relevance 0.61

Infrastructure Architecture Overview

Document ID: KD-ENG-003 · **Version:** 3.4 · **Owner:** Dana Whitfield, VP Engineering

Last updated: 5 February 2026 · **Classification:** Confidential, NDA required

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[7] infrastructure-architecture-overview — 5. Tenant isolation — relevance 0.60

5. Tenant isolation

Kestrel Insight is **multi-tenant** with logical isolation. There is no per-customer infrastructure, no single-tenant deployment option, and no customer-VPC option.

Isolation is enforced at three layers:

1. **Database** - PostgreSQL row-level security policies keyed on `tenant\_id`, applied at the connection level from an authenticated session variable. No application

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[8] sdlc-policy — 3. Testing requirements — relevance 0.59

3. Testing requirements

- Unit test coverage gate at **80%** on changed lines, enforced in CI.
- Integration tests run against ephemeral infrastructure provisioned per pull request.
- Tenant isolation tests run on every build: a suite of 84 assertions attempting cross-tenant reads through every public API surface.
- Load tests before any release expected to change the performance profile.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[9] sdlc-policy — 4. Security in the pipeline — relevance 0.57

4. Security in the pipeline

Static analysis (Semgrep, CodeQL), dependency scanning (Snyk), IaC scanning (Checkov), and secret scanning (GitLeaks pre-commit plus GitHub push protection) all run on every pull request. A Critical or High dependency finding blocks the merge.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[10] sdlc-policy — 1. Branching and review — relevance 0.57

1. Branching and review

`main` is protected and always releasable. All work happens on short-lived branches merged by pull request. `main` requires:

- At least **one approving review** from a engineer other than the author. Self-approval is blocked at the platform level.
- Two approvals for changes touching authentication, authorisation, tenant isolation, or cryptography. These paths ar

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[11] api-and-integration-standard — API, Authentication and Integration Standard — relevance 0.57

API, Authentication and Integration Standard

Document ID: KD-ENG-005 · **Version:** 2.6 · **Owner:** Dana Whitfield, VP Engineering

Approved: 21 January 2026 · **Next review:** 21 January 2027

Maps to: SOC 2 CC6.1, CC6.6, CC8.1 · ISO 27001:2022 A.5.15, A.8.5, A.8.26

gs://attestor-505506-corporus/engineering/api-and-integration-standard.txt

[12] sdlc-policy — Secure Software Development Lifecycle Policy — relevance 0.55

Secure Software Development Lifecycle Policy

Document ID: KD-ENG-001 · **Version:** 4.1 · **Owner:** Dana Whitfield, VP Engineering

Approved: 20 January 2026 · **Next review:** 20 January 2027

Maps to: SOC 2 CC8.1 · ISO 27001:2022 A.8.25-A.8.31

gs://attestor-505506-corporate/engineering/sdlc-policy.txt

[13] data-flow-and-shared-responsibility — Data Flow and Shared Responsibility Model — relevance 0.52

Data Flow and Shared Responsibility Model

Document ID: KD-ENG-011 · **Version:** 2.0 · **Owner:** Dana Whitfield, VP Engineering

Approved: 2 February 2026 · **Next review:** 2 February 2027

Maps to: SOC 2 CC2.3, CC3.2, CC6.1 · ISO 27001:2022 A.5.2, A.5.8, A.8.9 · GDPR Article 28

gs://attestor-505506-corporate/engineering/data-flow-and-shared-responsibility.txt

[14] data-flow-and-shared-responsibility — 4. Complementary user entity controls — relevance 0.50

4. Complementary user entity controls

The SOC 2 report lists these as complementary user entity controls; they are restated here because a customer reading only this document should still see them. If a customer does not operate the controls in the second list, Kestrel's controls in the first do not compensate: Kestrel cannot detect that a departed employee of the customer still holds a valid session

gs://attestor-505506-corporate/engineering/data-flow-and-shared-responsibility.txt

[15] api-and-integration-standard — 9. Integration security review — relevance 0.49

9. Integration security review

A new first-party integration is reviewed against this standard before release, covering credential handling, scope minimisation, rate limiting, and audit event emission. The review is recorded in the pull request and is a required check on the 'kd-api' repository.

gs://attestor-505506-corporate/engineering/api-and-integration-standard.txt

[16] data-flow-and-shared-responsibility — 3. The shared responsibility model — relevance 0.48

- * deciding what data they upload, and its lawfulness — Kestrel does not inspect it;
- * configuring SSO, and enforcing MFA at their own identity provider;
- * managing their own users, roles, and permissions, including timely removal of leavers;
- * the scope, storage, and rotation of the API credentials they create;
- * reviewing their own audit log, which Kestrel makes available for 13 months;
- * acting

gs://attestor-505506-corporate/engineering/data-flow-and-shared-responsibility.txt

286. Are customer API keys recoverable by your support team?

engineering · Q286 · Vendor Security Review row 287

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

287. Please confirm: Do you offer customer-managed encryption keys?

engineering · Q287 · Vendor Security Review row 288

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

288. Describe your change management process.

engineering · Q288 · Vendor Security Review row 289

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (6)

[1] change-management-procedure — 3. Emergency changes — relevance 0.71

3. Emergency changes

An Emergency change may bypass the Change Advisory step but never bypasses code review or CI. The Incident Commander authorises it, and a retrospective record is filed within one business day covering what changed, why the normal path was bypassed, and whether the change should be reworked.

All 9 Emergency changes in 2025 have completed retrospectives on file.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[2] change-management-procedure — 1. Change classes — relevance 0.69

1. Change classes

| Class | Definition | Approval | Example |

|---|---|---|---|

| **Standard** | Pre-approved, low risk, automated | PR review + CI | Application code, config change through IaC |

| **Normal** | Material risk or customer-visible | PR review + Change Advisory sign-off | Schema migration, dependency major version |

| **Emergency** | Fixing an active SEV1/SEV2 | Retrospective with

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[3] change-management-procedure — 2. Normal change requirements — relevance 0.68

2. Normal change requirements

A Normal change additionally requires a written rollback plan, a customer-impact assessment, and sign-off from the Change Advisory group (VP Engineering plus one SRE). Schema migrations must be backward compatible for at least one release, so that a rollback does not require a data migration.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[4] change-management-procedure — Change Management Procedure — relevance 0.67

Change Management Procedure

Document ID: KD-ENG-002 · **Version:** 3.0 · **Owner:** Dana Whitfield, VP Engineering

Approved: 20 January 2026 · **Maps to:** SOC 2 CC8.1 · ISO 27001:2022 A.8.32

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[5] change-management-procedure — 7. Change freeze — relevance 0.64

7. Change freeze

A change freeze applies from 20 December to 2 January, and during any active SEV1. Only Emergency changes are permitted during a freeze.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[6] change-management-procedure — 5. Database changes — relevance 0.53

5. Database changes

Migrations run through Atlas with a plan-and-approve step. Destructive operations (column drop, table drop) require a two-phase deployment separated by at least one release: the column is first stopped being read, then dropped in a later release.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

289. Please confirm: What is the export window available after termination?

legal · Q289 · Vendor Security Review row 290

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

290. What is the lawful basis for your product telemetry processing?

legal · Q290 · Vendor Security Review row 291

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] gdpr-records-of-processing — GDPR Records of Processing Activities (Art. 30) — relevance 0.65

GDPR Records of Processing Activities (Art. 30)

Document ID: KD-LEG-005 · **Version:** 3.0 · **Owner:** Priya Raghunathan, DPO

Last updated: 20 January 2026 · **Next review:** 20 July 2026

Maintained under Art. 30(1) where Kestrel is controller and Art. 30(2) where Kestrel is processor. Available to supervisory authorities on request.

gs://attestor-505506-corporus/legal/gdpr-records-of-processing.txt

[2] dpia-register — 5. Automated decision-making — relevance 0.65

5. Automated decision-making

Kestrel performs **no automated decision-making** producing legal effects or similarly significant effects concerning data subjects, within the meaning of Article 22. The two machine learning features described in KD-SEC-019 §2 surface information to the customer's own analysts; the decisions that follow are made by people at the customer, using the customer's own data

gs://attestor-505506-corporus/legal/dpia-register.txt

[3] gdpr-records-of-processing — Part A - Kestrel as Processor (Art. 30(2)) — relevance 0.65

Part A - Kestrel as Processor (Art. 30(2))

Controller: each Kestrel customer, as identified in the applicable Order Form.

Processor: Kestrel Data, Inc.

DPO: Priya Raghunathan, `dpo@kestreldata.com`

| # | Processing activity | Categories of data subject | Categories of personal data | Transfers | Retention |

|---|---|---|---|---|

| P1 | Hosting and operating the Kestrel Insig

gs://attestor-505506-corporus/legal/gdpr-records-of-processing.txt

[4] transfer-impact-assessment — 5. Supplementary measures relied on — relevance 0.65

5. Supplementary measures relied on

Technical:

- Data residency by default** — EU customer content, including backups and the replicated log ship, never leaves `eu-west-1`.
- Encryption in transit** — TLS 1.3 (1.2 minimum) on every hop, including between Kestrel and each sub-processor.
- Encryption at rest** — AES-256-GCM with keys in AWS KMS. Keys for the EU instance are held i

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

[5] data-processing-agreement — 1. Roles — relevance 0.64

1. Roles

Customer is **Controller**. Kestrel Data, Inc. is **Processor**. Where Customer is itself a processor for its own customers, Kestrel is sub-processor and the same obligations apply down the chain.

Kestrel is **Controller** for a limited set of data it determines the purposes of: account administrator contact details, billing records, and product telemetry described in Annex 3.

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

291. Do you operate active-active failover between regions?

engineering · Q291 · Vendor Security Review row 292

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

292. Have you ever received a national security request or National Security Letter?

legal · Q292 · Vendor Security Review row 293

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

293. What service credits apply if the availability commitment is missed?

legal · Q293 · Vendor Security Review row 294

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] master-agreement-summary — 10. Service levels — relevance 0.72

10. Service levels

The availability commitment, service credits, and support response targets are in the Availability SLA (KD-ENG-001). Service credits are the sole remedy for missed availability, with a termination right if the monthly commitment is missed in three consecutive months.

gs://attestor-505506-corpus/legal/master-agreement-summary.txt

[2] master-agreement-summary — 3. Liability — relevance 0.58

3. Liability

The standard limitation of liability is **12 months' fees paid** in the preceding twelve months. A **super-cap of 3x fees** applies to breaches of confidentiality, breaches of the data protection obligations, and Kestrel's indemnities. Liability for gross negligence, wilful misconduct, death or personal injury, and each party's indemnification obligations is uncapped to the extent the

gs://attestor-505506-corpus/legal/master-agreement-summary.txt

[3] master-agreement-summary — 7. Term, termination and transition — relevance 0.56

7. Term, termination and transition

The standard term is 12 months with automatic renewal on 30 days' notice of non-renewal. Either party may terminate for material breach uncured after 30 days, or immediately on the other's insolvency.

On termination the customer retains access to export their data for **30 days**, after which live data is deleted within 30 days and backups expire on the ordinar

gs://attestor-505506-corpus/legal/master-agreement-summary.txt

[4] master-agreement-summary — 8. Assignment and change of control — relevance 0.55

8. Assignment and change of control

Neither party may assign without the other's consent, except to a successor in a merger or sale of substantially all assets, subject to notice. Where the acquirer is a competitor of the customer, the customer may terminate within 30 days of notice.

gs://attestor-505506-corpus/legal/master-agreement-summary.txt

[5] master-agreement-summary — Master Subscription Agreement — Summary of Key Terms — relevance 0.51

Master Subscription Agreement — Summary of Key Terms

Document ID: KD-LEG-014 · **Version:** 3.2 · **Owner:** Aaron Feldstein, General Counsel

Approved: 28 January 2026 · **Next review:** 28 January 2027

Maps to: SOC 2 CC2.3, CC9.1 · GDPR Article 28

*A summary for review purposes. The executed agreement governs; where this summary and an executed contract differ, the contract prevails.

gs://attestor-505506-corpus/legal/master-agreement-summary.txt

294. What open source licences are prohibited in your codebase?

engineering · Q294 · Vendor Security Review row 295

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] third-party-library-policy — 2. Licence policy — relevance 0.69

2. Licence policy

****Allowed:**** MIT, BSD-2-Clause, BSD-3-Clause, Apache-2.0, ISC, Python Software Foundation, Unlicense, CC0.

****Requires legal review:**** MPL-2.0, LGPL-2.1, LGPL-3.0, EPL-2.0.

****Prohibited:**** GPL-2.0, GPL-3.0, AGPL-1.0, AGPL-3.0, SSPL, BUSL, Commons Clause, and any licence without a clear grant. AGPL and SSPL are prohibited because Kestrel distributes a network service.

L

gs://attestor-505506-corpus/engineering/third-party-library-policy.txt

[2] third-party-library-policy — 1. Adding a dependency — relevance 0.63

1. Adding a dependency

A new direct dependency requires a pull request that documents:

1. Why an existing dependency or the standard library is insufficient.
2. The licence, checked against the allowlist below.
3. Maintenance signal: last release date, open critical issues, number of maintainers.
4. Transitive dependency count added.

Review is by any engineer other than the author. Depend

gs://attestor-505506-corpus/engineering/third-party-library-policy.txt

[3] third-party-library-policy — 7. Internal forks — relevance 0.63

7. Internal forks

Forking a third-party library requires VP Engineering approval and creates an obligation to track upstream security advisories manually. Kestrel currently maintains ****zero**** internal forks, deliberately.

gs://attestor-505506-corpus/engineering/third-party-library-policy.txt

[4] third-party-library-policy — 6. Unmaintained dependencies — relevance 0.60

6. Unmaintained dependencies

A dependency with no release in 24 months and no active maintainer is flagged for replacement. Three such dependencies were identified in the January 2026 review, all scheduled for replacement by Q3 2026.

gs://attestor-505506-corpus/engineering/third-party-library-policy.txt

[5] third-party-library-policy — Third-Party Library Policy — relevance 0.57

Third-Party Library Policy

****Document ID:**** KD-ENG-008 · ****Version:**** 1.4 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 22 January 2026 · ****Maps to:**** SOC 2 CC7.1 · ISO 27001:2022 A.8.28

gs://attestor-505506-corpus/engineering/third-party-library-policy.txt

295. Do you conduct post-incident reviews, and are they shared with customers?

security · Q295 · Vendor Security Review row 296

Yes. Every SEV1 and SEV2 incident requires a blameless post-incident review conducted within five business days, which is published internally with resulting action items tracked to closure in Jira. These post-incident reviews are

shared with affected customers upon request (Incident Response Runbook, Section 8, "Post-incident review").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] incident-response-runbook — 8. Post-incident review — relevance 0.70

8. Post-incident review

Every SEV1 and SEV2 requires a blameless post-incident review within 5 business days, published internally, with action items tracked to closure in Jira. Reviews are shared with affected customers on request.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[2] incident-response-runbook — 2. Roles — relevance 0.60

2. Roles

The Incident Commander owns the response and is deliberately not the person fixing the problem; ICs are drawn from a rota of 6 trained staff. The Communications Lead owns customer, internal, and regulator messaging. A Scribe maintains the timeline for every SEV1 and SEV2. Subject matter experts are pulled in as needed.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[3] incident-response-runbook — Incident Response Runbook — relevance 0.59

Incident Response Runbook

Document ID: KD-SEC-005 · **Version:** 5.0 · **Owner:** Marcus Oyelaran, CISO

Approved: 27 January 2026 · **Last exercised:** 3 December 2025 (tabletop)

Maps to: SOC 2 CC7.3, CC7.4, CC7.5 · ISO 27001:2022 A.5.24-A.5.28 · GDPR Art. 33, 34

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[4] incident-response-runbook — 6. Evidence handling — relevance 0.59

6. Evidence handling

The IC directs preservation before remediation wherever containment allows. EBS snapshots, memory captures where feasible, and relevant log ranges are exported to a dedicated forensics S3 bucket with Object Lock in compliance mode, retention 1 year. Chain of custody is recorded in the incident ticket.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[5] incident-response-runbook — 1. Severity definitions — relevance 0.57

1. Severity definitions

| Sev | Definition | Page | Exec notify |

|---|---|---|---|

| **SEV1** | Confirmed unauthorised access to customer production data, or full platform outage | Immediate, 24/7 | CEO + CISO within 30 min |

| **SEV2** | Suspected compromise, partial outage affecting more than 10% of tenants, or confirmed data integrity fault | Immediate, 24/7 | CISO within 1 hour |

| **SEV3**

gs://attestor-505506-corporus/security/incident-response-runbook.txt

296. Please confirm: How are security responsibilities communicated to personnel?

security · Q296 · Vendor Security Review row 297

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

297. Is multi-factor authentication enforced for all personnel with production access?

security · Q297 · Vendor Security Review row 298

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

298. When does your ISO 27001 certification expire?

security · Q298 · Vendor Security Review row 299

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

299. How many secrets have been committed to your repositories in the last year?

engineering · Q299 · Vendor Security Review row 300

Quarantined: Model Armor blocked this question.

Release status: No — quarantined by the guardrail · confidence low · drafted by ArmorGuard

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

300. Do you generate a Software Bill of Materials for production builds?

engineering · Q300 · Vendor Security Review row 301

Yes. Kestrel generates a CycloneDX Software Bill of Materials (SBOM) for every production container image at build time. These SBOMs are retained for two years and can be provided to customers upon request under NDA ('third-party-library-policy', Section 3, "Software Bill of Materials").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] third-party-library-policy — 3. Software Bill of Materials — relevance 0.73

3. Software Bill of Materials

Kestrel generates a CycloneDX SBOM for every production container image at build time. SBOMs are retained for 2 years and are provided to customers on request under NDA. The current production SBOM covers 1,184 components across 6 services.

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[2] sdlc-policy — Secure Software Development Lifecycle Policy — relevance 0.58

Secure Software Development Lifecycle Policy

Document ID: KD-ENG-001 · **Version:** 4.1 · **Owner:** Dana Whitfield, VP Engineering

Approved: 20 January 2026 · **Next review:** 20 January 2027

Maps to: SOC 2 CC8.1 · ISO 27001:2022 A.8.25-A.8.31

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[3] sdlc-policy — 3. Testing requirements — relevance 0.54

3. Testing requirements

- Unit test coverage gate at **80%** on changed lines, enforced in CI.
- Integration tests run against ephemeral infrastructure provisioned per pull request.
- Tenant isolation tests run on every build: a suite of 84 assertions attempting cross-tenant reads through every public API surface.
- Load tests before any release expected to change the performance profile.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[4] sdlc-policy — 4. Security in the pipeline — relevance 0.54

4. Security in the pipeline

Static analysis (Semgrep, CodeQL), dependency scanning (Snyk), IaC scanning (Checkov), and secret scanning (Gitleaks pre-commit plus GitHub push protection) all run on every pull request. A Critical or High dependency finding blocks the merge.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[5] third-party-library-policy — Third-Party Library Policy — relevance 0.54

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

301. For each applicable system: Can an engineer deploy directly to production, bypassing the pipeline?

engineering · Q301 · Vendor Security Review row 302

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] sdlc-policy — 7. Separation of duties — relevance 0.68

7. Separation of duties

Engineers cannot deploy their own change to production without the automated pipeline: no human has the ability to push a container image to the production registry directly. The deployment role is held by the CI service identity, which authenticates through OIDC and holds no long-lived credentials.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[2] sdlc-policy — 4. Security in the pipeline — relevance 0.61

4. Security in the pipeline

Static analysis (Semgrep, CodeQL), dependency scanning (Snyk), IaC scanning (Checkov), and secret scanning (GitLeaks pre-commit plus GitHub push protection) all run on every pull request. A Critical or High dependency finding blocks the merge.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[3] sdlc-policy — 6. Release — relevance 0.57

6. Release

Releases are continuous: merge to `main` triggers a deployment to staging, an automated verification suite, and then a progressive rollout to production. Rollout is canary-based: 5% of traffic for 15 minutes, then 25%, then 100%, with automatic rollback on error-rate or latency regression.

Median lead time from merge to production in 2025 was **34 minutes**. Change failure rate w

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[4] sdlc-policy — 1. Branching and review — relevance 0.57

1. Branching and review

`main` is protected and always releasable. All work happens on short-lived branches merged by pull request. `main` requires:

- At least **one approving review** from a engineer other than the author. Self-approval is blocked at the platform level.
- Two approvals for changes touching authentication, authorisation, tenant isolation, or cryptography. These paths ar

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[5] sdlc-policy — 2. Environments — relevance 0.55

2. Environments

| Environment | Purpose | Data |

|---|---|---|

| `local` | Developer machines | Synthetic fixtures only |

| `ci` | Automated testing | Synthetic fixtures only |

| `staging` | Pre-production verification | Synthetic and anonymised data |

| `production` | Live service | Customer data |

****Production data is never copied to a lower environment.**** Staging fixtures are generated

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

302. Is the platform accessible from the public internet without authentication?

security · Q302 · Vendor Security Review row 303

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (9)

[1] network-security-standard — 6. Internal application access — relevance 0.67

6. Internal application access

There is no traditional VPN. Internal applications are published through Cloudflare Access with device posture and Okta identity required on every request. This is a zero-trust model in the practical sense: there is no network position that grants access, and being "inside" confers nothing.

gs://attestor-505506-corporus/security/network-security-standard.txt

[2] access-control-standard — 3. Role-based access — relevance 0.64

3. Role-based access

Access is granted to Okta groups, never to individuals. There are 41 defined roles, each mapping to a documented entitlement set in the Access Matrix (`SEC-GOV/access-matrix`), which is the authoritative record reviewed during audit. Standing production access is limited to 11 named Site Reliability Engineers. All other production access is just-in-time.

gs://attestor-505506-corporus/security/access-control-standard.txt

[3] network-security-standard — 4. Inbound rules — relevance 0.61

4. Inbound rules

****There are no unrestricted inbound rules (`0.0.0.0/0`) in any production security group other than ports 80 and 443 on the load balancer security group, which are themselves restricted to Cloudflare ranges.**** SSH ingress is closed entirely; administrative access is through AWS Systems Manager Session Manager, which requires an IAM identity and produces a recorded session.

Config

gs://attestor-505506-corporus/security/network-security-standard.txt

[4] cloud-security-posture-standard — 7. Cloud identity — relevance 0.60

7. Cloud identity

Human access to AWS is federated from Okta through IAM Identity Center; there are ****no IAM users with long-lived access keys in any account****, and the SCP set prevents their creation. Workloads use IAM Roles for Service Accounts. The last static access key in the estate was decommissioned on 17 November 2024.

gs://attestor-505506-corporus/security/cloud-security-posture-standard.txt

[5] access-control-standard — 8. Service accounts and machine identity — relevance 0.60

8. Service accounts and machine identity

Workloads authenticate using short-lived credentials: AWS IAM Roles for Service Accounts (IRSA) in EKS, and Workload Identity Federation for GCP components. Long-lived static access keys are prohibited; the last was decommissioned on 17 November 2024. Automated detection for newly created static keys runs hourly and pages the on-call SRE.

gs://attestor-505506-corporus/security/access-control-standard.txt

[6] access-control-standard — 9. Password requirements — relevance 0.59

9. Password requirements

Where a password is used, minimum length is 14 characters, checked against the Have I

Been Pwned breached-password corpus at set time. Rotation is not forced on a schedule, in line with NIST SP 800-63B guidance; rotation is forced on evidence of compromise.

gs://attestor-505506-corporus/security/access-control-standard.txt

[7] network-security-standard — 1. Perimeter — relevance 0.59

1. Perimeter

All customer traffic enters through Cloudflare. The AWS Application Load Balancers accept connections only from Cloudflare IP ranges, enforced by security group rules and verified by a synthetic check that attempts a direct origin connection hourly and alerts if it succeeds. The origin has not been reachable directly since 4 September 2024.

gs://attestor-505506-corporus/security/network-security-standard.txt

[8] network-security-standard — 2. Web application firewall — relevance 0.57

2. Web application firewall

****Cloudflare WAF is enabled on all production hostnames**, running the Cloudflare Managed Ruleset, the OWASP Core Ruleset at paranoia level 2, and 14 Kestrel-authored rules. Rules are deployed in log mode for 7 days before enforcement so that a false positive is found before it blocks a customer. Blocked request volume averaged 41,000 per day during 2025, of which the I**

gs://attestor-505506-corporus/security/network-security-standard.txt

[9] company-and-security-programme-overview — 8. How to obtain evidence — relevance 0.55

8. How to obtain evidence

The SOC 2 Type II report, the ISO 27001 certificate, the penetration test executive summary, and the standard DPA are available to customers and prospects under NDA through the account team, usually within two business days. The certificate and the trust page are available without an NDA.

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

303. Is security awareness training mandatory, and at what frequency?

security · Q303 · Vendor Security Review row 304

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] personnel-security-and-training — 4. Security awareness training — relevance 0.70

4. Security awareness training

Security awareness training is ****mandatory for all personnel, annually, plus at onboarding within the first 14 days****. Training is delivered through Curricula and runs approximately 45 minutes, covering phishing, credential handling, data classification, secure remote working, and incident reporting.

Measured completion for the 2025 cycle was ****99.5%**** (210 of 211 i

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

[2] personnel-security-and-training — Personnel Security and Security Training Programme — relevance 0.60

Personnel Security and Security Training Programme

****Document ID:** KD-SEC-013 · ****Version:** 2.1 · ****Owner:**** Sofia Brenner, Head of IT****

****Approved:** 22 January 2026 · ****Next review:** 22 January 2027****

****Maps to:** SOC 2 CC1.1, CC1.4, CC2.1, CC6.2 · ISO 27001:2022 A.6.1, A.6.2, A.6.3, A.6.6**

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

[3] information-security-policy — 6. Personnel security — relevance 0.59

6. Personnel security

All employees and contractors undergo background screening appropriate to jurisdiction before their start date, conducted by Checkr. Screening covers identity verification,

right to work, criminal records where lawful, and employment history for the preceding seven years.

Security awareness training is delivered through Curricula at onboarding and annually thereafter. Comple

gs://attestor-505506-corporus/security/information-security-policy.txt

[4] personnel-security-and-training — 5. Simulated phishing — relevance 0.59

5. Simulated phishing

Kestrel runs simulated phishing exercises **quarterly** through Curricula, targeting all personnel with a Kestrel mailbox. Results for 2025:

Quarter	Sent	Click rate	Credential submission	Reported to security
Q1 2025	198	6.1%	1.0%	41%
Q2 2025	203	4.4%	0.5%	52%
Q3 2025	208	3.4%	0.0%	58%
Q4 2025	211			2

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

[5] personnel-security-and-training — 6. Secure development training — relevance 0.58

6. Secure development training

Engineers complete role-specific secure development training annually, in addition to the general awareness training. The 2025 curriculum was Secure Code Warrior's OWASP Top 10 path plus an internal module on tenant isolation written by the platform team after the INSEC-2026-0219 penetration test. Completion for the 63 engineers in scope was 100% as of 19 December 20

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

304. Is automatic email forwarding to external addresses permitted? If not, describe compensating controls.

security · Q304 · Vendor Security Review row 305

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

305. Describe the data flow for customer data through your platform.

engineering · Q305 · Vendor Security Review row 306

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

306. Are audit logs tamper-resistant? Describe the mechanism.

security · Q306 · Vendor Security Review row 307

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

307. Provide your measured median access revocation time for the last 12 months. Provide supporting evidence.

security · Q307 · Vendor Security Review row 308

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

308. Are backups replicated across regions? Do they leave the residency boundary? Provide supporting evidence.

legal · Q308 · Vendor Security Review row 309

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

309. Provide your measured SLA compliance rate for the last 12 months.

engineering · Q309 · Vendor Security Review row 310

According to the Service Level Agreement documentation, Kestrel Data's measured availability performance is recorded annually: * **2025:** 99.97% measured availability, with 0 months falling below the 99.9% commitment and 0 service credits issued (`availability-sla`, Section 5). * **2024:** 99.94% measured availability, with 1 month falling below 99.9% (March at 99.87%) and 1 customer credit issued (`availability-sla`, Section 5). Uptime is calculated on a monthly percentage basis and measured via independent third-party monitoring running checks across global locations (`availability-sla`, Section 2).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] availability-sla — 2. Definitions — relevance 0.73

2. Definitions

****Uptime**** is the percentage of minutes in a calendar month during which the Service is Available, calculated as:

$$\text{Uptime \%} = ((\text{Total Minutes} - \text{Downtime Minutes}) / \text{Total Minutes}) \times 100$$

****Downtime**** is any minute during which all requests to the production API from the external monitoring network return a 5xx error or fail to connect. Measurement is by independent third-p

gs://attestor-505506-corpus/engineering/availability-sla.txt

[2] availability-sla — 5. Historical performance — relevance 0.69

5. Historical performance

| Year | Measured availability | Months below 99.9% | Credits issued |

|---|---|---|---|

| 2025 | 99.97% | 0 | 0 |

| 2024 | 99.94% | 1 (March, 99.87%) | 1 customer, 10% |

| 2023 | 99.91% | 1 (August, 99.82%) | 3 customers, 10% |

gs://attestor-505506-corpus/engineering/availability-sla.txt

[3] availability-sla — 4. Service credits — relevance 0.68

4. Service credits

| Monthly uptime | Credit (% of monthly fee) |

|---|---|

| Below 99.9% but at or above 99.0% | 10% |

| Below 99.0% but at or above 95.0% | 25% |

| Below 95.0% | 50% |

Credits are the sole and exclusive remedy for failure to meet this SLA. A claim must be submitted within ****30 days**** of the end of the affected month, with supporting detail.

Credits are applied to the nex

gs://attestor-505506-corpus/engineering/availability-sla.txt

[4] service-operations-and-support — 8. Capacity and performance — relevance 0.66

8. Capacity and performance

Capacity is reviewed monthly against a 90-day forecast. Autoscaling handles ordinary variation; the review exists for the changes autoscaling cannot absorb, such as a large tenant onboarding. Two capacity increases were made ahead of demand in 2025, neither triggered by a saturation alert.

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[5] service-operations-and-support — 6. Monitoring and alerting — relevance 0.65

6. Monitoring and alerting

Datadog holds infrastructure metrics, application performance monitoring, and synthetic checks running every 60 seconds from five geographic locations against both instances. Alerts are symptom-based — error rate, latency percentile, saturation, and synthetic failure — rather than cause-based, so a novel failure still pages someone.

Uptime is measured from the synthetic

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

310. Have you completed any Data Protection Impact Assessments? If not, describe compensating controls.

legal · Q310 · Vendor Security Review row 311

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] dpia-register — 6. Review cadence — relevance 0.68

6. Review cadence

Each completed DPIA is reviewed annually, and immediately on a material change to the processing it covers. The 2026 review cycle for all four assessments completed on 16 January 2026, with no changes to the residual risk ratings.

gs://attestor-505506-corporus/legal/dpia-register.txt

[2] dpa-annex-2-technical-measures — DPA Annex 2 - Technical and Organisational Measures — relevance 0.66

DPA Annex 2 - Technical and Organisational Measures

Document ID: KD-LEG-009 · **Version:** 4.0 · **Owner:** Marcus Oyelaran, CISO
Effective: 1 February 2026 · Annex to the DPA (KD-LEG-001)
Maps to: GDPR Art. 32

Measures are described at a level that allows a controller to assess adequacy under Art. 32 without exposing information that would itself create risk.

gs://attestor-505506-corporus/legal/dpa-annex-2-technical-measures.txt

[3] dpia-register — Data Protection Impact Assessment Register — relevance 0.64

Data Protection Impact Assessment Register

Document ID: KD-LEG-011 · **Version:** 1.9 · **Owner:** Priya Raghunathan, DPO
Approved: 16 January 2026 · **Next review:** 16 January 2027
Maps to: GDPR Articles 35, 36, 9, 8, 22

gs://attestor-505506-corporus/legal/dpia-register.txt

[4] dpia-register — 2. Completed assessments — relevance 0.64

2. Completed assessments

Four DPIAs have been completed, all reviewed and signed off by the DPO:

ID	Subject	Completed	Residual risk	Outcome
----	---------	-----------	---------------	---------

---	---	---	---	---
-----	-----	-----	-----	-----

DPIA-2024-01	Product telemetry collection and retention	14 May 2024	Low	Proceed. Event allowlist introduced; free-text fields excluded; retention set to 13 months
--------------	--	-------------	-----	--

DPIA-2025-01	EU instance and residency arc			
--------------	-------------------------------	--	--	--

gs://attestor-505506-corporus/legal/dpia-register.txt

[5] gdpr-records-of-processing — Data Protection Impact Assessments — relevance 0.63

Data Protection Impact Assessments

One DPIA is on file, covering the introduction of the anomaly detection feature

(‘LEG-GOV/dpia-2025-01’, completed 8 September 2025). Conclusion: residual risk low, no prior consultation with the supervisory authority required.

gs://attestor-505506-corporus/legal/gdpr-records-of-processing.txt

311. How frequently may a customer audit, and on what notice?

legal · Q311 · Vendor Security Review row 312

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

312. What is your scheduled maintenance window? Provide supporting evidence.

engineering · Q312 · Vendor Security Review row 313

Kestrel Data's standard scheduled maintenance window is Sundays from 06:00 to 10:00 UTC. Most changes do not require the use of this window, as deployments are rolling and zero-downtime. When scheduled maintenance is expected to be customer-affecting, customers are provided with at least 7 days' advance notice (and 30 days' notice if customer action is required) via email to tenant administrators and postings on the status page. Emergency maintenance for critical security fixes may be performed with shorter notice under the emergency change path, with notifications sent as soon as the change is scheduled. ****Supporting Evidence:**** ****Service Operations, Maintenance and Support (KD-ENG-009)*, Section 2: "Scheduled maintenance" * *Availability Service Level Agreement (KD-ENG-007)*, Section 3: "Exclusions"**

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (5)

[1] service-operations-and-support — 2. Scheduled maintenance — relevance 0.73

2. Scheduled maintenance

The standard maintenance window is ****Sundays 06:00–10:00 UTC****. Most changes do not use it: deployments are rolling and zero-downtime, and 2025 saw 1,412 production deployments with no customer-visible downtime.

****Customers receive at least 7 days' notice of scheduled maintenance expected to be customer-affecting**, and 30 days' notice where the change requires customer a**

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[2] availability-sla — 3. Exclusions — relevance 0.67

3. Exclusions

Downtime does not include unavailability caused by:

- Scheduled maintenance, notified at least 7 days in advance, in the window Sundays 04:00-06:00 UTC, capped at 4 hours per month.
- Emergency maintenance to address a security vulnerability, notified as soon as practicable.
- Customer configuration, customer code, or customer exceeding documented rate limits.
- Failure o

gs://attestor-505506-corporus/engineering/availability-sla.txt

[3] service-operations-and-support — Service Operations, Maintenance and Support — relevance 0.63

Service Operations, Maintenance and Support

****Document ID:** KD-ENG-009 · ****Version:** 2.2 · ****Owner:** Dana Whitfield, VP Engineering******

****Approved:** 23 January 2026 · ****Next review:** 23 January 2027****

****Maps to:** SOC 2 A1.1, A1.2, CC7.3, CC8.1 · ISO 27001:2022 A.5.29, A.8.6, A.8.32**

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[4] availability-sla — 6. Support response targets — relevance 0.61

6. Support response targets

Support targets are separate from this SLA and are not credit-bearing.

| Severity | First response | Coverage |

|---|---|---|

| Urgent (production down) | 1 hour | 24 x 7 |

| High (major feature impaired) | 4 business hours | Business hours |

| Normal | 1 business day | Business hours |

| Low | 3 business days | Business hours |

Business hours are 08:00-18:00

gs://attestor-505506-corporus/engineering/availability-sla.txt

[5] availability-sla — Availability Service Level Agreement — relevance 0.58

Availability Service Level Agreement

Document ID: KD-ENG-007 · **Version:** 3.0 · **Owner:** Aaron Feldstein, General Counsel

Effective: 1 January 2026 · Forms part of the Master Subscription Agreement

gs://attestor-505506-corporus/engineering/availability-sla.txt